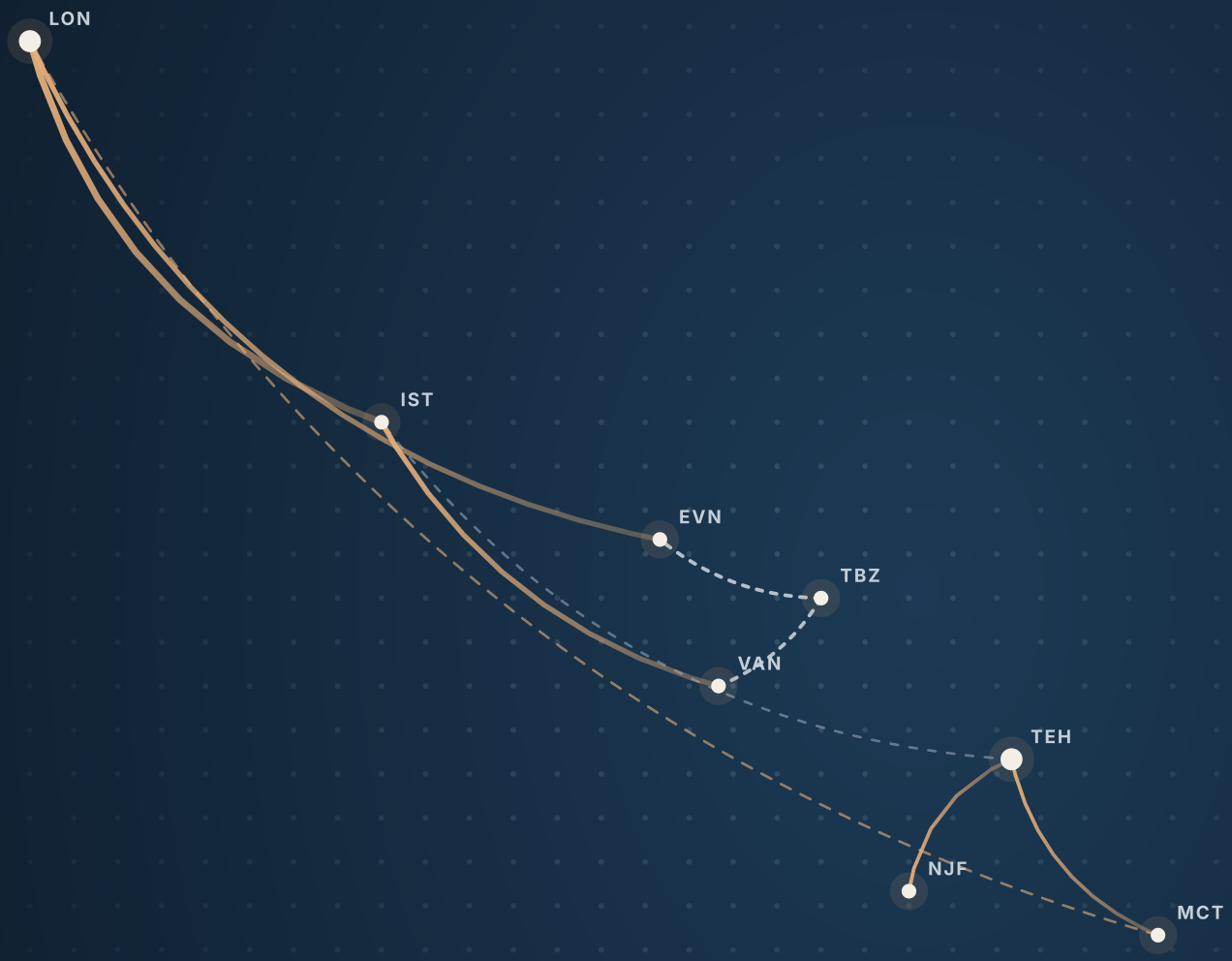
UNI TRAVEL



Flight & Cargo Request Platform

Implementation Booklet

Research, product design and technical architecture for the Uni Travel website, mobile app, Admin Panel and Developer Panel — flights between Iran, the UK and Europe, connecting-itinerary construction, fare variants, and cargo transport requests.

Version	Date	Covers project phases	Prepared with
1.0 — for approval	22 October 2026	2 · 3 · 4	Claude (Anthropic)

About this booklet

A single reference for building Uni Travel's flight and cargo request platform: what the research found, what the product does, how the system is built, and how delivery proceeds — written so that Uni Travel, its counsel, and the engineers and Claude Code sessions doing the build all work from the same page.

WHO IT IS FOR

- **Owner and management** — Parts A and E, and the decision register in Chapter 2.
- **Operations and admins** — Part C (journeys, request lifecycle, Admin Panel).
- **Counsel and compliance** — Chapters 3, 4, 9, 27 and 28.
- **Developers and Claude Code** — Parts C and D, Chapter 35 and the reference in Chapter 36.

HOW IT IS ORGANISED

- **Part A — Context and strategy:** summary, scope, the 2026 operating environment, legal considerations.
- **Part B — Research:** flight data, providers, seat maps, messaging and hosting, cargo.
- **Part C — Product design:** users and roles, journeys, ticket types, lifecycles, panels, notifications.
- **Part D — Technical architecture:** modules, engine, data model, API, security, clients, infrastructure.
- **Part E — Delivery:** roadmap, testing, risks, open questions, playbook, reference, sources.

EVIDENCE AND STATUS LABELS

DOCUMENTED	Stated in official documentation, vendor terms or government publications.
REPORTED	Reported by press or reference sources; not confirmed by the primary party.
OBSERVED	Seen directly during this work.
INFERRED	Our reasoning from the evidence; needs confirmation.
UNKNOWN	Could not be verified; listed in Chapter 34.
BLOCKED	Could not be checked because access was refused.
PROPOSED	A design proposal or stack addition needing approval.
DECIDED	A decision taken by Uni Travel (see Chapter 2).

CALLOUTS

Decision	A decision or recommendation.
Counsel	Needs legal sign-off before it is relied on.
Rule	A hard rule the implementation must enforce.
Implementation	Guidance for developers.

DOCUMENT CONTROL

VERSION	DATE	STATUS	NOTES
1.0	22 Oct 2026	For approval	First complete edition. Research current to 22 October 2026. Incorporates Uni Travel's decisions of 22 October 2026 (D-01, D-03, D-04, D-05).

IMPORTANT

This booklet contains research on sanctions, export controls, travel regulation and data protection to inform system design. It is not legal advice. Facts about airlines, routes, vendors and regulations change quickly; every item marked Reported or Unknown should be re-checked before it is relied on, and the whole document should be reviewed at each stage gate.

Approved by (Uni Travel) | Date | Comments / conditions

Contents

PART A · CONTEXT AND STRATEGY

1 Executive summary 8
- 1.1 The reality check 8
- 1.2 What we recommend 8
- 1.3 Decisions already taken 9
- 1.4 Top risks 9
- 1.5 Roadmap at a glance 9
- 1.6 The next 30 days 9

2 Scope, principles and decisions 10
- 2.1 What is being built 10
- 2.2 Scope 10
- 2.3 Principles 11
- 2.4 Decisions register 11
- 2.5 Assumptions 12
- 2.6 Where this booklet sits in the project roadmap 12

3 The operating environment in October 2026 13
- 3.1 What changed in 2026 13
- 3.2 The corridor today 14
- 3.3 What this means for the platform 14
- 3.4 What has not changed 15

4 Legal and regulatory considerations 16
- 4.1 Why this is a first-order design concern 16
- 4.2 The sanctions picture 16
- 4.3 Implications for flights 17
- 4.4 Implications for payments 17
- 4.5 Travel regulation (ATOL) 17
- 4.6 Cargo and export controls 17
- 4.7 Data protection 17
- 4.8 Questions for counsel 17

PART B · RESEARCH AND RECOMMENDATIONS

5 How flight data works 20
- 5.1 Kinds of flight data 20
- 5.2 Distribution channels 20
- 5.3 The two categories in the brief 21
- 5.4 Evaluation criteria 21

6 Flight data providers 22
- 6.1 Summary of findings 22
- 6.2 Amadeus Enterprise — primary 23
- 6.3 Duffel — secondary 24
- 6.4 Schedules and minimum connection times — later 24
- 6.5 Travel document checks — optional 24
- 6.6 What the providers can actually offer from Iran today 24
- 6.7 Recommendation 25

7 Seat maps 26
- 7.1 What the research found 26
- 7.2 Product decision 26
- 7.3 Normalised seat map model 27
- 7.4 Rendering rules 27

8 Messaging, notifications and hosting vendors 28
- 8.1 SMS and one-time codes 28
- 8.2 Push notifications 29
- 8.3 Email 29
- 8.4 App distribution and web reachability 29
- 8.5 Internet shutdowns 29
- 8.6 Recommended vendor set 30

9 Cargo partners and constraints 31
- 9.1 Couriers and postal services, UK → Iran 31
- 9.2 Digital air-cargo platforms 31
- 9.3 Excess baggage and personal effects 32
- 9.4 Overland and intermediaries 32
- 9.5 UK trade controls that touch cargo 32
- 9.6 Consequences for the design 32

PART C · PRODUCT DESIGN

10 Users, roles and surfaces 34
10.1 Who uses the platform 34
10.2 Roles 34
10.3 Permission catalogue 35
10.4 Surfaces 36
10.5 Role switching on mobile 37

11 Customer journeys 38
11.1 Journey map 38
11.2 J1 — Sign up and sign in 38
11.3 J2 — Search and request an itinerary 39
11.4 J3 — Manual request 40
11.5 J4 — Tracking and responding 40
11.6 J6 — Travellers and documents 41
11.7 J7 — Preferences 41

12 Ticket types and fare variants 42
12.1 Scope decision 42
12.2 Trip structures 42
12.3 Cabins, booking classes and fare basis 42
12.4 Passenger types 43
12.5 Fare brands (fare families) 43
12.6 Ticketing models 44
12.7 Special service requests 44
12.8 Ancillaries 44
12.9 Summary of enumerations 44

13 Flight request lifecycle 45
13.1 Seven objects that must never be confused 45
13.2 States 45
13.3 Transitions and guards 47
13.4 Reference numbers 48
13.5 Assignment, queues and SLA timers 48
13.6 Quotes 48
13.7 Reservations, tickets and payments in version 1 49
13.8 After-sales 49
13.9 History and audit 49

14 Cargo transport requests 50
14.1 Scope 50
14.2 Lanes 50
14.3 What the customer provides 51
14.4 Goods screening 51
14.5 Lifecycle 52
14.6 Quotes for cargo 53
14.7 Service availability register 53
14.8 Partners and handover 53
14.9 Documents 54

15 Admin Panel 55
15.1 Design principles 55
15.2 Screens 55
15.3 Request detail in depth 56
15.4 Contacting customers 56
15.5 Quote builder 56
15.6 Cargo detail specifics 57
15.7 Compliance cases 57
15.8 Mobile admin mode 57

16 Developer Panel 58
16.1 Access and protection 58
16.2 Sections 58
16.3 How configuration reaches the running system 60

17 Notifications and communication 61
17.1 Channels 61
17.2 Event catalogue 61
17.3 Routing algorithm 62
17.4 Templates 63
17.5 Delivery tracking 63
17.6 Admin alerts without alert fatigue 63

PART D · TECHNICAL ARCHITECTURE

18 Architecture overview 65
18.1 Architectural drivers 65
18.2 Architectural style 65
18.3 System context 66
18.4 Containers 66
18.5 Technology stack 67
18.6 The truth model 68
18.7 Key decisions at a glance 68

19 Repository and code organisation 70
19.1 Monorepo layout 70
19.2 Module boundary rules 71
19.3 Conventions 71
19.4 Branching, environments and CI 71
19.5 Generated artefacts 72

20 Backend modules 73
20.1 Module map 73
20.2 Dependency direction 74
20.3 Inside a module 75
20.4 The request pipeline 75
20.5 Concurrency and consistency 76

21 Supplier integration framework 77
21.1 Principles 77
21.2 The adapter interface 77
21.3 The normalised model 78
21.4 Planned providers 78
21.5 Call lifecycle 79
21.6 Error taxonomy 79
21.7 Deduplication across providers 80
21.8 Testing adapters 80
21.9 Checklist for adding a provider 80

22 Itinerary and connection engine 81
22.1 Three ways to get from A to B 81
22.2 Inputs 81
22.3 Connection rules 81
22.4 The pipeline 83
22.5 Validating connections 84
22.6 Scoring 84
22.7 Diversity 85
22.8 Progressive results and timing 85
22.9 Caching and cost control 85
22.10 What gets frozen in the snapshot 86
22.11 Worked example — Tehran to London 86
22.12 Known limits in version 1 86

23 Data model 87
23.1 Domain map 87
23.2 Conventions 87
23.3 Identity and access 88
23.4 Customers 88
23.5 Reference data 88
23.6 Suppliers and search 89
23.7 Requests, quotes and bookings 89
23.8 Cargo 90
23.9 Compliance 91
23.10 Notifications, documents, configuration and platform 91
23.11 Example: Drizzle definition 92
23.12 Database roles and safety 93

24 API design 94
24.1 Conventions 94
24.2 Errors 94
24.3 Endpoint catalogue — customer and public 95
24.4 Endpoint catalogue — Admin Panel 96
24.5 Endpoint catalogue — Developer Panel 97
24.6 Webhooks (inbound) 97
24.7 Example: starting a search 98
24.8 Example: one result item 98
24.9 Example: server-sent events 99

25 Authentication and authorisation 100
25.1 Sign-in with a one-time code 100
25.2 Tokens and sessions 101
25.3 Email as an alternative 102
25.4 Account linking and recovery 102
25.5 Staff authentication 102
25.6 Authorisation 102
25.7 Rate limits 103

26 Background jobs, events and caching 104
26.1 The transactional outbox 104
26.2 Queues 104
26.3 Domain events 105
26.4 Redis usage 106
26.5 Performance budgets 106

27 Compliance engine 107
27.1 What is checked, when 107
27.2 Sanctions list ingestion 107
27.3 Matching Persian names 108
27.4 Policies 108
27.5 Cases and decisions 109
27.6 Payment timing and ATOL 109
27.7 Evidence and retention 109

28 Security and privacy 110
28.1 Threat model 110
28.2 Secrets and keys 110
28.3 Encryption 111
28.4 Web and console hardening 111
28.5 Logging and the audit log 111
28.6 Privacy (UK GDPR) 111
28.7 Verification before launch 112

29 Website, console and mobile app 113
29.1 Website (Next.js) 113
29.2 Console (Next.js) 113
29.3 Mobile app (Expo / React Native) 113 PROPOSED
29.4 Internationalisation and right-to-left 114
29.5 Accessibility 115

30 Infrastructure, deployment and operations 116

30.1 Hosting constraints discovered in research 116
30.2 Environments 116
30.3 Deployment topology PROPOSED 117
30.4 CI/CD 117
30.5 Observability 118
30.6 Backups and recovery 118
30.7 Runbooks (to be written in Stage 6) 118

PART E · DELIVERY

31 Delivery roadmap 121
31.1 Stages at a glance 121
31.2 Stage 0 — Commercial, legal and discovery (weeks 0–4, parallel) 121
31.3 Stage 1 — Foundations (weeks 1–5) 122
31.4 Stage 2 — Requests and Admin Panel (weeks 4–9) 122
31.5 Stage 3 — Search and itinerary engine (weeks 7–14) 122
31.6 Stage 4 — Mobile app (weeks 10–16) 122
31.7 Stage 5 — Cargo (weeks 12–17) 122
31.8 Stage 6 — Hardening, pilot and launch (weeks 16–20) 123
31.9 Stage 7 — After launch 123

32 Testing and quality 124
32.1 Test layers 124
32.2 Invariants tested by property 124
32.3 Permission matrix tests 125
32.4 Benchmark queries 125
32.5 Compliance matcher evaluation 125
32.6 Test data 125
32.7 User acceptance 125
32.8 Definition of done (per story) 125

33 Risk register 127

34 Open questions and unknowns 128
34.1 Decisions owed by Uni Travel 128
34.2 Questions for counsel 128
34.3 Questions for providers 128
34.4 Research unknowns 129

35 Implementation playbook for Claude Code 130
35.1 Rules of engagement 130
35.2 Working method 130
35.3 Epics 131
35.4 Sample stories with acceptance criteria 131
35.5 Sprint 1 and 2 (two weeks each) 132

36 Reference 133
36.1 Glossary 133
36.2 Configuration keys (defaults) 134
36.3 Environment variables 135

37 Sources 136
37.1 Corridor, airlines and aviation sanctions 136
37.2 UK sanctions, trade controls and regulation 136
37.3 Flight data providers 137
37.4 Messaging, push, hosting and distribution 137
37.5 Cargo 138

PART A

A

Context and strategy

What Uni Travel is building, why the brief's example route no longer exists, the decisions taken so far, and the legal ground rules that shape every later chapter.

01	Executive summary	8
02	Scope, principles and decisions	10
03	The operating environment in October 2026	13
04	Legal and regulatory considerations	16

CHAPTER 1

Executive summary

Uni Travel wants a website, mobile app and staff panels that find real flight combinations from Iran to the UK and Europe, take requests, and add cargo. This booklet designs that platform for the world as it is on 22 October 2026 — which is very different from the world the brief assumed.

27
IRANIAN AIRLINES DESIGNATED BY THE US ON 8 SEP 2026

Mar 2027
EARLIEST RETURN OF TURKISH CARRIERS TO IRAN

17 Jul 2026
AMADEUS SELF-SERVICE APIS CLOSED; ENTERPRISE ONLY

1.1 The reality check

- **The example route no longer exists.** Turkish Airlines, AJet and Pegasus have no Iran flights before March 2027; every remaining Iranian airline is under US sanctions, and Iran Air also under UK and EU sanctions. Only a few foreign carriers fly into Iran (for example Iraqi Airways via Najaf, SalamAir via Muscat). Travellers are crossing overland to Türkiye and Armenia to fly onward.
- **Several standard tools do not work for this customer base.** Stripe prohibits dealings with people in, resident in or citizens of Iran. Twilio, Vonage and SendGrid no longer reach Iran. Google's push service and Google Maps are unavailable or prohibited there, and some hosts block Iranian visitors.
- **Legal exposure is real and strict.** UK sanctions breaches carry strict-liability penalties, and the US has warned foreign firms against selling tickets for Iranian airlines. UK travel rules (ATOL) affect when payment may be taken.

1.2 What we recommend

PRODUCT

- One platform: website, one mobile app (customer and admin modes), Admin Panel and Developer Panel, sharing one backend.
- A **request-based** service in v1: the platform finds and quotes; staff reserve and ticket in existing tools and record the results; nothing is shown as booked before it is.
- An **itinerary engine** that combines supplier itineraries, self-transfers via hubs with configurable layover rules (default preferred window 4–6 h), and **gateway starts** from Türkiye and Armenia — all configurable as the corridor changes.
- **Cargo** as request-and-quote through vetted partners, with Iran lanes disabled until counsel approves.

TECHNOLOGY

- The Engineering Kit stack: Next.js, React, TypeScript, Tailwind, shadcn/ui, Base UI; NestJS REST; PostgreSQL with Drizzle; Redis and BullMQ.
- Proposed additions: Expo for mobile, pnpm/Turborepo, Zod contracts, OpenTelemetry, Docker on UK/EU hosting.
- A **modular monolith** with API and worker processes, a transactional outbox, versioned configuration and a compliance module.
- Flight data from **Amadeus Enterprise** (primary, via Uni Travel's existing relationship) and **Duffel** (secondary, seat maps), plus staff-entered options. No scraping, ever.

1.3 Decisions already taken

Iranian carriers are excluded by default (D-01); no online payments in v1 (D-03); ticket types mean flight fare variants (D-04); cargo covers documents and parcels, excess baggage and commercial air freight (D-05). The full register is in Chapter 2.

1.4 Top risks

RISK	MITIGATION
Sanctions breach through a sale, payment or partner	Counsel review before launch; automated screening and policy gates with human decisions
Suppliers decline the customer profile	Early disclosure; adapter framework; manual service works without suppliers
Very little to sell from Iran	Gateways, hubs as configuration, manual requests as a first-class path
Customers unreachable during shutdowns	SMS through Iranian routes, inbox, alternative contacts, honest status

1.5 Roadmap at a glance

STAGE	WEEKS	OUTCOME
0 Commercial, legal, discovery	0–4 (parallel)	Counsel's position, supplier access, vendors chosen
1 Foundations	1–5	Sign-in (+98 and international), roles, Developer Panel core
2 Requests and Admin Panel	4–9	**Manual-request service live** (milestone M1)
3 Search and engine	7–14	Real itineraries with connections and gateways
4 Mobile app	10–16	Customer and admin modes
5 Cargo	12–17	Cargo requests behind compliance gates
6 Hardening and launch	16–20	Pen test, pilot, launch

1.6 The next 30 days

1. Approve this booklet, or mark the parts to change (stack additions, defaults, decisions marked "Proposed").
2. Instruct sanctions and travel-regulation counsel with the questions in Chapter 4.
3. Open the Amadeus Enterprise conversation (Chapter 6) and complete the read-only Flight Builder discovery; open a Duffel test account.
4. Choose SMS, email and hosting vendors after the terms review in Chapters 8 and 30.
5. Start Stage 1 (foundations) in parallel; target the manual-request service for week 9 and launch for week 20 (Chapter 31).

CHAPTER 2

Scope, principles and decisions

What version 1 includes and excludes, the principles every design choice in this booklet follows, and the decisions taken so far — with who took them.

2.1 What is being built

One platform with six parts, sharing a single backend:

PART	USERS	PURPOSE
Customer website	Customers	Search, request flights and cargo, track requests, manage travellers
Mobile app	Customers; admins in admin mode	The same customer features, plus admin triage on the move
Admin Panel	Admins, cargo admins, compliance officers	Turn requests into quotes, reservations, tickets and shipments
Developer Panel	Developers, owner	Users and roles, providers, engine rules, workflows, notifications, audit, diagnostics
Flight search and itinerary engine	All of the above	Build real, ranked itineraries including connections and gateway starts
Cargo request service	Customers, cargo admins	Request-and-quote for documents, parcels, personal effects and air freight

2.2 Scope

AREA	VERSION 1	LATER STAGES	OUT OF SCOPE
Flight search	Through itineraries, self-transfer via one hub, gateway starts; two providers + manual options	Schedules/MCT data, more providers, multi-hub self-transfer	Scraped data of any kind
Booking	Requests, quotes, staff-recorded reservations and tickets	Automated orders and ticketing through provider APIs	—
Ticket types	Flight fare variants (Chapter 12)	Group and charter handling	Bus, rail, ferry tickets
Payments	Offline, staff-recorded, ATOL-aware	Online payments with a provider counsel approves	Stripe for Iran-linked customers
Seat maps	Seat preference	View-only maps (Stage 3); selection at booking (Stage 7)	Copied or generic layouts presented as real
Cargo	Documents/parcels, excess baggage, air freight; request-and-quote	Partner APIs for tracking	Road freight
Channels	Website, iOS/Android app, SMS, push, email, in-app inbox	—	Telegram (brief §11)
Languages	English, Persian (RTL)	Others on demand	—

2.3 Principles

1. **Truth before convenience.** Every flight shown carries its source and time; nothing is shown as booked until a reservation or ticket record exists; unknown baggage stays unknown.
2. **A request is not a booking.** Search results, requests, quotes, reservations, tickets and payments are separate objects with separate lifecycles.
3. **The backend is the authority.** Roles, permissions, statuses and flight data are decided server-side; clients render.
4. **Compliance by design.** Screening and policies run before staff act; decisions are recorded; counsel's answers become configuration.
5. **Configuration over code.** Hubs, gateways, connection rules, workflows, templates and policies are versioned data editable in the Developer Panel.
6. **Built for Iranian conditions.** No Google dependencies in critical paths, SMS fallback, light pages, honest failure during shutdowns.
7. **Simple to operate.** A modular monolith on a small number of machines; no microservices or extra infrastructure without a demonstrated need.
8. **Provider-agnostic.** Suppliers sit behind adapters; switching one off never breaks the product.

2.4 Decisions register

ID	DECISION	STATUS	SOURCE
D-01	Flight segments operated or marketed by Iranian airlines (all now US-designated; Iran Air also UK/EU-designated) are **excluded by default**, through a compliance policy that can be changed only with counsel's approval	DECIDED	Uni Travel, 22 Oct 2026
D-02	Version 1 is **request-based**: the platform searches and quotes; staff reserve and ticket in existing tools and record the results	PROPOSED	Brief §8 + this booklet
D-03	**No online payments** in version 1; staff record offline payments; Stripe parked	DECIDED	Uni Travel, 22 Oct 2026
D-04	"Ticket types" means **flight fare variants**; ground, charter/group and rail/ferry tickets out of scope	DECIDED	Uni Travel, 22 Oct 2026
D-05	Cargo covers **documents and small parcels, excess baggage / personal effects, commercial air freight**; Iran lanes start disabled pending counsel	DECIDED (scope) · PROPOSED (lanes)	Uni Travel, 22 Oct 2026
D-06	Stack follows the Engineering Kit; additions (Expo, pnpm/Turborepo, Zod, TanStack Query, Pino/OpenTelemetry, Docker/Caddy) are proposals needing approval	PROPOSED	Chapter 18
D-07	Seat maps: preference in v1, view-only maps in Stage 3, selection only with automated booking	PROPOSED	Chapter 7
D-08	Gateway departures are shown with **information-only** access notes; overland travel is not sold	PROPOSED	Follows D-04
D-09	English and Persian at launch, with Jalali date display	PROPOSED default	Question (c)
D-10	Host in the UK/EU with vendors checked for Iranian reachability and sanctions terms; no Google services in critical paths	PROPOSED	Chapters 8, 30
D-11	One mobile app with role-based customer and admin modes; Developer Panel on the web only	PROPOSED	Brief §9
D-12	Telegram is not part of version 1	DECIDED	Brief §11

2.5 Assumptions

These defaults were proposed on 22 October 2026 and stand until Uni Travel says otherwise:

#	ASSUMPTION	EFFECT IF WRONG
A-1	The Engineering Kit stack is the one recorded for this project (Next.js, React, TypeScript, Tailwind, shadcn/ui, Base UI; NestJS REST; PostgreSQL, Drizzle; Redis, BullMQ; Stripe). The Kit names no mobile framework or hosting	Chapter 18 stack table changes
A-2	Uni Travel is a UK-registered company with an Amadeus agency relationship and no API ticketing yet	Provider plan and ATOL position change
A-3	Customers are mainly Iranian students and families in the UK and in Iran	Language and channel defaults change
A-4	First destinations: UK, then Germany, Netherlands, France, then wider Europe	Hub tables and provider markets change
A-5	The booklet is in English; branding neutral until a logo and colours are supplied	Cosmetic only

2.6 Where this booklet sits in the project roadmap

The project's agreed roadmap has six phases, with a stop for approval after each deliverable: (1) understand the Amadeus panel and authorised integration; (2) finalise requirements and workflow; (3) data model, integration boundaries, reservation states and payment consistency; (4) implementation plan; (5) implement and verify in a test environment; (6) deploy and monitor. **This booklet is the deliverable for phases 2–4.** Phase 1's read-only discovery of the Amadeus Flight Builder panel has not yet been carried out and is scheduled as part of Stage 0 in Chapter 31. Implementation (phase 5) should start only after Uni Travel approves this booklet.

CHAPTER 3

The operating environment in October 2026

The brief was written around a Tehran → Istanbul → London itinerary. In October 2026 that itinerary is not available: war, sanctions and airline decisions have removed most flights out of Iran. The platform must be built for a corridor that changes month to month.

3.1 What changed in 2026

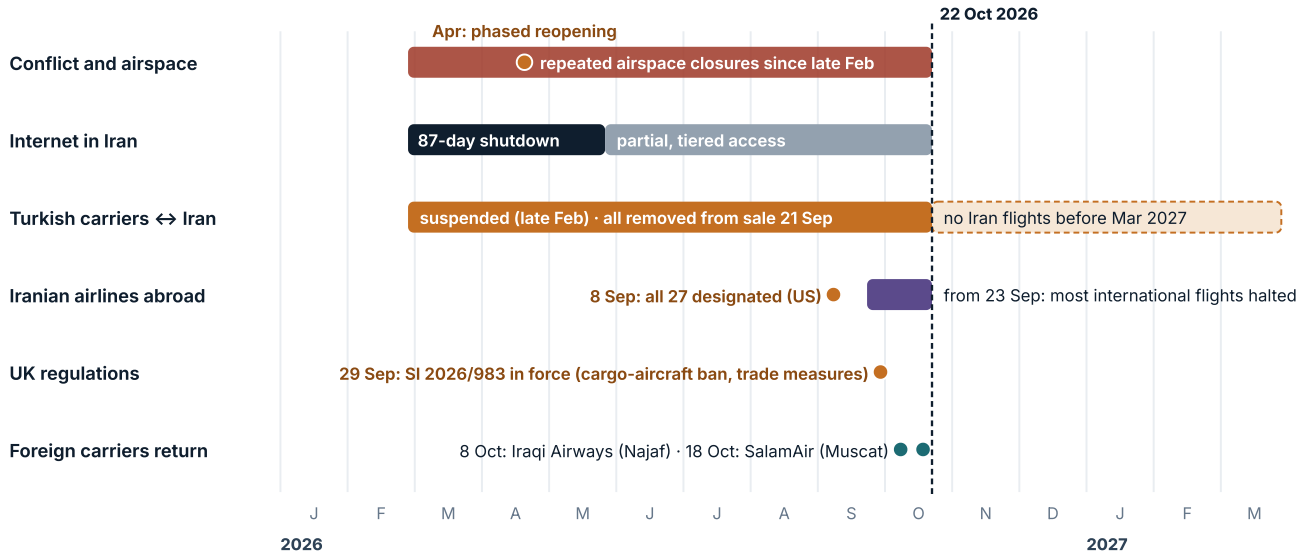


Figure 3.1 — Events that shape the Iran–UK corridor. Dates as reported; sources in Chapter 37.

DATE	EVENT	LABEL
Oct–Nov 2024	EU sanctions Iran Air, Mahan Air and Saha Airlines; the UK cancels bilateral air-service arrangements and designates Iran Air (asset freeze). Scheduled Iran–Europe flights end	DOCUMENTED
Mar 2025	Twilio stops messaging, voice and email to recipients in Iran	DOCUMENTED
Late Feb 2026	US and Israeli strikes on Iran; airspace closures; Turkish carriers suspend Iran services	REPORTED
28 Feb – 26 May 2026	87-day national internet shutdown in Iran, then partial, tiered restoration	REPORTED
Apr 2026	Phased reopening of Tehran's airports; first international services to Istanbul and Muscat	REPORTED
Aug 2026	Iran's international seat capacity about half of August 2025	REPORTED
8 Sep 2026	US designates all 27 remaining Iranian airlines and suspends the licence that let foreign airlines fly US-content aircraft into Iran; the UK lays new Iran sanctions regulations	DOCUMENTED
21–23 Sep 2026	Turkish Airlines, AJet and Pegasus remove Iran flights (none before March 2027); wind-down ends and neighbouring states stop servicing Iranian carriers; travellers move to land crossings into Türkiye and Armenia	REPORTED
29 Sep 2026	UK Iran (Sanctions) (Amendment) Regulations 2026 in force, including a landing ban on Iranian cargo aircraft and new trade prohibitions	DOCUMENTED
8 Oct 2026	International flights resume at Tehran IKA, starting with Iraqi Airways from Najaf	REPORTED

DATE	EVENT	LABEL
18 Oct 2026	SalamAir resumes Muscat–Tehran twice weekly	REPORTED

3.2 The corridor today

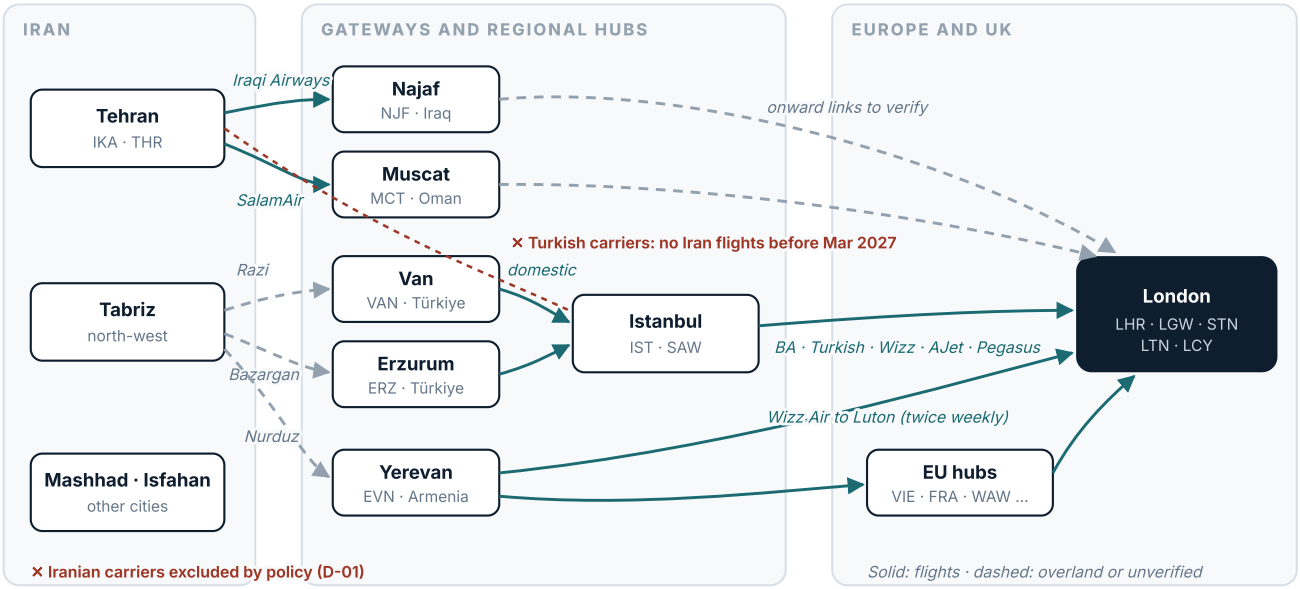


Figure 3.2 — Schematic of the routes that remain (not to scale, not geographic). Solid lines are flights that providers may be able to sell; dashed lines are overland journeys the customer makes on their own.

Three practical routes remain for a traveller from Iran to the UK:

1. **Fly out on a foreign carrier to a regional hub** — currently a handful of services such as Iraqi Airways via Najaf and SalamAir via Muscat — then connect to Europe. Capacity is small and could change at any time.
2. **Travel overland to a gateway** in Türkiye (Van, Erzurum, then Istanbul) or Armenia (Yerevan), then fly. This is what most travellers are reported to be doing; border congestion and bus prices have risen sharply.
3. **Wait** for carriers to return; Turkish carriers indicate March 2027 at the earliest, without guarantees.

3.3 What this means for the platform

REALITY	DESIGN CONSEQUENCE	WHERE
Routes appear and disappear within weeks	Hubs, gateways and access notes are configuration with `active` flags, owned by operations	Ch. 16, 22
Iranian carriers are designated by the US, and some by the UK and EU	Carrier policy excludes them by default; any change requires counsel	Ch. 4, 27
Overland legs are part of real journeys	Gateway starts are a first-class result type, with access information — but no ground ticketing in v1	Ch. 12, 22
Few itineraries are bookable from Iran	Manual requests and staff options are central, not a fallback	Ch. 11, 13
Customers' internet may disappear for weeks	SMS through an Iranian provider; honest status; staff-side continuity	Ch. 8, 17
Many Western platforms block Iranian users	Vendor and hosting choices checked for Iranian reachability and terms	Ch. 8, 30

3.4 What has not changed

The demand in the brief is real and probably larger: Iranian students and families still need to reach the UK and Europe, and they need help assembling journeys from fragments. The parts of the brief that are independent of the corridor — honest flight data, a connection engine with configurable rules, request tracking, admin and developer control — are exactly what makes a service useful in these conditions.

CHAPTER 4

Legal and regulatory considerations

Sanctions, export controls, travel regulation and data protection shape what the platform may sell, to whom and how it takes money. This chapter summarises what the research found and lists the questions Uni Travel's lawyers must answer before launch.

> **NOT LEGAL ADVICE**
>
> This chapter is research to inform system design. It is not legal advice and must not be relied on as such. Uni Travel should instruct UK sanctions and travel-regulation counsel (with US sanctions input) before selling any itinerary, taking any payment or opening any cargo lane. The platform is designed so that counsel's answers become configuration, not code changes.

4.1 Why this is a first-order design concern

- UK financial and trade sanctions breaches carry **strict-liability civil penalties** — the authorities do not need to prove intent; trade-sanctions penalties can reach the greater of £1 million or 50% of the breach value DOCUMENTED.
- UK sanctions apply to UK companies wherever they act, and to anyone in the UK DOCUMENTED.
- US secondary sanctions reach non-US companies: the US Treasury warned that foreign firms providing Iranian airlines with fuel, ground services **or ticket sales** risk being cut off from the US financial system REPORTED.
- Payment processors, SMS gateways, hosting and app platforms apply their own restrictions, often stricter than the law (Chapter 8).

4.2 The sanctions picture

REGIME	WHAT MATTERS FOR UNI TRAVEL	LABEL
UK	Iran Air designated (asset freeze) since November 2024; bilateral air services cancelled; Iran (Sanctions) Regulations 2023 and Iran nuclear regulations; SI 2026/983 in force 29 September 2026 adding trade prohibitions and a landing ban on Iranian cargo aircraft; the UK Sanctions List is the single list since 28 January 2026	DOCUMENTED
US	All remaining Iranian airlines designated on 8 September 2026 (Iran Air and Mahan Air already designated); General License J-1 suspended; secondary sanctions exposure for non-US persons dealing with designated airlines; food and medicine sales by non-US persons generally carry no secondary exposure if no designated parties are involved	DOCUMENTED
EU	Iran Air, Mahan Air and Saha Airlines sanctioned in October 2024 (asset freeze, no ticket sales in the EU)	DOCUMENTED

Being Iranian, or living in Iran, does not make a customer a sanctioned person under UK law. The risks lie in **who is paid** (airlines, partners, banks, vendors), **what is supplied** (goods, technology, services), and **who the parties are** (screened against lists).

4.3 Implications for flights

TOPIC	PLATFORM POSITION	STATUS
Iranian airlines	Excluded from search results and quotes by carrier policy	DECIDED D-01
Foreign carriers flying into or out of Iran (e.g. under a US waiver)	Allowed by default, but counsel must confirm; the carrier policy can move any carrier to REVIEW or BLOCK	Counsel question 2
Itineraries starting at gateways outside Iran	Allowed; overland leg is information only	DECIDED D-08
Customers who are Iranian nationals or residents	Served; all parties screened against UK, US and EU lists; matches held for compliance	Proposed
Supplier contracts (Amadeus, Duffel)	Disclose the customer profile; obtain written confirmation of acceptability	Stage 0

4.4 Implications for payments

- **Stripe** — part of the Engineering Kit — prohibits use for dealings with persons located in, resident in, or citizens of Iran, and for services originating there DOCUMENTED. Using it for this customer base risks account closure and frozen funds. It is parked (Decision D-03).
- Version 1 takes **no online payments**. Staff record offline payments (bank transfer, office payment) after screening the payer; nothing is routed through Iranian banks.
- Whether and when payment may be taken is also an **ATOL** question (below).

4.5 Travel regulation (ATOL)

UK rules allow a flight seller to operate without its own ATOL as an *airline ticket agent* only if conditions are met, including issuing confirmed tickets **immediately upon payment** and telling the customer the flight is not ATOL-protected DOCUMENTED. A request model in which money is taken before tickets exist would need Uni Travel's own ATOL or selling as agent for an ATOL holder, with ATOL Certificates issued at first payment INFERRED. The platform supports all three modes through `atol.mode`, defaulting to **payment only at ticketing** (Chapter 27).

4.6 Cargo and export controls

Summarised from Chapter 9: broad and growing UK prohibitions on goods to Iran, licensing (not exemption) for humanitarian and medical goods, strict liability, designated intermediaries in Türkiye and the UAE, and an unclear position for unaccompanied personal effects. All Iran lanes start **disabled** (Decision D-05).

4.7 Data protection

UK GDPR applies to all processing. Specific points: ICO registration fee; a DPIA before launch; passport data minimised and encrypted; no inference of ethnicity or religion from names; restricted transfers when personal data goes to an Iranian SMS provider or any processor outside the UK without adequacy (Chapter 28).

4.8 Questions for counsel

1. May Uni Travel (a UK company) sell or quote itineraries for travellers starting in Iran, and on what conditions, given UK, US and EU measures in force on the launch date?
2. Which carriers must be blocked or reviewed beyond the designated Iranian airlines — in particular foreign carriers operating into Iran under US waivers?

3. Does recording a booking made in the agency terminal, or quoting an itinerary, create any exposure if a carrier is later designated? What is the procedure for existing bookings?
4. Payments: which payment methods and banks may be used for customers who are Iranian nationals living in the UK, and for payers in Iran? Is any third-party payer acceptable?
5. Can Uni Travel contract and pay an Iranian SMS provider (directly or through a partner) for OTP and notifications? What transfer-risk assessment is needed under UK GDPR?
6. ATOL: which mode applies to the planned workflow, and what wording is required on quotes and receipts?
7. Cargo: is Uni Travel providing brokering or ancillary services when it arranges shipments through partners? Which lanes, services and goods categories may be offered, and what screening and record-keeping is required? Does the personal-effects exception cover unaccompanied baggage?
8. Screening: which lists, thresholds and review procedures are expected; how long must screening evidence be kept?
9. Vendors: review of sanctions clauses for hosting, CDN, email, SMS, push and app-store vendors (Chapters 8 and 30).
10. Consumer law: required pre-contract information, cancellation rights and complaint handling for flight and cargo services sold online.

PART B

B

Research and recommendations

Flight data channels and providers, seat maps, messaging and hosting vendors, and cargo partners — verified against official sources where possible, with every gap marked.

05	How flight data works	20
06	Flight data providers	22
07	Seat maps	26
08	Messaging, notifications and hosting vendors	28
09	Cargo partners and constraints	31

CHAPTER 5

How flight data works

"Real, verifiable flight information" means different things at different stages of a sale. Before comparing providers, this chapter separates the kinds of flight data, the channels that sell them, and the criteria Uni Travel should use to choose.

5.1 Kinds of flight data

KIND	WHAT IT TELLS YOU	TYPICAL SOURCE	CAN IT BE SOLD FROM?
Schedules	Which flights an airline plans to operate, on which days, at what times	OAG, Cirium (from airline filings)	No — it says nothing about seats or price
Minimum connection times (MCT)	The shortest legal connection at an airport for given carriers and terminals	OAG, Cirium, airlines via GDS	No — it validates connections
Availability	Whether seats are open in a booking class right now	GDS, NDC airline APIs, low-cost carrier systems	Only together with a fare
Offers / fares	A priced, sellable combination of flights, fare, taxes and conditions	GDS shopping (e.g. Amadeus Master Pricer), NDC, aggregators	Yes, until it expires
Orders / reservations	Seats held for named passengers (PNR)	GDS, NDC, aggregators	Becomes a ticket on issuance
Tickets	The issued contract of carriage (13-digit number)	Ticketing agent via BSP, or the aggregator's ticketing authority	—
Status	Whether a flight is on time, delayed, cancelled	Cirium, OAG, AeroDataBox	Information only

The platform's truth ladder (Chapter 18) maps directly onto this table: schedules may guide where to search, but only offers can be shown as options, and only reservations and tickets can be shown as booked.

5.2 Distribution channels

CHANNEL	HOW IT WORKS	STRENGTHS	WEAKNESSES
GDS (Amadeus, Sabre, Travelport)	Agencies shop and book many airlines through one system under a contract	Broad full-service coverage, interline itineraries with validated connections, fare rules, established ticketing	Contract and certification needed; often SOAP; costs per transaction; low-cost carrier coverage varies
NDC (airline APIs following IATA's New Distribution Capability)	Airlines sell their own offers directly or through NDC aggregators	Richer content (bundles, seats), sometimes better prices	One integration per airline unless using an aggregator
Aggregators (Duffel, Travelfusion, Mystifly, PKFARE, Verteil)	One API over many GDS, NDC and LCC sources; some sell under their own ticketing authority	Faster onboarding, modern APIs, LCC coverage	Margins or fees; their own terms and restrictions
Airline direct / charter systems	Agent portals or APIs of individual airlines and charter operators	Content not available elsewhere	Fragmented; in Iran's case, often reachable only through local systems or bots

CHANNEL	HOW IT WORKS	STRENGTHS	WEAKNESSES
Metasearch / scraping	Prices scraped from websites (e.g. "Google Flights APIs" offered by third parties)	Easy to start	Not authorised, unstable, not bookable — **excluded** by Uni Travel's rules

5.3 The two categories in the brief

The brief asks for providers for two categories (§2):

1. **Flights originating in Iran.** In October 2026 this category is dominated by sanctions and war effects rather than by technology. Iranian carriers are excluded by policy (Decision D-01), most foreign carriers have suspended Iran, and the few that operate (Chapter 3) may or may not appear in GDS and aggregator content. The practical answer is a combination of (a) whatever compliant foreign-carrier content the chosen providers carry, (b) gateway departures from Türkiye and Armenia, and (c) manual options entered by staff.
2. **International flights outside Iran.** This is a conventional problem: the gateway and hub airports (Istanbul, Yerevan, Muscat, Najaf) and the UK and European destinations are well covered by GDS, NDC and aggregator content.

5.4 Evaluation criteria

Each provider in Chapter 6 is assessed against the brief's list, plus three criteria that matter for Uni Travel specifically:

CRITERION	QUESTION
Coverage	Which airlines and routes, including the gateways and hubs that matter now?
Iran-origin support	Does it carry any compliant flights departing Iran?
Connections	Does it return connecting itineraries, and how are connection times validated?
Real-time	Live availability and fares, or cached?
Booking	Search only, or orders and ticketing? Whose ticketing authority?
Pricing and commercial restrictions	Public prices? Contract terms? Display rights on Uni Travel's own site?
Integration	REST or SOAP, sandbox, certification, time to production
Sanctions posture	Will the provider serve a UK agency whose customers are largely Iranian nationals, and on what terms?
Seat maps and ancillaries	Available before booking? At what cost?
Fit with existing relationships	Does Uni Travel already have an account (it does with Amadeus)?

CHAPTER 6

Flight data providers

No single provider solves Iran-origin travel in October 2026. The recommended combination is Amadeus Enterprise as the primary source through Uni Travel's existing agency relationship, Duffel as a secondary source for NDC, low-cost content and seat maps, staff-entered manual options from day one, and schedule and MCT data later if the engine needs them.

6.1 Summary of findings

Capabilities

PROVIDER	COVERAGE	IRAN-ORIGIN	CONNECTIONS	REAL-TIME	BOOKING
Amadeus Enterprise (Master Pricer via Web Services; some REST)	400+ airlines incl. ~100 LCC/hybrid, 20+ NDC DOCUMENTED	Depends on foreign carriers' Iran filings UNKNOWN	Up to 6 segments; airline and time filters DOCUMENTED	Live availability and fares	Full PNR and ticketing flow REPORTED
Duffel (London)	300+ airlines: NDC, GDS, LCC DOCUMENTED	No public airline list UNKNOWN	`max_connections` (default 1); separate offers cannot share an order	Live; single-offer fetch revalidates	Orders, changes, cancellations; Duffel's or own IATA ticketing
Travelport (JSON Air)	GDS + NDC	UNKNOWN	Yes	Live	Booking, ticketing, exchanges, void DOCUMENTED
Sabre (BFM, Revalidate, Get Seats)	GDS + NDC + LCC	UNKNOWN	Yes	Live; revalidation without booking	Full booking management DOCUMENTED
Kiwi.com Tequila	Virtual interlining	—	Self-transfer itineraries	—	—
Travelfusion	400+ LCCs, 70+ NDC DOCUMENTED	UNKNOWN	Per carrier	Live	Yes
Mystifly · PKFARE · Verteil	Consolidator and NDC aggregators	UNKNOWN	Yes	Live	Varies
Search-only APIs (e.g. Ignav; Google-Flights-based actors)	Varies	—	—	Varies	**None**
Iranian aggregators / charter systems (e.g. Parto CRS)	Iranian carriers, charters	Yes	—	—	—

Commercial terms and verdict

PROVIDER	PUBLIC PRICING	ACCESS	VERDICT
Amadeus Enterprise	Quote only	Sales process and contract; office ID; IATA accreditation usually required; sandbox after approval REPORTED	**Primary** — existing relationship

PROVIDER	PUBLIC PRICING	ACCESS	VERDICT
Duffel	$3/order; 1% managed content; $2/paid ancillary; search fee above 1,500:1; 2% FX DOCUMENTED	Self-serve test tokens; production after onboarding	**Secondary** — NDC/LCC, seat maps
Travelport	Not public	Trial credentials, then provisioning DOCUMENTED	Alternative if Amadeus terms fail
Sabre	Not public	Sabre customer (PCC); BFM needs a contract amendment DOCUMENTED	Alternative
Kiwi.com Tequila	—	**Invitation only** since May 2024 DOCUMENTED	Not available
Travelfusion	Not public	Contract	Option for LCC breadth
Mystifly · PKFARE · Verteil	Not public	Contract or B2B sign-up	Only if gaps remain
Search-only APIs	Per request	Self-serve	**Not recommended**: no ticketing, unclear provenance; scraping-based sources break project rules
Iranian aggregators	—	Iranian contracts; some content only via bots	**Excluded** (D-01; sanctions; no-scraping rule)

Tables 6.1 and 6.2 — Provider comparison as of 22 October 2026. "Unknown" items are on the Stage 0 question list (Chapter 34).

6.2 Amadeus Enterprise — primary

Why primary. Uni Travel already has an Amadeus UK relationship (the Flight Builder panel on airquest.com). Amadeus's Enterprise APIs remain available under contract after the Self-Service portal closed on 17 July 2026 DOCUMENTED, and the Master Pricer product returns availability, fares, taxes, baggage allowances and fare conditions in one response, for public, private, corporate and negotiated fares DOCUMENTED. That is the content most of Uni Travel's customers will travel on once they reach a gateway.

What the existing panel is. airQuest states that Amadeus's net-fares system "FareWizard" is built on airQuest technology from proQuest (Travelsoft Group). airQuest automates net, negotiated and private fare selling and books through GDSs, but it publishes no outbound search or booking API for agencies DOCUMENTED. Whether "Amadeus Flight Builder" exposes an API is UNKNOWN. The read-only discovery of the panel agreed earlier for this project is still outstanding; it should be completed in Stage 0 (Chapter 31).

Integration shape. The documented agency flow over Amadeus Web Services is SOAP-based: search (`Fare_MasterPricerTravelBoardSearch`), informative pricing, sell from recommendation, PNR creation, pricing, TST creation and ticket issuance REPORTED. Version 1 uses only search and informative pricing; reservations and ticketing stay in the agency terminal and are recorded by staff (Chapter 13).

QUESTIONS FOR THE AMADEUS UK ACCOUNT MANAGER (STAGE 0)

1. Which Enterprise air APIs are available to Uni Travel's office ID: Master Pricer search, informative pricing, fare rules, seat map display, PNR/ticketing? REST or SOAP?
2. Commercial terms: set-up fee, per-transaction fees, look-to-book limits, minimum volumes.
3. Display rights: may prices from these APIs be shown to the public on Uni Travel's own website and app?
4. Sanctions and market terms: restrictions on serving customers who are Iranian nationals or resident in Iran; treatment of Iran-origin itineraries; carrier exclusions.
5. Does Flight Builder / Fare Wizard expose net fares through an API, or only through the panel?
6. Sandbox access, certification steps and typical time to production.

6.3 Duffel — secondary

Why secondary. Duffel can be integrated in days with self-serve test tokens, has a modern REST API, returns per-offer seat maps for supporting airlines, supports ancillaries, changes and cancellations, and publishes its prices DOCUMENTED. It complements Amadeus with NDC and low-cost content and gives the platform a working provider while the Amadeus contract is negotiated.

Constraints. Duffel offers are single orders, so a self-transfer journey built by the engine becomes two Duffel orders (the platform handles that as separate tickets). Offers expire quickly, so revalidation by fetching the single offer is part of the flow. Duffel's sanctions terms could not be read during this research UNKNOWN; onboarding must disclose Uni Travel's customer profile honestly and confirm acceptability in writing before production use.

6.4 Schedules and minimum connection times — later

OAG and Cirium sell MCT datasets (over 150,000 standards and exceptions, refreshed up to daily) and connection data explicitly aimed at building valid connections and virtual interlining; both are contact-only on price DOCUMENTED. AeroDataBox offers schedules and status with public pricing but no MCT data DOCUMENTED. Version 1 does not need them: through itineraries carry the supplier's own MCT validation, and self-transfers use Uni Travel's longer configurable minimums. They become worthwhile if the engine starts suggesting hubs from real schedules (Stage 7).

6.5 Travel document checks — optional

IATA Timatic offers AutoCheck (API), Timatic Web and an embeddable widget for passport, visa and health requirements; pricing is not public and agency eligibility for AutoCheck is UNKNOWN DOCUMENTED. Version 1 relies on staff checks with advisory flags from the engine (Chapter 22).

6.6 What the providers can actually offer from Iran today

Reported operations as of late October 2026 REPORTED:

CARRIER / ROUTE	STATUS	RELEVANCE
Iraqi Airways — Najaf to Tehran IKA, Mashhad, Isfahan	Resumed 8 October 2026 under a US waiver	Possible hub route via Najaf; GDS availability to be tested
SalamAir — Muscat to Tehran	Resumed 18 October 2026, twice weekly	Possible hub route via Muscat
Qatar Airways — Tehran, Mashhad, Shiraz	In schedule filings, reservations unavailable (mid-October)	Watch
Turkish Airlines, AJet, Pegasus	No Iran flights before March 2027	Gateway strategy via Türkiye instead
Lufthansa Group	Suspended to at least 24 October 2026	Watch
Emirates	Not flying to Tehran since March 2026	—

Gateway airports and their onward links to the UK REPORTED: **Istanbul** (IST: British Airways, Turkish Airlines, Wizz Air to London; SAW: AJet and Pegasus to Stansted and Manchester); **Yerevan** (Wizz Air to Luton twice weekly since June 2026, plus Austrian, LOT, Lufthansa, Air France, Aegean to European hubs); **Van** (domestic flights only — onward via Istanbul or Ankara); **Erzurum** (domestic and SunExpress to Düsseldorf). These lists come from press and reference sources and must be confirmed against live supplier content in Stage 0.

6.7 Recommendation

RECOMMENDED PROVIDER COMBINATION

1. **Now (Stage 0):** open the Amadeus Enterprise conversation with the questions above; open a Duffel test account; complete the read-only Flight Builder discovery.
2. **Version 1:** Amadeus Enterprise (search + informative pricing) as primary, Duffel (search + revalidation + seat maps) as secondary, and manual staff options — all behind the adapter framework (Chapter 21), with reservations and tickets handled by staff.
3. **If gaps remain** for Gulf, Caucasus or regional low-cost carriers: evaluate Travelfusion or an NDC aggregator.
4. **Stage 7:** schedules/MCT data, Timatic, and automated booking through the providers' order APIs.
5. **Never:** scraping-based sources or bot access to Iranian systems.

CHAPTER 7

Seat maps

Interactive seat maps are possible, but only for offers whose supplier returns a seat map, and never for every flight. The design shows a real seat map when one exists and falls back to a seat preference otherwise — never to a generic drawing passed off as the real aircraft.

7.1 What the research found

QUESTION FROM THE BRIEF (§5)	FINDING
Do flight APIs provide seat map data?	Yes. Duffel returns one seat map per segment for an offer (`GET /air/seat_maps?offer_id=`) DOCUMENTED. Sabre's Get Seats covers NDC, ATPCO and LCC content DOCUMENTED. Travelport's JSON APIs include seat availability DOCUMENTED. Amadeus offered SeatMap Display in Self-Service; the Enterprise equivalent for Uni Travel's contract is UNKNOWN.
Paid subscription or extra fees?	Duffel charges nothing to *view* seat maps; selling a paid seat counts as a paid ancillary ($2 per ancillary) on top of the seat price DOCUMENTED. GDS pricing is contractual UNKNOWN.
Available before booking?	Duffel: yes, by offer, before the order DOCUMENTED. Sabre: NDC seat maps before booking are view-only, and some points of sale cannot sell seats DOCUMENTED.
Seat availability and selection?	Duffel returns availability and prices per seat; seats are chosen when creating the order, and its documentation states that selecting a seat after the order is created is not supported DOCUMENTED.
Coverage	Not available for every airline or flight; an empty list is a normal response DOCUMENTED. Iranian carriers are excluded anyway; coverage for the foreign carriers that matter is UNKNOWN until tested.
Legal display	Seat maps obtained through a contracted API may be displayed under that contract. Copying layouts from third-party sites (for example seat-review websites) is not acceptable: it is someone else's content, and it is not live availability.
Alternatives	Seat preference (window / aisle / together / extra legroom request) captured with the request; staff request seats after booking where the airline allows.

7.2 Product decision

DECISION D-07 · SEAT MAPS

- **Version 1:** customers record a **seat preference**; staff handle seats after reservation. No seat map is shown.
- **Stage 3 (with the Duffel adapter):** on the itinerary detail, offer **"View seats"** when the supplier of every segment in the offer returns a seat map. The map is view-only for customers, labelled with its fetch time, and the chosen seat is stored as a **preference** in the request.
- **Stage 7 (automated booking):** seat selection becomes part of order creation for suppliers that support it, priced as an ancillary.
- **Never:** generic or copied seat layouts shown as if they were the actual aircraft.

7.3 Normalised seat map model

Seat maps are irregular: row numbers skip, seat letters do not align in columns, and the same aircraft type differs between airlines. Duffel's own guidance warns against assuming aligned columns or consecutive rows DOCUMENTED. The model therefore follows the supplier's structure rather than imposing a grid.

```
interface SeatMap {
  segmentRef: string;               // which segment of the offer
  source: { provider: ProviderId; fetchedAt: string };
  cabins: Cabin[];
}
interface Cabin {
  cabinClass: Cabin;                // ECONOMY, BUSINESS, …
  deck: 0 | 1;                      // main / upper
  wings?: { firstRow: number; lastRow: number };
  rows: Row[];
}
interface Row { sections: Section[] }                // sections are separated by aisles
interface Section { elements: Element[] }
type Element =
  | { type: 'seat'; designator: string;              // '27B'
      available: boolean; price?: Money;
      characteristics: string[] }                    // 'WINDOW', 'EXIT_ROW', 'EXTRA_LEGROOM', 'BASSINET',
…
  | { type: 'empty' | 'exit_row' | 'lavatory' | 'galley' | 'closet' | 'stairs' | 'bassinet' };
```

7.4 Rendering rules

- Render rows and sections exactly as supplied; show the seat designator on every seat instead of column headers.
- Use text and patterns, not colour alone, for available / unavailable / paid / selected.
- Show the price on paid seats and a legend for characteristics (exit row restrictions, bassinet positions).
- In the Persian UI the cabin is **not** mirrored — the aircraft nose stays at the top and seat letters keep their physical order; only the surrounding interface is right-to-left.
- On small screens, render one cabin at a time with pinch-zoom; never shrink seats below a 32 px touch target.

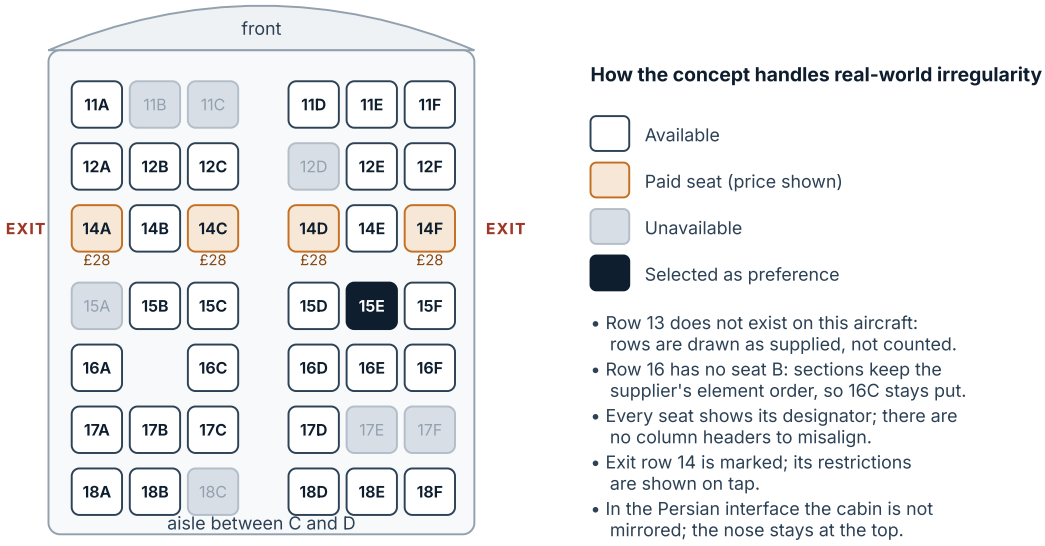


Figure 7.1 — Rendering concept with an irregular row (row 13 missing, a row with a missing middle seat). Layout and prices are illustrative.

CHAPTER 8

Messaging, notifications and hosting vendors

The large US platforms most teams reach for by default have each stopped serving Iran in some way. The platform therefore needs two messaging routes — one for +98 numbers, one for everyone else — and hosting choices that have been checked for Iranian reachability.

8.1 SMS and one-time codes

To Iranian numbers (+98)

VENDOR	OTP MECHANISM	DELIVERY REPORTS	NOTES
Kavenegar	`VerifyLookup`: pre-approved template + up to three tokens; official Node SDK; voice-call option DOCUMENTED	Yes	Templates must be approved before use DOCUMENTED
SMS.ir	`POST /v1/send/verify` with `templateId` and parameters (≤ 25 chars each); service lines reach numbers that block promotional SMS DOCUMENTED	Per-message status (delivered … blacklisted) DOCUMENTED	Good candidate for fallback
Ghasedak	OTP endpoints without a dedicated line; brand name required in template DOCUMENTED	Yes	No official Node SDK
Melipayamak	Template send from a shared service line DOCUMENTED	—	—

Whether a UK company can sign up and pay these vendors directly is UNKNOWN; in practice an Iranian contracting partner may be needed, and paying an Iranian company raises sanctions questions for counsel. Iranian SMS tariffs reportedly rose about 45% in late summer 2026 REPORTED. Iran's regulator can disable SMS entirely during unrest or restrict it to whitelisted local senders DOCUMENTED.

To UK, EU and other numbers

VENDOR	REACHES +98?	SANCTIONS TERMS	HEADQUARTERS
Twilio Verify	**No** — messaging, voice and email to recipients in Iran stopped on 15 March 2025 DOCUMENTED	End users must not be on restricted lists	US
Vonage Verify	**No** — does not operate in Iran DOCUMENTED	US restrictions	US
Sinch	UNKNOWN	Customer must comply with sanctions; Sinch excused where it believes sanctions apply DOCUMENTED	Stockholm
Infobip	UNKNOWN	No sanctions clause found in terms DOCUMENTED	London (founded in Croatia)
Bird (MessageBird)	UNKNOWN	"Sanctions may prohibit service" — confirm with support DOCUMENTED	Amsterdam

Recommendation: route by country prefix (`sms_routes`, Chapter 23): **+98 → Kavenegar, fallback SMS.ir**; **all other countries → Sinch or Infobip, fallback the other**. Do not route +98 through international providers.

8.2 Push notifications

OPTION	FINDING	USE
Expo push service	Delivers through Google FCM (Android) and Apple APNs (iOS) DOCUMENTED; FCM refuses Iranian IPs REPORTED	iOS everywhere; Android outside Iran
APNs inside Iran	No reliable measurement found UNKNOWN	Treat as best effort
Pushy	Own MQTT gateway, no FCM dependency; no sanctions clause in terms DOCUMENTED; delivery inside Iran untested UNKNOWN	Candidate for Android users in Iran (Stage 4 pilot)
Pushe.co, Najva (Iranian)	Status in 2026 and foreign sign-up UNKNOWN	Not planned

Critical notifications never depend on push alone: SMS escalation and in-app polling cover them (Chapter 17).

8.3 Email

VENDOR	RELEVANT CLAUSE	RECOMMENDATION
Brevo (Paris)	Customer organisation must not be based in Iran; recipients not addressed DOCUMENTED	**Primary**
Mailjet (Sinch group)	General export-compliance clause only DOCUMENTED	Fallback
Postmark	May not provide access to people located in Iran DOCUMENTED	Avoid
Twilio SendGrid	Email to recipients in Iran stopped March 2025 DOCUMENTED	Avoid
Resend, AWS SES	No country clause found / customer responsible DOCUMENTED	Possible alternatives after review

8.4 App distribution and web reachability

The findings that shape the client and hosting design are summarised in Chapters 29 and 30: no Apple App Store in Iran; Google Play free apps intermittently reachable; Cafe Bazaar dominant but with unknown requirements for foreign publishers; Vercel reportedly returning 403 to Iranian visitors; DigitalOcean's terms forbidding access from sanctioned regions; Google Maps listing Iran as a prohibited territory DOCUMENTED / REPORTED.

8.5 Internet shutdowns

Iran experienced a national shutdown in June 2025, a blackout from 8 January 2026 during which domestic SMS was restored first (after 9 days) and international SMS stayed blocked, and an 87-day shutdown from 28 February to 26 May 2026 followed by tiered, partial restoration REPORTED. Design consequences:

- During a shutdown, a site hosted outside Iran is unreachable from Iran; the platform cannot fix this, but it can **fail honestly** (status messaging for staff, no false "sent" states).
- Domestic SMS through an Iranian provider is the first channel to return; international SMS the last.
- Requests already in progress should be workable by staff through the customer's family contacts or alternative numbers recorded on the request (an optional "alternative contact" field).
- Any presence on Iran's national network would raise sanctions questions and is out of scope.

8.6 Recommended vendor set

NEED	PRIMARY	FALLBACK	STATUS
OTP and SMS to +98	Kavenegar	SMS.ir	Contracting route and payment to be confirmed with counsel
OTP and SMS elsewhere	Sinch or Infobip	The other	Confirm sanctions terms in writing
Push	Expo (iOS; Android outside Iran)	Pushy pilot for Android in Iran; SMS escalation	Pilot in Stage 4
Email	Brevo	Mailjet	—
Captcha	Self-hosted proof-of-work (e.g. ALTCHA)	—	No Google or hCaptcha dependency
Maps (if ever needed)	Open data (OpenStreetMap-based tiles, self-hosted or EU provider)	—	Google Maps excluded

CHAPTER 9

Cargo partners and constraints

Mainstream couriers and digital air-cargo marketplaces do not serve Iran in 2026. A cargo service on these lanes can only work as request-and-quote through vetted specialist partners, behind a compliance gate — which is exactly how Chapter 14 designs it.

9.1 Couriers and postal services, UK → Iran

SERVICE	REPORTED STATUS	LABEL
Royal Mail / Parcelforce	Suspended to Iran since 1 March 2026; items in transit likely returned (bulletin updated 6 October 2026)	DOCUMENTED
FedEx	Iran on the "countries not served" list	DOCUMENTED
DHL Express	Reported suspended to Iran from 4 March 2026; DHL's own Middle East bulletin does not mention Iran	REPORTED
UPS	No service according to a shipping reseller; no official UPS page found	UNKNOWN
Aramex	Suspended in 2021; a 2026 aggregator page claims otherwise — conflicting	UNKNOWN
USPS	Suspended	DOCUMENTED
Reseller listings (e.g. DHL or DPD to Iran on consolidator sites)	Likely stale marketing pages; bookability unverified	UNKNOWN

9.2 Digital air-cargo platforms

PLATFORM	WHAT IT OFFERS	ACCESS	IRAN LANES
cargo.one	E-booking with dozens of airlines; API for rates, booking and tracking	Free for forwarders; tied to a CASS account and AWB stock — effectively an IATA cargo agent DOCUMENTED	Not offered INFERRED
CargoAi	Schedules, rates, booking and tracking APIs; plans from free to $349/month DOCUMENTED	Sign-up	UNKNOWN
Freightos for Forwarders (WebCargo)	75+ carriers, e-booking free for forwarders; API is a paid add-on DOCUMENTED	Sign-up	UNKNOWN
IATA ONE Record	Open data standard and API specification (MIT-licensed reference) endorsed from 1 January 2026 DOCUMENTED	Standard	Not a sales channel

Western ground handlers screen cargo messages for Iranian airports and sanctioned carriers and refuse or quarantine matches DOCUMENTED. These platforms might price a UK → Istanbul or UK → Dubai leg; they cannot carry the Iran leg.

9.3 Excess baggage and personal effects

- Send My Bag and Seven Seas Worldwide do not list Iran as a destination DOCUMENTED.
- At least one UK freight firm advertises air freight of personal effects to Iranian cities on request; whether it operates today is UNKNOWN.
- The UK Iran regulations contain a **personal-effects exception** for items in the luggage of a person travelling to Iran (reg. 56A) DOCUMENTED. Whether **unaccompanied** baggage qualifies is not clear and needs legal advice UNKNOWN.

9.4 Overland and intermediaries

- Road freight is the fallback for regional trade, but the Gürbulak–Bazargan crossing reported week-long truck queues in September 2026 REPORTED.
- On 8 September 2026 the US designated Turkish logistics firms that served Mahan Air, among others REPORTED. Turkish and UAE consolidators are therefore exactly the counterparties that need enhanced screening.

9.5 UK trade controls that touch cargo

- The Iran (Sanctions) Regulations 2023 prohibit exports of internal-repression goods, interception and monitoring goods, and goods "of strategic concern" including UAV and missile items, with related services DOCUMENTED.
- SI 2026/983 (in force 29 September 2026) added trade prohibitions covering energy, gold and precious metals, maritime goods, natural gas, oil, petrochemicals, sectoral software and technology, and additional dual-use items, reaching supply and delivery including third-country trade DOCUMENTED.
- Strategic export controls (military and dual-use lists, end-use catch-all) need ECJU licences; humanitarian and medical supplies are **licensing grounds, not automatic exceptions** DOCUMENTED.
- UK trade and financial sanctions breaches carry **strict-liability** civil penalties DOCUMENTED.
- Whether a cargo-request agency that does not itself export is providing "brokering" or "ancillary services" under the regulations needs legal advice UNKNOWN.

9.6 Consequences for the design

FINDING	DESIGN RESPONSE (CHAPTER 14 / 27)
No mainstream carrier serves Iran	Partner model; partners vetted and screened; no instant pricing
Availability changes month to month	`service_availability` register: provider, lane, service, status, source URL, last-checked date
Strict liability and broad prohibitions	Structured goods declaration (no free-text-only items); goods rules; compliance hold before any quote
Intermediaries designated	Partner screening at onboarding and on every list update
Unaccompanied personal effects unclear	Excess-baggage service on Iran lanes disabled until counsel advises; accompanied baggage handled as an airline ancillary, not cargo
Iran lanes legally sensitive	Lanes created disabled; enabling requires owner + compliance approval with counsel reference

PART C

C

Product design

Who uses the platform, the journeys they take, the ticket types and request lifecycles, the Admin and Developer Panels, and how people are kept informed.

10	Users, roles and surfaces	34
11	Customer journeys	38
12	Ticket types and fare variants	42
13	Flight request lifecycle	45
14	Cargo transport requests	50
15	Admin Panel	55
16	Developer Panel	58
17	Notifications and communication	61

CHAPTER 10

Users, roles and surfaces

Four surfaces, six roles, one source of truth. Every permission is decided by the backend; the clients only reflect what the backend says the current user may do.

10.1 Who uses the platform

The platform serves two very different kinds of people: customers who want to travel or ship something, and the Uni Travel team who turn those requests into real reservations, tickets and shipments. The table below describes the people we design for. They drive the defaults in later chapters (language, channel choice, connectivity assumptions).

PERSONA	SITUATION	WHAT THEY NEED MOST	DESIGN CONSEQUENCES
Customer in Iran	Lives in Iran, +98 mobile number, Persian first, unstable or filtered internet, no international card	A credible route out of Iran and a human who calls them back	Persian UI, SMS as the dependable channel, light pages, no dependency on Google services, offline-friendly request tracking
Diaspora customer	Lives in the UK or Europe, UK/EU number, bilingual, books for themselves or for parents in Iran	Find options quickly, submit on behalf of family, follow progress	Traveller profiles for other people, English or Persian UI, push notifications, email copies
Student	Iranian student in the UK (Uni Travel's core audience), price-sensitive, flexible dates	Cheapest acceptable itinerary, baggage clarity, term-time dates	Flexible-date search, baggage shown only when known, fare comparison
Cargo customer	Individual sending documents, parcels or personal effects; or a small business moving commercial freight	A quote, clear rules about what can be sent, tracking	Guided item declaration, prohibited-item screening up front, document upload
Admin (agent)	Uni Travel staff member handling requests by phone, using Amadeus and partner tools	A clean queue, everything about the request on one screen, fast status updates	Simple console, mobile admin mode, no technical settings in sight
Compliance officer	Senior staff member accountable for sanctions and export-control decisions	Clear holds, evidence, ability to approve or decline with a reason	Compliance case queue, four-eyes overrides, immutable audit
Developer / Owner	Platform owner and authorised developers	Control over roles, providers, engine rules, notifications and health	Separate Developer Panel with step-up authentication

10.2 Roles

PROPOSED Roles are named bundles of permissions. The backend checks **permissions**, never role names, so roles can be reshaped later without code changes. The six default roles are:

ROLE	PURPOSE	SURFACES	ASSIGNABLE BY
`customer`	Default for every new account	Web, Mobile	Automatic on sign-up
`admin`	Handles flight requests (the "Administrator" in the brief)	Console › Admin, Mobile admin mode	Developer, Owner

ROLE	PURPOSE	SURFACES	ASSIGNABLE BY
`cargo_admin`	Handles cargo requests	Console › Admin, Mobile admin mode	Developer, Owner
`compliance_officer`	Reviews compliance holds; approves or declines	Console › Admin (Compliance area)	Owner
`developer`	Technical configuration, diagnostics, user management	Console › Developer	Owner
`owner`	Superuser; the platform owner	All	Owner (minimum one must always exist)

A user can hold several roles. Staff members are also customers in principle, but staff accounts should be separate from personal customer accounts to keep the audit trail clean PROPOSED.

> **HARD RULE**
>
> Hiding a button is never a security control. Every protected endpoint independently checks the caller's permissions on the server (Chapter 25). The client receives the permission list only so it can decide what to *display*.

10.3 Permission catalogue

Permissions follow the pattern `resource.action[.scope]`. Scope `own` means "records the user owns"; `any` means "all records". This is the starting catalogue; the Developer Panel can create new roles from it but cannot invent permissions that the code does not check.

PERMISSION	CUSTOMER	ADMIN	CARGO_ADMIN	COMPLIANCE	DEVELOPER	OWNER
`flight_search.run`	●	●	●		●	●
`flight_request.create.own` / `.read.own`	●					
`flight_request.read.any`		●		●		●
`flight_request.assign`		●				●
`flight_request.transition`		●				●
`flight_request.note.internal`		●	●	●		●
`quote.create` / `reservation.record` / `ticket.record`		●				●
`payment.record`		●	●			●
`cargo_request.create.own` / `.read.own`	●					
`cargo_request.read.any` / `.transition`			●	● (read)		●
`customer.read.pii`		●	●	●		●
`customer.read.documents` (passport data)		●	●	●		●
`compliance.case.read` / `.decide`				●		●
`user.read`					●	●
`user.role.assign` (non-privileged roles)					●	●

PERMISSION	CUSTOMER	ADMIN	CARGO_ADMIN	COMPLIANCE	DEVELOPER	OWNER
`user.role.assign.privileged` (developer, owner, compliance)						●
`provider.config.read` / `.write`					●	●
`engine.rules.read` / `.publish`		● (read)			●	●
`settings.write` / `flags.write`					●	●
`notification.template.write`					●	●
`audit.read`				●	●	●
`diagnostics.read`					●	●

Table 10.1 — Default permission matrix. ● = granted by default.

Two safeguards sit on top of the matrix:

- **Privileged role changes** (granting `developer`, `owner` or `compliance_officer`) require the `owner` permission, a step-up re-authentication, and produce a security notification to every owner.
- **The last owner cannot be demoted.** The backend rejects any change that would leave zero active owners.

10.4 Surfaces

The platform has four user-facing surfaces. They share one backend and one design system, but they are deliberately separated so that customer, administrative and developer concerns never mix (brief §12).

SURFACE	USERS	TECHNOLOGY	NOTES
Website	Customers	Next.js (Kit)	Public pages, search, requests, account. English and Persian.
Mobile app	Customers; admins in admin mode	Expo / React Native PROPOSED	One app. The interface switches by role after permissions are refreshed. No Developer Panel on mobile.
Console › Admin Panel	admin, cargo_admin, compliance_officer	Next.js (Kit)	Queues, request detail, quotes, cargo, compliance cases. Deliberately simple.
Console › Developer Panel	developer, owner	Next.js (Kit)	Users and roles, providers, engine rules, workflows, notifications, auth settings, audit, diagnostics. Separate hostname, step-up auth, optional IP allowlist.

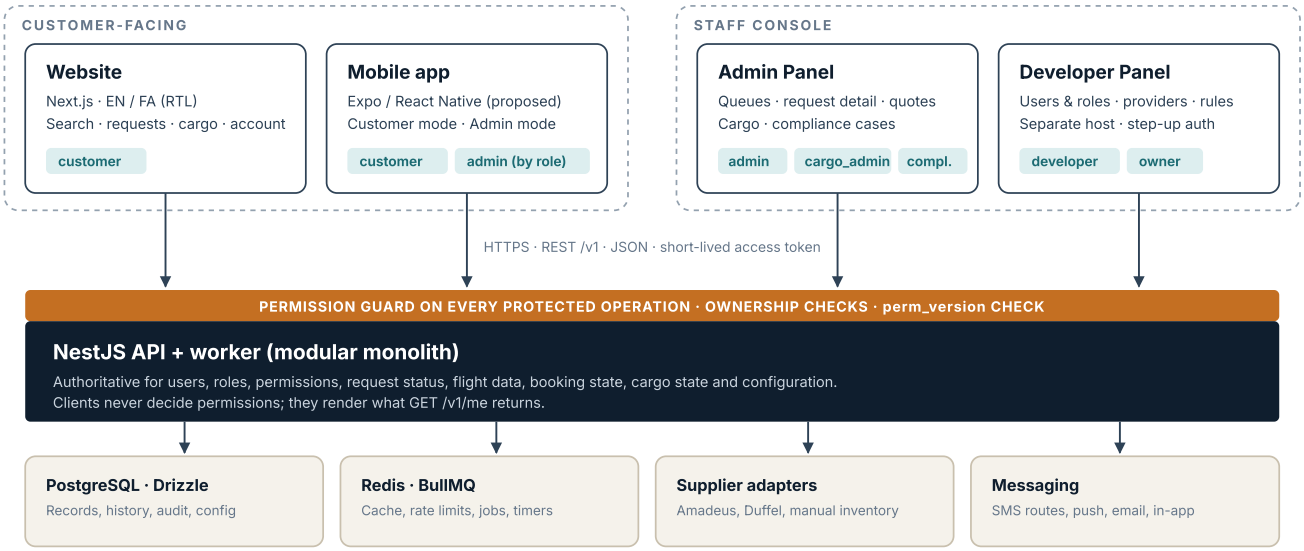


Figure 10.1 — Surfaces, roles and the single backend. The mobile app hosts both customer and admin modes; the Developer Panel is web-only.

10.5 Role switching on mobile

The brief asks that a customer promoted to administrator sees the admin interface "after the user's permissions are refreshed". The mechanism is:

1. An owner or developer changes the user's roles in the Developer Panel.
2. The backend increments the user's `perm_version`, writes an audit entry and emits a `user.permissions_changed` event.
3. The user's next API call carries an access token with the old `perm_version`. The API responds `401 PERMISSIONS_CHANGED`.
4. The app silently refreshes its token, calls `GET /v1/me`, receives the new permission list and rebuilds its navigation. If push is available, a silent push triggers the same refresh immediately.
5. Demotions take effect on the very next request: the API compares the token's `perm_version` with the current value on every call, so an old token cannot keep removed privileges alive.

The details are in Chapter 25.

CHAPTER 11

Customer journeys

The customer experience is built around one promise: show real options honestly, then hand over to a person. Search is automated; booking is confirmed by staff.

11.1 Journey map

#	JOURNEY	ENTRY POINT	ENDS WITH	CHANNELS
J1	Sign up / sign in	Any protected action	Verified phone on the account	Web, Mobile
J2	Search and request an itinerary	Home search box	Request with reference number	Web, Mobile
J3	Manual request (no suitable result)	Empty results, or "Ask our team"	Request with reference number	Web, Mobile
J4	Track a request and respond	Notification, "My requests"	Quote accepted, information supplied, or request closed	Web, Mobile, SMS link
J5	Send cargo	"Send cargo"	Cargo request with reference number	Web, Mobile
J6	Manage travellers and documents	Account	Saved traveller profiles	Web, Mobile
J7	Preferences	Account	Language, notification and privacy settings	Web, Mobile

11.2 J1 — Sign up and sign in

Phone number is the primary identity; email is the alternative (brief §7). Both use one-time codes, so there are no passwords to leak or reset.

1. **Enter phone number.** Country picker defaults from the device locale or IP; the number is normalised to E.164 on the server. Iranian numbers may be typed in local format (`0912…`) and are converted to `+98912…`.
2. **Receive code.** The backend sends a 6-digit code through the SMS route for that country (Chapter 8). The screen shows a resend timer and, after two failed deliveries, offers a voice call where the provider supports it.
3. **Verify.** On success the phone identity is marked *verified* with a timestamp. A new user is created if none exists; the user is asked for their name (as in passport, Latin script, plus optional Persian name for display).
4. **Email alternative.** "Use email instead" sends a code to the email address. An account created by email must still verify a phone number before submitting a request, if `auth.require_verified_phone_for_requests` is on (default: on).

> **VERIFIED MEANS VERIFIED**
>
> A phone number is only ever shown as verified when the server holds a successful OTP verification for that exact E.164 number. Changing the number creates a new, unverified identity until it is verified; the old verified number stays on the account until the new one is confirmed. Requests store a snapshot of the contact number and its verification state at submission time.

11.3 J2 — Search and request an itinerary

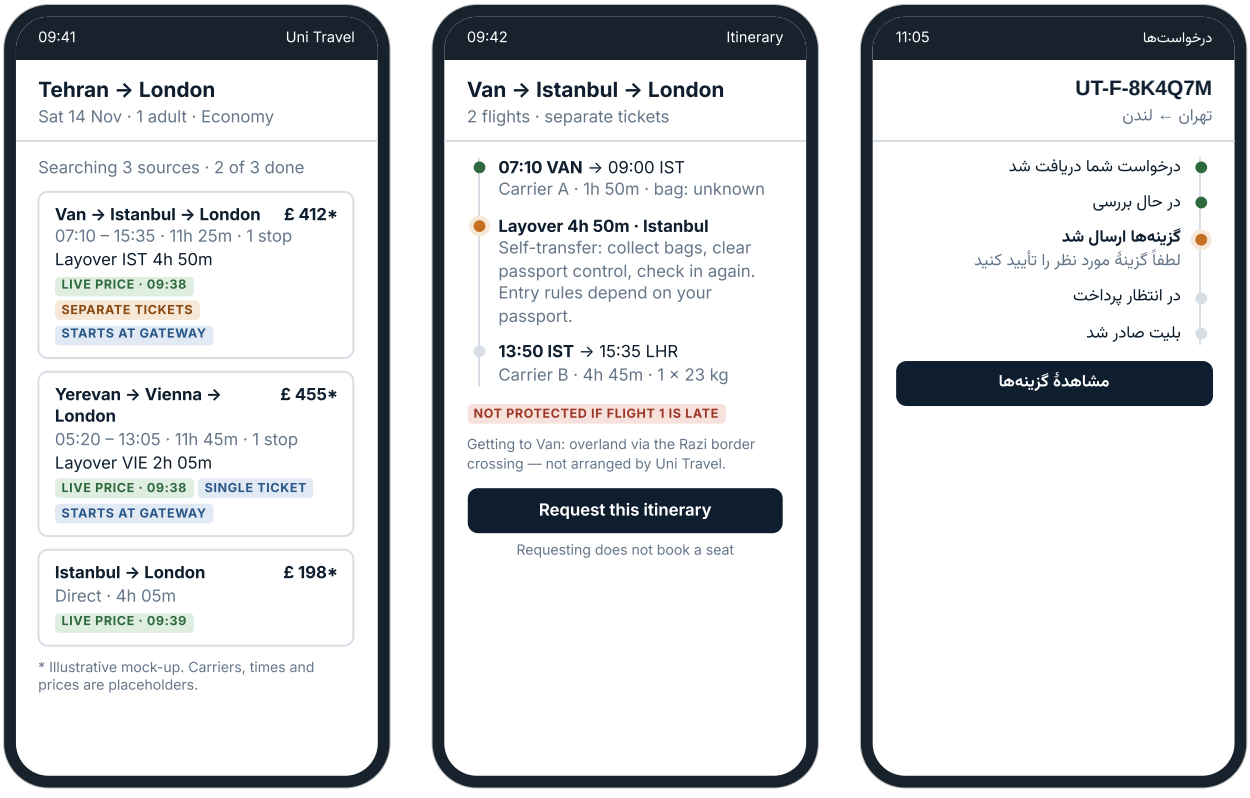
Search form

FIELD	BEHAVIOUR
Trip type	One-way, return, multi-city (up to 4 legs)
From / To	City or airport autocomplete in English and Persian ("Tehran — all airports", "London — all airports"). Cities expand to their airports server-side.
Dates	Calendar with Jalali display option for Persian UI; "± 3 days" flexibility toggle
Travellers	Adults (12+), children (2–11), infants (under 2, on lap); ages collected for children
Cabin	Economy, premium economy, business, first
Connection preferences	Preferred layover window (pre-filled from route rules, e.g. 4–6 h), allow self-transfer (separate tickets), allow airport change, allow overnight layover, maximum stops
Gateway option	"If there are no suitable flights from my city, show departures from nearby gateways" — on by default when the origin is in a restricted-origin country (Chapter 22)

Results

Results stream in progressively (Chapter 22, §22.6). The page shows a progress line ("Searching 3 sources · 2 of 3 done") and the first options as soon as they exist. Results are grouped into tabs: **Best**, **Cheapest**, **Fastest**, and **Single ticket** (protected connections only).

Every result card carries truth badges (Chapter 18): where the price came from, when it was fetched, and whether the journey is on one ticket or several.



Results with truth badges — Itinerary detail with layover advice — Request tracking in Persian (RTL)

Figure 11.1 — Illustrative mobile screens. The RTL timeline shows the customer-facing status labels from Chapter 13.

Itinerary detail

The detail view answers the questions customers phone about:

- **Every segment**: carrier (marketing and operating), flight number, aircraft if known, terminals, local times with the day offset shown when the date changes.
- **Every connection**: duration, whether it is protected (single ticket) or a self-transfer, whether bags must be collected and re-checked, airport or terminal changes, overnight warnings, and a plain-language note that transit and entry rules depend on the passport.
- **Fare conditions and baggage**: shown only when the supplier returned them. Otherwise the field reads "Not provided by the airline — our team will confirm". The platform never infers baggage allowances.
- **Seat map**: offered when the supplier for that offer returns one (Chapter 7); otherwise the customer records a seat preference.
- **Price freshness**: "Live price fetched at 09:38. Prices change; our team re-confirms the fare before reserving."

Submitting the request

1. The customer chooses travellers from saved profiles or adds new ones (names exactly as in passport).
2. The contact number defaults to the verified account number; it can be changed only to another verified number.
3. Optional: seat preference, meal or assistance needs (captured as special service requests), best time to call, free-text note.
4. The customer confirms two statements: "I understand this is a request, not a booking" and the privacy notice.
5. The server optionally revalidates the price with the supplier (config `requests.revalidate_on_submit`), stores an immutable **offer snapshot**, creates the request and returns a reference such as `UT-F-8K4Q7M`.
6. The confirmation screen repeats the reference, explains what happens next and when to expect a call, and sends an SMS with the reference.

11.4 J3 — Manual request

If the engine finds nothing suitable, or the customer prefers to talk to someone, the empty-results screen offers **"Ask our team to find options"**. The form is pre-filled from the search (route, dates, travellers, preferences) and adds free-text fields: flexibility, budget, airlines to avoid or prefer, and whether overland travel to a gateway is acceptable. The request enters the same queue with type `MANUAL`.

11.5 J4 — Tracking and responding

"My requests" lists every flight and cargo request with its customer-facing status. Inside a request the customer sees:

- a **status timeline** with dates;
- a **conversation thread** with the team (customer-visible messages only; internal notes are never sent to clients);
- **quote cards** when the team has priced options: each shows the itinerary, total price, what is included, the expiry time, and *Accept* or *Decline* buttons;
- **documents** issued by the team (e-ticket receipts, itinerary PDFs, invoices) via short-lived download links;
- **actions** such as "Provide passport details" when the request is in *Action needed*.

11.6 J6 — Travellers and documents

A traveller profile stores: title, given names and surname in Latin script exactly as in the passport, optional Persian name, date of birth, gender as in passport, nationality, passport number, issuing country and expiry date. Passport fields are encrypted at field level (Chapter 28) and requested only when a quote is accepted, not at search time. Profiles can belong to the account holder or to people they book for, such as parents.

11.7 J7 — Preferences

- **Language and calendar:** English or Persian; Gregorian or Jalali display (storage is always ISO-8601 UTC).
- **Notifications:** per-channel toggles for non-essential messages. Security and booking-critical messages cannot be switched off.
- **Privacy:** download my data, delete my account (subject to legal retention of booking records, explained on screen).

CHAPTER 12

Ticket types and fare variants

"Ticket type" in this booklet means the variants of a flight ticket: how the journey is structured, who is travelling, what cabin and fare brand they buy, and whether the journey is protected on one ticket or assembled from several.

12.1 Scope decision

> **DECISION D-04 · TICKET TYPES**
>
> Version 1 covers **flight fare variants only**. Bus and ground tickets, charter and group tickets, and rail or ferry tickets are out of scope. The data model keeps a generic `product_type` on requests and quote lines (`FLIGHT`, `CARGO`, later `GROUND`, `GROUP`) so they can be added without a redesign. Ground access to gateway airports is shown as *information only* (Chapter 22).

12.2 Trip structures

STRUCTURE	DEFINITION	SEARCH MODEL	REQUEST MODEL	NOTES
One-way	One journey A → B	1 slice	1 slice	Most common for Iran-origin travel while return dates are uncertain
Return	A → B, later B → A	2 slices	2 slices	Searched as one request to get round-trip pricing where suppliers offer it
Open-jaw	A → B, return C → A (or B → A to D)	2 slices with different airports	2 slices	Useful when the outbound starts at a gateway such as Van but the return ends in Tehran-bound options
Multi-city	Up to 4 independent slices	N slices	N slices	Self-transfer construction is disabled for multi-city in v1 (combinatorial cost); only supplier-priced multi-city offers are shown

A **slice** is one directional journey from origin to destination; it contains one or more **segments** (individual flights). The engine always works at slice level.

12.3 Cabins, booking classes and fare basis

Customers choose a **cabin**; staff also see the **booking class** (a one-letter inventory bucket) and **fare basis** code (the fare rule identifier) because those determine price, rules and availability when they reserve.

CABIN (CUSTOMER LABEL)	CODE	NOTES
Economy	`ECONOMY`	Default
Premium economy	`PREMIUM_ECONOMY`	Not offered by many regional carriers; the engine falls back to economy only if the customer allowed "nearest cabin"
Business	`BUSINESS`	
First	`FIRST`	Rare on the corridors in scope

Mixed-cabin itineraries (e.g. economy on a regional leg, business long-haul) are allowed when the supplier returns them; the result card shows the cabin per segment.

12.4 Passenger types

TYPE	IATA CODE	RULE USED BY THE PLATFORM	NOTES
Adult	`ADT`	12 years or older on the date of the **last** flight	
Child	`CHD`	2–11 on the date of travel	Age is captured; some suppliers price by exact age
Infant on lap	`INF`	Under 2 for the whole journey	Maximum one per adult; validated server-side
Infant with seat	`INS`	Under 2, own seat	Supported only where the supplier supports it; otherwise manual
Youth / student	`YTH` / `STU`	Carrier-specific age and status rules	Only requested if the customer selects "student fare" and the route rule enables it; staff verify eligibility before ticketing
Unaccompanied minor	—	Child travelling without an adult	Always routed to a **manual request**; never self-transfer

IMPLEMENTATION NOTE

Ages are calculated from date of birth against the local date of each segment, because an infant who turns two mid-journey is a child on the return. The engine validates passenger mix before calling suppliers (e.g. infants ≤ adults, total ≤ 9) to avoid wasted calls.

12.5 Fare brands (fare families)

Airlines sell the same seat under several brands — e.g. *Light*, *Classic*, *Flex* — that differ in bags, changes and refunds. Suppliers return brands in different shapes, so the platform normalises them into a fixed attribute set with an explicit **unknown** state.

ATTRIBUTE	VALUES	SOURCE
`checked_bags`	count + weight per piece, or total weight; or `UNKNOWN`	Supplier baggage data only
`cabin_bag`	included / not included / `UNKNOWN`	Supplier
`seat_selection`	free / paid / not allowed / `UNKNOWN`	Supplier brand attributes
`change_before_departure`	allowed (penalty amount) / not allowed / `UNKNOWN`	Supplier conditions or fare rules
`refund_before_departure`	allowed (penalty amount) / not allowed / `UNKNOWN`	Supplier conditions or fare rules
`brand_name`	Airline's brand label as provided	Supplier

HARD RULE · BAGGAGE AND CONDITIONS

The platform never invents baggage allowances or fare conditions. If the supplier did not return a value, the UI shows "Not provided — our team will confirm", the quote builder forces the admin to fill it in from the fare rules before sending a quote, and the customer sees the confirmed value only on the quote.

12.6 Ticketing models

How the journey is ticketed determines who is responsible if something goes wrong. The platform shows this prominently.

MODEL	WHAT IT MEANS	MISSED CONNECTION	BAGS	BADGE
Single ticket (one carrier, codeshare or interline)	All segments on one ticket; the supplier priced and validated the connection against minimum connection times	Airline re-accommodates	Usually checked through	`Single ticket · protected`
Separate tickets (self-transfer)	The engine combined two or more independently priced offers	Customer bears the risk; the next ticket may be lost	Collect and re-check	`Separate tickets · self-transfer`
Starts at gateway	The first flight departs outside the customer's chosen origin country	n/a — customer reaches the gateway on their own	n/a	`Starts at gateway`

Self-transfer itineraries get stricter rules (Chapter 22): longer minimum layovers, no airport change unless enabled for that airport pair, an explicit warning on the result card, and a required acknowledgement in the request form.

12.7 Special service requests

Assistance and preferences are captured as structured items so staff can add them to the reservation using standard codes.

CATEGORY	EXAMPLES (IATA SSR CODE)	CAPTURED AS
Mobility	Wheelchair to aircraft door `WCHR`, steps `WCHS`, cabin seat `WCHC`	Per traveller, per request
Meals	Vegetarian `VGML`, Muslim `MOML`, child `CHML`, diabetic `DBML`	Per traveller
Travelling with	Pet in cabin `PETC`, extra seat `EXST`	Per traveller; always staff-confirmed
Minors	Unaccompanied minor `UMNR`	Forces manual request
Medical	Oxygen, medical clearance	Free text + staff follow-up; data minimised (Chapter 28)

SSRs are requests, not guarantees; the customer-facing label is "Requested — confirmed by the airline after booking".

12.8 Ancillaries

Paid seats and extra bags are **preferences** in version 1: the customer records them, staff price them on the quote. Where the supplier supports ancillaries through the API (Chapter 6), Stage 7 can attach them to offers directly.

12.9 Summary of enumerations

```
type TripType        = 'ONE_WAY' | 'RETURN' | 'OPEN_JAW' | 'MULTI_CITY';
type Cabin           = 'ECONOMY' | 'PREMIUM_ECONOMY' | 'BUSINESS' | 'FIRST';
type PassengerType   = 'ADT' | 'CHD' | 'INF' | 'INS' | 'YTH' | 'STU';
type TicketingModel  = 'SINGLE_TICKET' | 'SEPARATE_TICKETS';
type Tri<T>          = { status: 'KNOWN'; value: T } | { status: 'UNKNOWN' };
type ProductType     = 'FLIGHT' | 'CARGO';            // later: 'GROUND' | 'GROUP'
```

CHAPTER 13

Flight request lifecycle

A request is a case, not a booking. This chapter defines the objects that must never be confused, the states a request moves through, who may move it, and the invariants the backend enforces so that nothing is ever shown as booked before it is.

13.1 Seven objects that must never be confused

The brief insists that a search result, a customer request, a confirmed reservation and a purchased ticket stay distinct (§8). The design goes one step further and separates seven objects, each with its own table, owner and lifecycle.

OBJECT	WHAT IT IS	CREATED BY	SOURCE OF TRUTH	CAN THE CUSTOMER SEE IT?
Search result	An itinerary the engine assembled from supplier responses at a moment in time	Engine	Supplier response + fetch time (cached ≤ TTL)	Yes, with truth badges
Offer snapshot	An immutable copy of the itinerary the customer chose, frozen at submission	Server, on submit	Platform database	Yes (inside the request)
Request	The customer's case: what they want, who travels, status, conversation	Customer or admin	Platform database	Yes
Quote	Priced options prepared by staff, with confirmed baggage and conditions and an expiry	Admin	Platform database (prices from supplier/terminal)	Yes
Reservation	A held or confirmed booking (PNR) in a supplier or airline system	Admin (v1, recorded manually) or API (later)	Supplier/airline system; platform keeps a mirror	Status only
Ticket	An issued electronic ticket with a 13-digit number	Admin (v1) or API (later)	Airline/BSP; platform keeps a mirror	Yes (number and receipt)
Payment record	Money received offline, recorded by staff	Admin	Platform database (bank statement is the evidence)	Yes (receipt)

INVARIANT

The customer-facing status is *derived* from these objects, never typed freely. A request can only show "Ticket issued" when every traveller has an `ISSUED` ticket record; it can only show "Seats reserved" when an active reservation with a record locator exists. The server rejects transitions whose guards are not met (§13.3).

13.2 States

Fulfilment status and payment status are tracked separately, because payment may arrive before or after the reservation.

Fulfilment status

STATE	MEANING	CUSTOMER LABEL	TERMINAL
`SUBMITTED`	Created; automatic checks running (seconds)	Received	
`COMPLIANCE_HOLD`	Screening flagged a party, carrier or route; only a compliance officer can release or decline	Being reviewed	
`NEW`	Passed checks, waiting for an admin	Received	
`IN_REVIEW`	Assigned admin is working on it	Being reviewed	
`AWAITING_CUSTOMER`	Information or a decision is needed from the customer	Action needed	
`QUOTED`	A quote has been sent and is valid	Options sent	
`ACCEPTED`	Customer accepted one quote option	Reserving your seats	
`RESERVED`	An active reservation exists with a ticketing deadline	Awaiting payment / Issuing ticket*	
`TICKETED`	All travellers have issued tickets	Ticket issued	
`COMPLETED`	Travel date passed or the case was closed after ticketing	Completed	●
`DECLINED`	Cannot be fulfilled, or compliance declined	Unable to arrange	●
`CANCELLED`	Cancelled by customer or staff before ticketing	Cancelled	●
`EXPIRED`	Quote or reservation lapsed without action	Expired	(reopenable)

* "Awaiting payment" while payment status ≠ PAID; "Issuing ticket" once paid.

Payment status

`NONE` → `PARTIAL` → `PAID`, with `REFUND_PENDING` and `REFUNDED` for after-sales. It is computed from verified payment records against the accepted quote total, never set by hand.

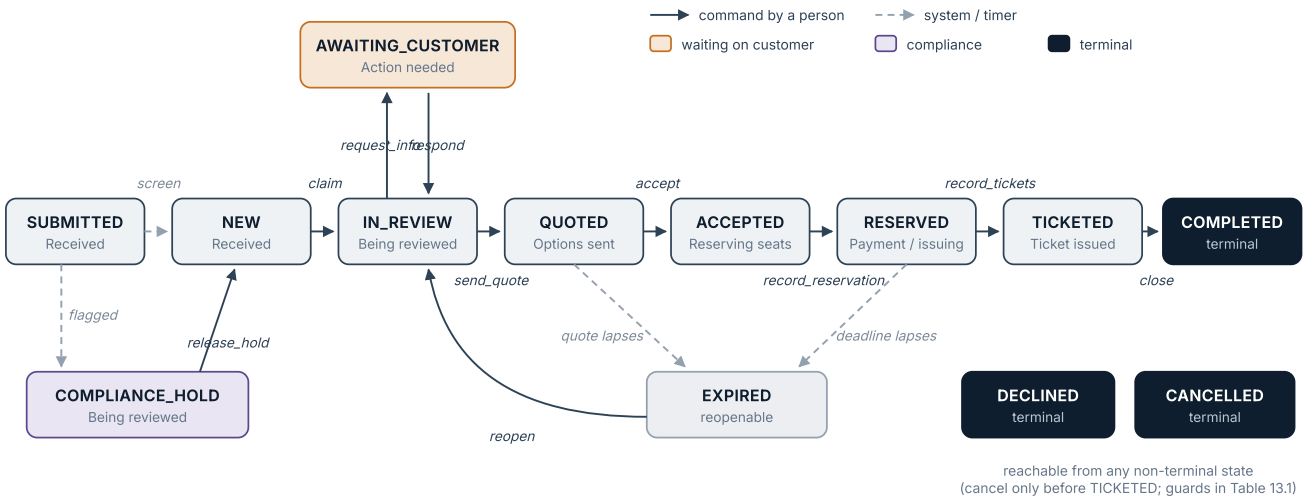


Figure 13.1 — Flight request fulfilment states. Dashed arrows are system-driven (timers and automatic checks); solid arrows are commands issued by people.

13.3 Transitions and guards

Every transition is a named **command** on the API (`POST /v1/admin/flight-requests/{ref}/commands/{command}`), not a free-form status update. The state machine lives in one module (Chapter 20), runs inside a database transaction, writes the history row, the audit entry and the outbox event atomically, and returns `409 INVALID_TRANSITION` if a guard fails.

COMMAND	FROM → TO	WHO (PERMISSION)	GUARDS	SIDE EFFECTS
(auto) `screen`	SUBMITTED → NEW / COMPLIANCE_HOLD	System	—	Notify admins (NEW) or compliance (HOLD)
`release_hold`	COMPLIANCE_HOLD → NEW	`compliance.case.decide`	Decision reason recorded	Audit; notify admins
`decline`	any non-terminal → DECLINED	`flight_request.transition` or `compliance.case.decide`	Reason code + customer message	Notify customer
`assign` / `claim`	NEW → IN_REVIEW	`flight_request.assign`	Assignee has `flight_request.transition`	Notify assignee
`request_info`	IN_REVIEW → AWAITING_CUSTOMER	`flight_request.transition`	Customer-visible message present	Push + SMS to customer
(customer) `respond`	AWAITING_CUSTOMER → IN_REVIEW	Owner of request	Message or requested data supplied	Notify assignee
`send_quote`	IN_REVIEW → QUOTED	`quote.create`	≥ 1 option; every option has known baggage and conditions; expiry in future	Push + SMS; starts expiry timer
(customer) `accept_quote`	QUOTED → ACCEPTED	Owner of request	Quote valid and not superseded; traveller documents complete	Notify assignee
`record_acceptance`	QUOTED → ACCEPTED	`quote.create`	Verbal acceptance; note with date/time of call required	Customer notified to confirm in app
`record_reservation`	ACCEPTED → RESERVED	`reservation.record`	Record locator format valid; ticketing deadline set; passengers match quote	Deadline timers start
`record_tickets`	RESERVED → TICKETED	`ticket.record`	One ISSUED ticket per traveller; payment status PAID *or* owner-approved credit override	Customer notified; documents published
`close`	TICKETED → COMPLETED	`flight_request.transition`	—	—
(timer) `expire_quote`	QUOTED → EXPIRED	System	Quote `valid_until` passed	Customer notified
(timer) `expire_reservation`	RESERVED → EXPIRED	System	Deadline passed and reservation marked lapsed by admin or supplier	Admin alerted first at T-24 h and T-4 h

COMMAND	FROM → TO	WHO (PERMISSION)	GUARDS	SIDE EFFECTS
`reopen`	EXPIRED → IN_REVIEW	`flight_request.transition`	—	—
(customer) `cancel`	before RESERVED → CANCELLED	Owner of request	—	Notify assignee
`cancel`	before TICKETED → CANCELLED	`flight_request.transition`	Active reservation must be cancelled first (recorded)	Notify customer
(timer) `complete`	TICKETED → COMPLETED	System	Last segment departure + 24 h	—

Table 13.1 — Commands. "Owner of request" means the authenticated customer who owns it; the check is done server-side on every call.

13.4 Reference numbers

Format: `UT-{type}-{code}` where `type` is `F` (flight), `C` (cargo) or `A` (after-sales) and `code` is six characters of Crockford Base32 (no I, L, O, U). Example: `UT-F-8K4Q7M`.

- Codes are random, not sequential, so they leak no volume information; a unique index guarantees no collisions.
- The reference is a *lookup handle*, not a credential: possession of a reference never grants access. Every lookup is checked against ownership or permissions.
- References are read aloud on the phone, so the alphabet avoids ambiguous characters, and search in the console is case-insensitive.

13.5 Assignment, queues and SLA timers

Requests enter the **New** queue. Admins either *claim* a request or a lead assigns it. Timers are configurable in the Developer Panel (Chapter 16) and run as delayed BullMQ jobs (Chapter 26).

TIMER	DEFAULT	ACTION
Unassigned in NEW	30 min within business hours	Alert all admins; escalate to owners at 2 h
No first contact after assignment	2 h within business hours	Reminder to assignee
AWAITING_CUSTOMER without reply	24 h, then 72 h	Reminder to customer; then admin decides to close
Quote expiry	Per quote; default 24 h	Reminder at T-6 h; expire at T-0
Ticketing deadline	From reservation	Alert assignee at T-24 h and T-4 h; owners at T-2 h

Business hours are defined per team in two time zones (Europe/London and Asia/Tehran) so that Iranian customers' morning requests are not treated as overnight.

13.6 Quotes

- A request can have several quotes over time; each quote has a **version**, a **status** (`DRAFT`, `SENT`, `ACCEPTED`, `DECLINED`, `EXPIRED`, `SUPERSEDED`) and up to five **options**.
- An option contains the itinerary (from an offer snapshot, from a fresh admin search, or typed manually from the Amadeus terminal), the price breakdown (fare, taxes, service fee, total, currency), confirmed baggage and conditions, and the ticketing model.
- **Manually typed segments** are labelled `MANUAL` and carry the admin's identity as the attesting source. They are never shown with a "Live price" badge.

- Sending a new quote supersedes the previous one. A price change after acceptance always requires a new quote version and a new acceptance.

13.7 Reservations, tickets and payments in version 1

In version 1, admins create reservations and issue tickets in the tools Uni Travel already uses (for example the Amadeus agency terminal), then **record** them in the console. Recording is validated:

RECORD	REQUIRED FIELDS	VALIDATION
Reservation	Supplier/system, record locator, segments, passengers, ticketing deadline	Locator 6 alphanumerics; passengers and segments must match the accepted option, or the admin must record a reason for the difference
Ticket	Ticket number, passenger, validating carrier, issue date, coupons/segments, receipt PDF	13 digits; the 3-digit prefix must match the validating carrier's accounting code in the reference data
Payment	Amount, currency, method, date received, bank or receipt reference, evidence file	Allowed only at the stage permitted by the ATOL mode (Chapter 27); payer screened; amounts above a configurable threshold need a second staff member to verify

Automating reservation and ticketing through supplier APIs is a Stage 7 option (Chapter 31); the objects above are designed so that the API path writes the same records.

13.8 After-sales

Changes, refunds and cancellations after ticketing are handled as linked **after-sales requests** (`UT-A-…`) with a simpler lifecycle (`OPEN → IN_PROGRESS → AWAITING_CUSTOMER → RESOLVED / REJECTED`). The original request stays `TICKETED`, and ticket records move to `EXCHANGED`, `REFUNDED` or `VOIDED` as appropriate, so history is never rewritten.

13.9 History and audit

Every transition writes a `request_status_history` row (from, to, command, actor, reason, timestamp) and an append-only audit entry. The console shows the full timeline; the customer sees the customer-facing labels and the messages addressed to them, never internal notes.

CHAPTER 14

Cargo transport requests

Cargo follows the same pattern as flights — request, review, quote, fulfil — but adds what freight needs: a goods declaration, dimensions and weights, partner handover, tracking events and much heavier compliance screening.

14.1 Scope

> **DECISION D-05 · CARGO SERVICES IN VERSION 1**
>
> Three services: **documents and small parcels**, **excess baggage / personal effects** (unaccompanied), and **commercial air freight**. Road freight is out of scope. Uni Travel brokers shipments through partners (couriers, consolidators, freight forwarders); it does not operate transport itself. Every shipment is quoted by staff; nothing is auto-priced in version 1.

SERVICE	TYPICAL CUSTOMER	TYPICAL SIZE	KEY DATA	DEFAULT PARTNER TYPE
`DOCUMENTS`	Individual, student, small business	Envelope, < 2 kg	Sender, recipient, description, purpose	Courier / consolidator
`PARCEL`	Individual	1–30 kg, 1–5 pieces	Item list with values, dimensions	Courier / consolidator
`EXCESS_BAGGAGE`	Student moving to or from the UK	Boxes or suitcases, 20–100 kg	Item list (personal effects), owner's passport, travel dates	Baggage shipper / consolidator
`AIR_FREIGHT`	Business	45 kg and above, palletised or loose	Commodity, HS codes, commercial invoice, packing list, Incoterms, shipper and consignee companies	Freight forwarder

14.2 Lanes

A **lane** is an origin–destination country pair with its own rules, configured in the Developer Panel:

LANE FIELD	PURPOSE
`enabled`	Whether customers can choose the lane
`services`	Which of the four services the lane supports
`requires_compliance_approval`	Every request on the lane goes to `COMPLIANCE_HOLD` before an admin can quote
`partners`	Partners that can carry the lane, in priority order
`volumetric_divisor`	cm³ per kg for chargeable-weight estimates (partner-specific; commonly 6000 for air freight, often 5000 for couriers)
`customer_notice`	Lane-specific text shown before submission (e.g. transit times, current restrictions)

COUNSEL SIGN-OFF REQUIRED

Default configuration: any lane that touches Iran is created **disabled**, with `requires_compliance_approval = true`, until sanctions counsel has approved the lane, the services offered on it and the partner chain. Chapters 4 and 9 explain why: goods movements to and from Iran are subject to UK trade sanctions and export controls with strict-liability penalties, mainstream couriers have suspended Iran, and intermediaries in Türkiye and the UAE have been designated by the US. **Unaccompanied excess baggage** on Iran lanes stays disabled even after a lane opens, until counsel confirms whether the personal-effects exception covers it.

14.3 What the customer provides

The form adapts to the service. Fields marked † are required for `AIR_FREIGHT` only.

GROUP	FIELDS
Parties	Shipper and consignee: full name (Latin script), company†, address, phone (shipper's phone must be the verified account phone or another verified number), email, ID or company registration number where the partner requires it
Shipment	Service, lane, ready date, pickup or drop-off preference, number of pieces, per piece: length × width × height (cm) and weight (kg)
Contents	Line items: description, quantity, unit value and currency, country of origin, category (from a controlled list), HS code† (optional for others), purpose (`PERSONAL_EFFECTS`, `GIFT`, `DOCUMENTS`, `SALE`, `SAMPLE`, `RETURN`)
Commercial†	Incoterms, commercial invoice, packing list, export licence reference if any
Declarations	"Contains batteries / liquids / medicines / magnets" toggles; dangerous goods yes/no; insurance requested; declared total value
Documents	Uploads (PDF/JPG/PNG): invoice, packing list, ID, photos of contents (optional)
Consents	Accuracy of declaration; acknowledgement of prohibited-items list; privacy notice

The form calculates and shows **actual weight**, **volumetric weight** = L × W × H ÷ divisor, and **chargeable weight** = the greater of the two, clearly labelled as an estimate.

14.4 Goods screening

Before an admin sees a request, the compliance module (Chapter 27) screens both the **parties** and the **goods**:

CATEGORY (CONTROLLED LIST)	DEFAULT RULE	EXAMPLES
Documents, clothing, personal effects, books	Allowed	Certificates, used clothes, textbooks
Food (non-perishable), cosmetics	Allowed with partner rules	Dried fruit, packaged sweets
Medicines and medical devices	**Compliance review**	Prescription medicines, glucose meters
Electronics (phones, laptops, components)	**Compliance review**	Laptops, network equipment, drones
Lithium batteries (any)	**Compliance review**; partner DG acceptance needed	Power banks, devices with batteries
Aircraft, vehicle or industrial parts	**Compliance review**	Engine parts, sensors
High value (above configurable threshold)	**Compliance review**	Jewellery, art

CATEGORY (CONTROLLED LIST)	DEFAULT RULE	EXAMPLES
Weapons, ammunition, explosives, narcotics, counterfeit goods, cash and bearer instruments	**Prohibited — auto-decline**	—
Dangerous goods (flammable, corrosive, gases)	**Prohibited in v1**	Aerosols, paints

Matching works on the category the customer selects, on keywords in the description (in English and Persian), and on HS-code chapters for freight. Any review hit puts the request in `COMPLIANCE_HOLD`; prohibited hits decline it with a neutral message. The category list and rules are configuration, maintained by the compliance officer and approved by counsel; the table above is a starting proposal, not legal guidance.

14.5 Lifecycle

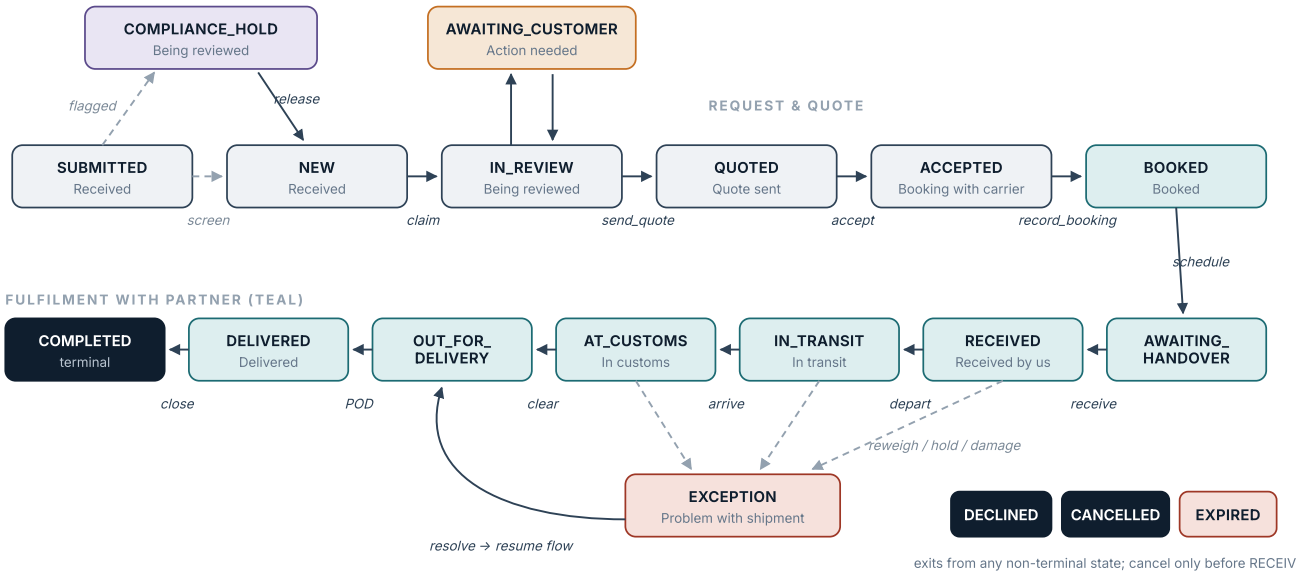


Figure 14.1 — Cargo request states. As with flights, fulfilment and payment status are separate; customer labels are shown under each state.

STATE	MEANING	CUSTOMER LABEL
`SUBMITTED`	Created; party and goods screening running	Received
`COMPLIANCE_HOLD`	Screening or lane rule requires a compliance decision	Being reviewed
`NEW` / `IN_REVIEW`	Waiting for / handled by a cargo admin	Received / Being reviewed
`AWAITING_CUSTOMER`	Missing information, documents or photos	Action needed
`QUOTED`	Quote sent with validity date	Quote sent
`ACCEPTED`	Customer accepted	Booking with carrier
`BOOKED`	Partner booking recorded (partner reference, AWB if issued)	Booked
`AWAITING_HANDOVER`	Pickup scheduled or awaiting drop-off	Awaiting pickup / drop-off
`RECEIVED`	Goods received by Uni Travel or partner; weights verified	Received by us
`IN_TRANSIT`	Moving between origin and destination	In transit
`AT_CUSTOMS`	Held for customs clearance	In customs

STATE	MEANING	CUSTOMER LABEL
`OUT_FOR_DELIVERY`	Final-mile delivery or ready for collection	Out for delivery
`DELIVERED`	Proof of delivery recorded	Delivered
`COMPLETED`	Closed after delivery and settlement	Completed
`EXCEPTION`	Held, damaged, lost, returned or re-weighed with a price change	Problem with shipment
`DECLINED` / `CANCELLED` / `EXPIRED`	Terminal exits as for flights (cancel only before `RECEIVED`)	Unable to arrange / Cancelled / Expired

Re-weighing at `RECEIVED` that changes the chargeable weight beyond a tolerance (default 5%) moves the shipment to `EXCEPTION` with reason `REWEIGH`. The admin issues a revised quote, which the customer must accept before the shipment proceeds.

14.6 Quotes for cargo

A cargo quote has the same versioning and expiry behaviour as a flight quote (Chapter 13) with cargo-specific lines: freight charge (rate × chargeable weight), fuel and security surcharges, handling, customs brokerage, duties and taxes (estimate or "payable by consignee"), insurance, pickup and delivery. Partner cost and margin are stored on the quote for internal reporting and are never sent to clients.

14.7 Service availability register

Because carrier and courier coverage of these lanes changes month to month (Chapter 9), cargo admins maintain a **service availability register**: for each provider, lane and service, a status (`AVAILABLE`, `SUSPENDED`, `UNKNOWN`), the source URL that supports it and the date it was last checked. The partner picker and the lane notice shown to customers read from it, and entries older than 30 days are flagged for re-checking.

14.8 Partners and handover

PARTNER FIELD	PURPOSE
Name, type (`COURIER`, `CONSOLIDATOR`, `FORWARDER`, `BAGGAGE_SHIPPER`)	Identification
Lanes and services served	Drives which partners admins can pick
Integration level (`MANUAL`, `EMAIL`, `API`)	v1 is manual: admins book with the partner outside the platform and record the result
Compliance status	Partners are screened like customers and re-screened when lists change
Contacts, SLAs, cut-off times	Shown to admins at booking time

When booking, the admin records the partner, the partner's booking reference, and the **air waybill (AWB)** number when issued. An AWB number has 11 digits: a 3-digit airline prefix and an 8-digit serial whose last digit is a check digit (the first seven digits modulo 7); the console validates it. Tracking events (`event_code`, location, timestamp, free text) are entered by admins in v1 and can be fed by partner APIs later. Customers see a tracking timeline that mirrors these events.

14.9 Documents

Uploads go to object storage through short-lived pre-signed URLs, are virus-scanned (Chapter 28), and are linked to the request with a document type. Staff can publish generated documents to the customer (shipment summary, quote PDF, receipt). Commercial invoices remain the customer's responsibility; the platform provides a template.

CHAPTER 15

Admin Panel

The Admin Panel is where requests become reservations, tickets and shipments. It is deliberately plain: queues, one detail screen per request, a quote builder and a handful of recording dialogs. Configuration lives elsewhere.

15.1 Design principles

- **One screen per case.** Everything an admin needs to phone a customer — who they are, what they asked for, what the engine found, what has happened so far — is on the request detail screen.
- **Commands, not fields.** Admins never edit a status field. They press the actions the state machine allows for that state and their permissions; disabled actions explain why ("Quote needs confirmed baggage on option 2").
- **No technical settings.** Provider credentials, engine rules and notification templates are in the Developer Panel. Admins can *read* the engine rule that produced a result (to explain it to a customer), not change it.
- **Desktop first, mobile capable.** Quote building and recording dialogs are desktop features in v1. The mobile admin mode covers triage: queue, claim, call, note, message, request information.

15.2 Screens

SCREEN	PURPOSE	KEY ELEMENTS
Home	Start of shift	My open cases, unassigned count, SLA breaches, reservations with deadlines in the next 24 h, compliance holds (compliance officers)
Queues	Find work	Tabs: New · Mine · Awaiting customer · Quoted · Reserved · Cargo · All. Filters: type, status, route, travel date, assignee, flags. Sort by SLA risk by default
Request detail	Work a case	Three columns: customer and travellers · request, snapshot and timeline · actions, quotes, records, notes and messages
Staff search	Find options for a quote	Same engine as customers, plus staff fields (provider, booking class, fare basis, offer id) and "Add to quote"
Quote builder	Price options	Options from snapshot, staff search or manual entry; validations; customer preview; send
Record dialogs	Mirror external actions	Reservation, ticket, payment, partner booking, tracking event
Cargo detail	Work a shipment	Parties, goods list with screening results, dimensions and chargeable weight, documents, partner booking, tracking
Compliance cases	Decide holds	Case list, match evidence, decision with reason, four-eyes override
Customer	Context	Profile (PII permission), verified identities, requests history, contact log

15.3 Request detail in depth

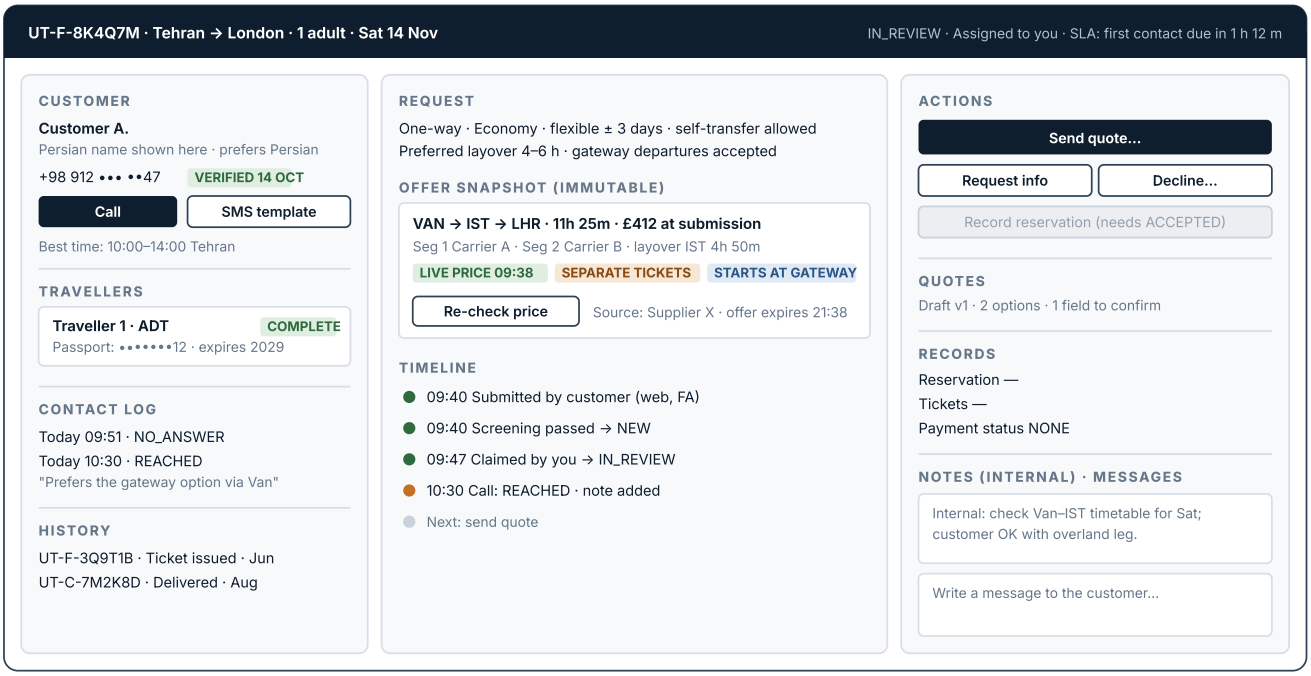


Figure 15.1 — Request detail layout (wireframe). Actions shown in the right column are computed by the server from the request state and the admin's permissions.

Left — customer. Name (Latin and Persian), verified phone with verification date and a *Call* action (`tel:` on mobile, click-to-copy on desktop), email, preferred language and contact time, previous requests, and travellers with document completeness indicators. Passport numbers are masked until the admin clicks *Reveal*, which is logged (`customer.read.documents`).

Centre — the case. Route, dates, travellers, preferences, the immutable offer snapshot with its original truth badges and fetch time, a *Re-check price* button (calls the supplier again and shows the difference without altering the snapshot), and the timeline of status changes, messages, contact attempts and records.

Right — actions and records. Available commands; assignment; internal notes (never visible to customers); customer messages; quotes with their status; reservation, ticket and payment records; documents.

15.4 Contacting customers

The brief makes the verified phone the main channel. The console supports it directly:

- **Call logging.** After each call the admin records an outcome — `REACHED`, `NO_ANSWER`, `BUSY`, `WRONG_NUMBER`, `CALL_BACK_REQUESTED` (with time) — and an optional note. Outcomes feed SLA reporting.
- **Template SMS.** Admins can send pre-approved SMS templates ("We tried to call you about UT-F-8K4Q7M…") through the SMS router (Chapter 17). Free-text SMS is off by default to control cost and content; it can be enabled per role.
- **In-app messages.** Free-text messages to the customer appear in the request thread and trigger push or SMS according to the notification rules.

15.5 Quote builder

1. **Add options** from the customer's snapshot, from a staff search ("Add to quote"), or by typing segments manually from the Amadeus terminal. Manual segments are labelled `MANUAL` and attested by the admin.
2. **Confirm what the supplier did not return.** For each option the builder lists every `UNKNOWN` attribute (baggage, change and refund conditions) and blocks sending until the admin fills it in from the fare rules.

3. **Price.** Fare, taxes and the Uni Travel service fee; total in the quote currency. The builder shows the supplier price, the fetch time and the difference from the snapshot.
4. **Set validity.** Default from configuration (24 h); never later than the supplier's offer expiry, if known.
5. **Preview** exactly what the customer will see, in their language, then **Send**. The request moves to `QUOTED` and the customer is notified.

15.6 Cargo detail specifics

- Goods table with the screening outcome per line (allowed / review / prohibited) and the matched rule.
- Dimensions per piece with automatic volumetric and chargeable weight using the lane's divisor; a re-weigh field at `RECEIVED` that triggers `EXCEPTION` beyond tolerance.
- Partner picker limited to partners that serve the lane and service and are compliance-cleared.
- AWB entry with check-digit validation; tracking event entry with event codes and locations.

15.7 Compliance cases

Compliance officers see a separate queue. Each case shows what triggered it (party name match with score and the list entry matched, a blocked carrier in the snapshot, a goods rule, a lane rule), the request context, and three decisions: **Release** (with reason), **Decline** (reason code plus neutral customer message), **Escalate to owner**. Overriding a *prohibited* rule requires a second compliance officer or owner to approve (four-eyes). All decisions are immutable audit records (Chapter 27).

15.8 Mobile admin mode

Available to users with `admin` or `cargo_admin`. It includes: the queues (read-only filters), request detail (read), claim, call and log outcome, add internal note, send message, `request_info`, and push notifications for new and assigned requests. Quote sending, recording dialogs and compliance decisions are not available on mobile in v1, to keep the app simple and reduce the risk of errors on small screens.

CHAPTER 16

Developer Panel

The Developer Panel is the control room for the platform owner and authorised developers. It covers every item listed in brief §10, and every change it makes is versioned, validated and audited.

16.1 Access and protection

CONTROL	RULE
Hostname	Served on its own hostname (e.g. `dev.` subdomain); the customer site and Admin Panel cannot reach its routes
Authentication	Staff sign-in (phone OTP) **plus** a second factor: passkey (WebAuthn) preferred, TOTP accepted
Step-up	Sensitive actions (privileged role changes, credential rotation, publishing engine rules, disabling a provider, exporting audit logs) require re-authentication within the last 10 minutes
Network	Optional IP allowlist per environment
Session	Idle timeout 30 minutes; absolute lifetime 12 hours; visible list of active sessions with *Revoke*
Permissions	Each section requires its own permission (Table 10.1); read-only views exist for most sections
Change safety	Configuration is edited as a draft, validated, optionally simulated, then published as a new version; the previous version is one click away

16.2 Sections

1. Users and roles

- **User directory**: search by name, phone, email or reference; filters by role, status, verification state, last activity.
- **User detail**: identities (phones and emails with verification timestamps), roles, active sessions and devices, recent security events (sign-ins, failed OTPs, role changes), requests summary.
- **Role assignment**: add or remove roles. Privileged roles need `user.role.assign.privileged`, step-up and produce an owner notification. The last owner cannot be removed.
- **Account actions**: suspend or reactivate, revoke all sessions, force re-verification of phone, unlink an identity.
- **Role editor**: create custom roles by combining permissions from the catalogue. Built-in roles can be cloned but not deleted.

2. Flight API configuration (providers)

SETTING	NOTES
Enabled / disabled, environment (test, production)	Disabling a provider takes effect within seconds through a cache-invalidation event
Credentials	Write-only: entered or rotated here, encrypted at rest, never displayed again, never sent to any client; last-rotated date and the rotating user shown
Capabilities in use	Search, price, seat map, order creation (each can be switched off independently)
Markets and routes	Point-of-sale settings, currency, which origin and destination regions the provider should be queried for

SETTING	NOTES
Limits	Timeouts, maximum concurrent calls, requests per second, daily call budget, look-to-book alert threshold
Priority	Used when results are deduplicated across providers
Test connection	Runs a harmless call (e.g. a reference-data lookup or a fixed sandbox search) and shows the raw status, latency and any error code

3. Integration health and errors

A live view of every external dependency: providers, SMS routes, push, email, object storage, sanctions-list sync. For each: success rate, p50/p95 latency, last error with its normalised code (Chapter 21), circuit-breaker state, and the queue depth of related jobs. Failed jobs land in a **dead-letter view** where a developer can inspect the payload (personal data redacted), retry or discard.

4. Search and itinerary engine settings

The engine is configured through **rule sets** (Chapter 22): global defaults, then overrides per route, airport, carrier pair and gateway. The editor offers:

- forms with validation for each rule type (connection times, layover window, airport changes, overnight, maximum stops, scoring weights, limits and cache TTLs);
- **hubs and gateways**: which hub airports to consider for each origin and destination region, and which gateways to suggest for restricted origins, with customer-facing access notes;
- **simulate**: run a stored or ad-hoc query against the draft rules using cached supplier responses (no new supplier calls) and compare results with the published version side by side;
- **publish and roll back** with a mandatory change note.

5. Request workflow configuration

SLA timers, business hours per team and time zone, default quote validity, decline and cancellation reason codes, required fields per request type, auto-assignment (off, round-robin, by language), payment verification threshold for four-eyes, and the customer-facing label text for each state (per language).

6. Notification configuration

The event × channel matrix (Chapter 17), templates per language with variable preview and SMS segment counter, SMS routing by country prefix with fallback order, quiet hours, throttling rules, and a **send test** button that delivers a template to the developer's own verified phone or email.

7. Authentication settings

SETTING	DEFAULT
OTP length / lifetime	6 digits / 5 minutes
Maximum verification attempts per code	5
Resend cooldown	60 s, doubling after each resend
Sends per phone	5 per hour, 10 per day
Allowed SMS destination countries	Iran, United Kingdom, EU/EEA, Türkiye, Armenia, Georgia, UAE (editable)
Challenge (proof-of-work captcha) after	3 sends from one IP within 10 minutes
Email sign-in	Enabled

SETTING	DEFAULT
Require verified phone to submit requests	On
Access token / refresh token lifetime	10 minutes / 30 days rotating (staff: 12 hours absolute)
Staff second factor	Required

8. Audit logs

Every security-relevant and business-relevant action is in the audit log (Chapter 28): who, what, which record, before and after values (with personal data masked), from which IP and client, and the request id for tracing. Filters by actor, action, entity, reference and date; export to CSV requires step-up and is itself audited.

9. System diagnostics

Health of the database, Redis, queues and workers; application version and commit; database migration status; configuration versions in force; feature flags; maintenance-mode switch with a customer-facing banner message.

10. Application settings and feature flags

Company details and contact points, supported languages, display currencies, legal document versions (terms and privacy notices, with re-consent on change), and feature flags such as `cargo.enabled`, `search.gateways.enabled`, `seatmaps.enabled`, `payments.online.enabled` (off in v1) and `search.self_transfer.enabled`.

16.3 How configuration reaches the running system

1. The Developer Panel calls a `/v1/dev/…` endpoint; the API validates the payload against the same Zod schema the editor used.
2. The change is stored as a new immutable version row with author, timestamp and change note; the audit log records the diff.
3. A `config.published` event is placed on the outbox; API and worker processes receive it through Redis pub/sub and reload the affected configuration from the database.
4. Each process logs the configuration version it is running, which the diagnostics page shows, so drift is visible.

CHAPTER 17

Notifications and communication

Customers in Iran and customers in Europe need different channels. The notification service treats the in-app inbox as the permanent record, uses push where it works, and falls back to SMS for anything a customer must not miss.

17.1 Channels

CHANNEL	ROLE	STRENGTHS	LIMITS
In-app inbox	System of record for every notification	Always available when the user opens the app or site; no third party; full content	Not proactive
Push (iOS, Android, web)	Proactive nudge	Free, instant	Android push through Google's FCM (which Expo uses) is unavailable to Iranian IPs; a non-FCM provider is piloted for Android users in Iran (Chapter 8); tokens expire; users can disable
SMS	Guaranteed reach for critical events and OTP	Works on any phone, survives app-store and internet restrictions	Costs per message; Persian text uses UCS-2 encoding, so one SMS segment holds 70 characters instead of 160
Email	Copies, documents, staff digests	Rich content, attachments	Lower urgency; deliverability to some Iranian providers varies
Telegram	Not in scope (brief §11)	—	—

17.2 Event catalogue

EVENT	CUSTOMER	ADMINS	OTHERS	DEFAULT CHANNELS
`request.submitted`	Confirmation with reference	All on-duty admins of that request type	—	Customer: inbox + SMS. Admins: inbox + push
`request.assigned`	—	Assignee	—	Inbox + push
`request.info_requested`	"Action needed"	—	—	Inbox + push; SMS if not read in 30 min
`request.message_from_staff`	Message preview	—	—	Inbox + push; SMS if not read in 2 h
`request.message_from_customer`	—	Assignee	—	Inbox + push
`quote.sent`	Options ready, with expiry	—	—	Inbox + push + SMS
`quote.expiring` (T-6 h)	Reminder	Assignee	—	Inbox + push + SMS
`quote.accepted`	Confirmation	Assignee	—	Inbox + push
`reservation.deadline_approaching`	—	Assignee (T-24 h, T-4 h)	Owners (T-2 h)	Inbox + push + email

EVENT	CUSTOMER	ADMINS	OTHERS	DEFAULT CHANNELS
`ticket.issued`	Ticket numbers + receipt	—	—	Inbox + push + SMS + email (PDF)
`cargo.status_changed`	Tracking update	—	—	Inbox + push; SMS for `AWAITING_HANDOVER`, `AT_CUSTOMS`, `DELIVERED`, `EXCEPTION`
`compliance.hold_created`	—	—	Compliance officers	Inbox + push + email
`security.new_sign_in`	Alert	—	—	Inbox + push + email
`security.role_changed`	Alert	—	All owners	Inbox + push + email
`provider.degraded`	—	—	Developers	Inbox + email

Table 17.1 — Default routing. All rows are editable in the Developer Panel except security events, which cannot be disabled.

17.3 Routing algorithm

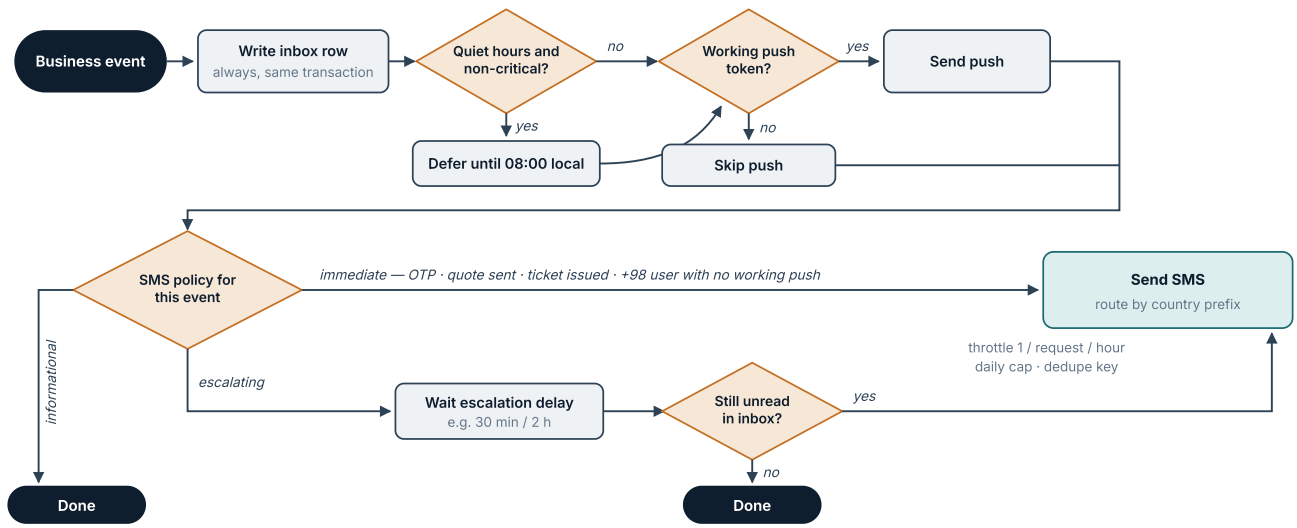


Figure 17.1 — Delivery decision for one notification to one user. Every attempt is recorded in `notification_deliveries`.

The worker applies these rules for each recipient:

1. **Always write the inbox row** first, in the same transaction as the business event (via the outbox, Chapter 26).
2. **Respect preferences and quiet hours** for non-critical events (quiet hours default 22:00–08:00 in the recipient's time zone; deferred, not dropped).
3. **Push** if the user has at least one device token that delivered successfully in the last 30 days. Expired tokens are removed when the push service reports them invalid.
4. **SMS escalation** for events marked *critical* or *escalating*: send immediately when the event requires it (OTP, quote sent, ticket issued), or after the configured delay if the inbox item is still unread. For users whose only phone is a +98 number and who have no working push token, escalation is immediate.
5. **Throttle**: at most one escalation SMS per request per hour, and a per-user daily SMS cap (default 6, excluding OTP), to protect customers and budget.
6. **Deduplicate** by `(event_id, recipient, channel)` so retries never send twice.

17.4 Templates

- Each template exists per language (English, Persian) and per channel; the variable set is declared (e.g. `{ref}`, `{status_label}`, `{expires_at_local}`) and validated at save time.
- SMS templates show a live segment counter (GSM-7 vs UCS-2). Persian templates should fit in one or two segments: reference, status and a short link, nothing more.
- Links in SMS are short links on Uni Travel's own domain that open the request in the app or website after sign-in; they carry no personal data and grant no access on their own.
- Dates are rendered in the recipient's time zone and calendar preference (Jalali for Persian users who chose it).
- Kavenegar-style OTP templates must be pre-approved by the SMS provider; template ids are part of the SMS route configuration (Chapter 8).

17.5 Delivery tracking

SMS providers' delivery reports arrive on webhook endpoints (`/v1/webhooks/sms/{provider}`), verified by signature or shared secret and mapped to delivery rows (`QUEUED`, `SENT`, `DELIVERED`, `FAILED`, `UNDELIVERABLE`). Push and email results are recorded the same way. The Developer Panel shows delivery rates per route and alerts developers when a route's success rate drops below a threshold, so a failing SMS provider is noticed before customers complain.

17.6 Admin alerts without alert fatigue

New-request alerts go to *on-duty* admins only (on-duty is a toggle in the console and mobile admin mode). Outside business hours, new requests generate a single digest email per hour to on-call staff, plus immediate push for requests flagged urgent (travel within 72 hours).

PART D

D

Technical architecture

The modular monolith, its modules and data model, the supplier framework and itinerary engine, the API, security and compliance machinery, the clients and the infrastructure.

18	Architecture overview	65
19	Repository and code organisation	70
20	Backend modules	73
21	Supplier integration framework	77
22	Itinerary and connection engine	81
23	Data model	87
24	API design	94
25	Authentication and authorisation	100
26	Background jobs, events and caching	104
27	Compliance engine	107
28	Security and privacy	110
29	Website, console and mobile app	113
30	Infrastructure, deployment and operations	116

CHAPTER 18

Architecture overview

A modular monolith in TypeScript: one NestJS codebase running as an API process and a worker process, PostgreSQL as the system of record, Redis for speed and queues, and three clients that hold no authority of their own.

18.1 Architectural drivers

DRIVER	WHAT IT DEMANDS	WHERE IT IS ADDRESSED
Truthful data	No fabricated or stale flights shown as bookable; every price traceable to a source and time	Truth model (§18.6), supplier framework (Ch. 21), engine (Ch. 22)
Correct state	Request ≠ reservation ≠ ticket; no lost or duplicated transitions	State machines with guards, transactional outbox (Ch. 13, 26)
Security and privacy	Backend-enforced permissions, protected passport data, strong staff authentication	Ch. 25, 28
Compliance by design	Sanctions and export-control rules applied before staff act	Compliance module (Ch. 27)
Works for users in Iran	No hard dependency on Google services; SMS fallback; light pages; tolerant of outages	Ch. 8, 17, 29
Provider independence	Add or drop a flight provider without touching the engine or UI	Adapter framework (Ch. 21)
Simplicity	Small team, no microservices, minimal infrastructure	This chapter, Ch. 30
Cost control	Supplier calls and SMS cost money	Call budgets, caching, throttling (Ch. 21, 22, 17)

18.2 Architectural style

ADR-01 · MODULAR MONOLITH, TWO PROCESS ROLES

One NestJS application, organised into modules with explicit boundaries (Chapter 20), deployed as two process roles built from the same code: **api** (HTTP) and **worker** (BullMQ consumers and timers). This keeps deployment simple and transactions local, while letting search fan-out and notifications scale separately from the API. It is not a microservice architecture: there is one database, one codebase and one release. Splitting a module out later is possible because modules communicate through interfaces and events, not shared tables.

18.3 System context

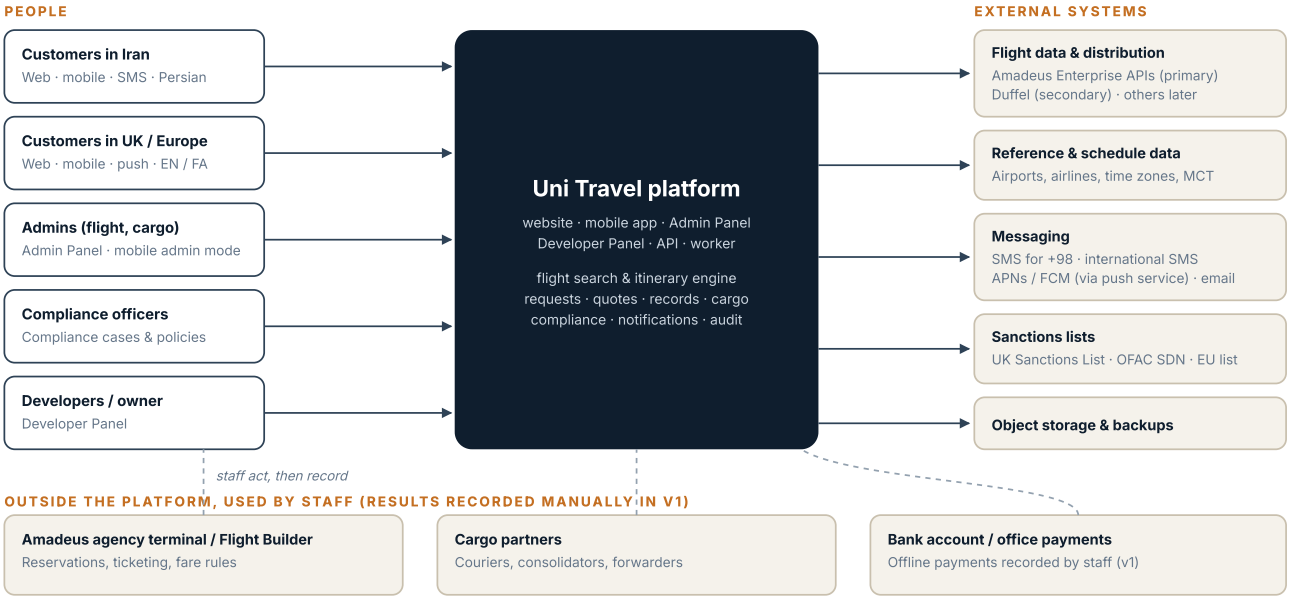


Figure 18.1 — System context. Uni Travel's platform sits between customers and staff on one side and flight, messaging and data providers on the other.

18.4 Containers

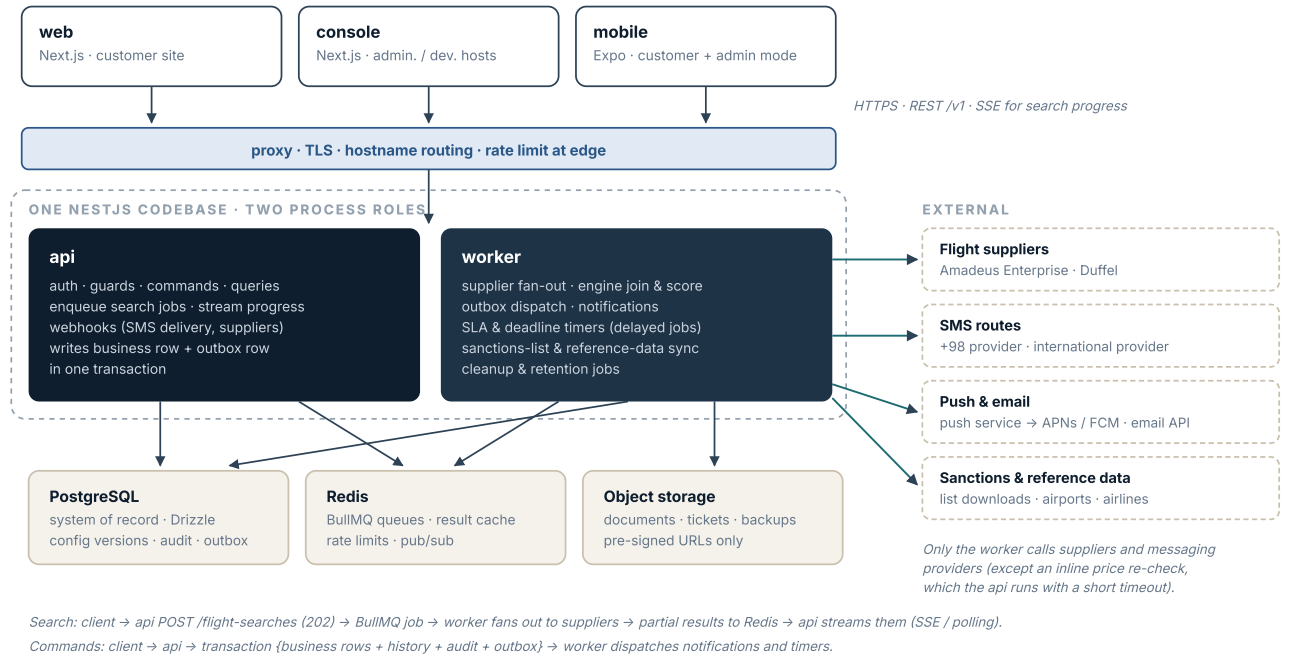


Figure 18.2 — Containers and their main interactions. All clients talk only to the API; only the worker talks to most external providers.

CONTAINER	TECHNOLOGY	RESPONSIBILITY	SCALES BY
`web`	Next.js (App Router), React, TypeScript, Tailwind, shadcn/ui, Base UI	Customer website; server-renders public pages; calls the API with the user's session	Replicas behind the proxy
`console`	Next.js, same UI kit	Admin Panel and Developer Panel (two hostnames, one app)	Replicas

CONTAINER	TECHNOLOGY	RESPONSIBILITY	SCALES BY
`mobile`	Expo / React Native PROPOSED	Customer app with admin mode	App stores / direct distribution
`api`	NestJS, REST	Authentication, authorisation, all business commands and queries, SSE for live updates	Replicas (stateless)
`worker`	NestJS (same code), BullMQ	Supplier fan-out, notifications, timers, outbox dispatch, list sync, housekeeping	Replicas; queues are partitioned by priority
`postgres`	PostgreSQL + Drizzle ORM	System of record; configuration versions; audit	Vertical first; read replica later
`redis`	Redis	BullMQ queues, search result cache, rate limits, OTP attempt counters, pub/sub for config and live updates	Vertical; managed or self-run
`object storage`	S3-compatible PROPOSED	Documents, tickets, cargo files, backups	Provider
`proxy`	Caddy or Nginx PROPOSED	TLS, routing by hostname, compression, request size limits	—

18.5 Technology stack

The stack follows the Engineering Kit as recorded for this project. Items marked PROPOSED fill gaps the Kit does not cover and need approval before use; none of them introduces a new language or a service mesh.

LAYER	CHOICE	STATUS	WHY
Language	TypeScript everywhere	Kit	One language for web, console, API, worker and mobile
Web framework	Next.js, React	Kit	
Styling / UI	Tailwind CSS, shadcn/ui, Base UI	Kit	RTL via logical properties
Backend	NestJS, REST	Kit	Modules, guards, interceptors fit the permission model
Database	PostgreSQL, Drizzle ORM	Kit	Strong transactions, JSONB for supplier payloads
Cache / jobs	Redis, BullMQ	Kit	Delayed jobs implement SLA timers
Payments	Stripe	Kit — **parked**	Not used in v1 (Decision D-03, Chapter 4)
Mobile	Expo / React Native	PROPOSED	Shares TypeScript, validation schemas and API client with the web; Flutter is excluded by the Kit
Monorepo	pnpm workspaces + Turborepo	PROPOSED	Shared packages and cached builds
Validation / contracts	Zod (+ `nestjs-zod`), OpenAPI generated from schemas	PROPOSED	One schema validates the form, the request and the docs
Client data	TanStack Query	PROPOSED	Caching, retries, polling for search progress
i18n	`next-intl` (web), `i18next` (mobile)	PROPOSED	Persian and English, ICU plurals
Logging / tracing	Pino, OpenTelemetry	PROPOSED	Structured logs with request ids
Testing	Vitest, Testcontainers, Playwright, Maestro	PROPOSED	Chapter 32

LAYER	CHOICE	STATUS	WHY
Containers	Docker, Compose	PROPOSED	Chapter 30

18.6 The truth model

The brief's central rule — never present fabricated or unverified flights as bookable — is implemented as an explicit ladder. Every piece of flight information in the system carries its rung, its source and its timestamp, and the UI renders a badge from them. Nothing can climb a rung without the corresponding event.

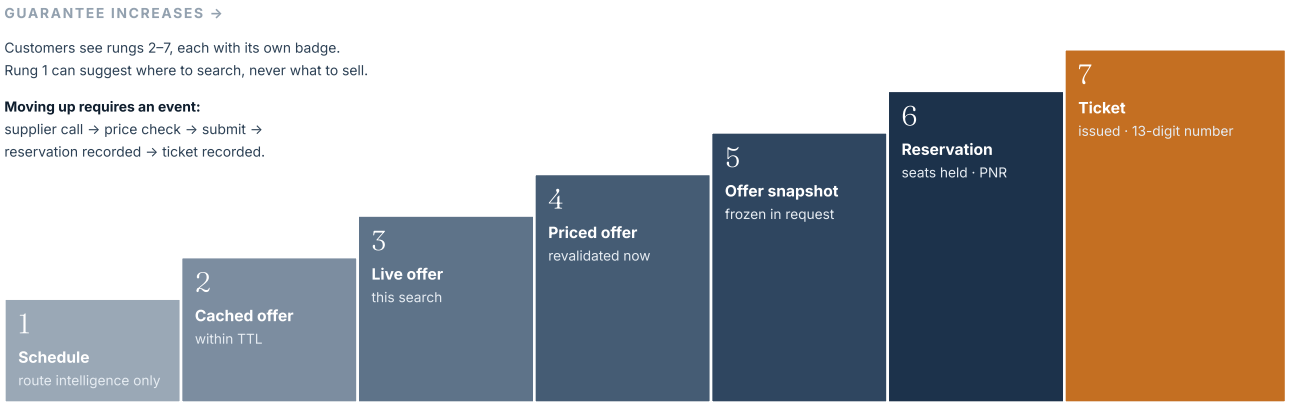


Figure 18.3 — The truth ladder. Each rung is a different object with different guarantees; the badge shown to users is derived from the rung.

RUNG	OBJECT	GUARANTEE	BADGE
1	Schedule (route intelligence)	The airline publishes this flight on these days	*Not shown to customers as an option*
2	Cached offer	A supplier returned this price within the cache TTL	"Price from {time}"
3	Live offer	Returned by the supplier for this search	"Live price · {time}"
4	Priced / revalidated offer	Supplier confirmed price and availability just now	"Price confirmed · {time}"
5	Offer snapshot	What the customer chose, frozen	Shown inside the request with its original badge
6	Reservation	Seats held in an airline or supplier system	"Seats reserved · ticket by {deadline}"
7	Ticket	Ticket issued	"Ticket issued · {number}"
—	Manual option	Typed by staff from a terminal	"Confirmed by Uni Travel staff"

18.7 Key decisions at a glance

ADR	DECISION	CONSEQUENCE
01	Modular monolith with api and worker roles	Simple operations; module boundaries must be policed (Ch. 19)
02	REST with OpenAPI generated from Zod schemas	Typed clients for web, console and mobile from one source
03	PostgreSQL is the system of record; side effects via a transactional outbox	No lost notifications or double sends

ADR	DECISION	CONSEQUENCE
04	BullMQ for async work and timers	SLA timers survive restarts; retries with back-off
05	Flight search runs as an asynchronous job with progressive results	Slow suppliers never block the page; partial results appear early
06	Suppliers behind a normalised adapter interface with capability flags	New providers without engine or UI changes
07	Configuration (rules, workflows, templates) is versioned data	Changes are audited and reversible; no redeploy for rule changes
08	Field-level encryption for passport data	Database dumps and logs never expose document numbers
09	One mobile app, role-based UI	Admin promotion works by permission refresh, not reinstall
10	No Google-dependent service in a critical path	OTP, captcha, maps and fonts work for users in Iran

CHAPTER 19

Repository and code organisation

One monorepo, five apps, a handful of shared packages and a small set of rules that keep module boundaries honest. The layout is designed so that Claude Code and human developers can find anything by convention.

19.1 Monorepo layout

PROPOSED pnpm workspaces with Turborepo for task orchestration and build caching.

```
unitravel/
├─ apps/
│  ├─ api/                NestJS — HTTP process role (main.api.ts)
│  │  └─ src/
│  │     ├─ main.api.ts
│  │     ├─ main.worker.ts  same app, worker process role
│  │     ├─ app.module.ts
│  │     └─ modules/        one folder per backend module (Chapter 20)
│  ├─ web/                Next.js — customer website (/[locale]/…)
│  ├─ console/            Next.js — Admin Panel (admin.*) + Developer Panel (dev.*)
│  └─ mobile/             Expo — customer app with admin mode
├─ packages/
│  ├─ contracts/          Zod schemas, DTO types, error codes, enums, OpenAPI build
│  ├─ api-client/         Generated typed client (from OpenAPI) used by web, console, mobile
│  ├─ db/                 Drizzle schema, migrations, seed, test factories
│  ├─ domain/             Pure domain logic: state machines, money, time, reference formats
│  ├─ engine/             Itinerary engine core (pure functions, no I/O) — Chapter 22
│  ├─ ui/                 Shared React components (shadcn/ui + Base UI), tokens, RTL helpers
│  ├─ i18n/               Message catalogues (en, fa), formatting helpers (Jalali, numbers)
│  └─ config/             ESLint, TypeScript and Tailwind presets
├─ infra/                 Dockerfiles, compose files, proxy config, backup scripts
├─ docs/                  ADRs, runbooks, this booklet's source of truth for decisions
└─ .github/workflows/     CI pipelines
```

Why `engine` and `domain` are separate packages

The itinerary engine and the state machines are the two places where mistakes are most expensive. Keeping them as pure TypeScript packages with no NestJS, database or network dependencies means they can be unit-tested exhaustively (including property-based tests, Chapter 32), reused by the Developer Panel's rule simulator, and reasoned about in isolation.

19.2 Module boundary rules

BOUNDARY RULES (ENFORCED IN CI)

1. A backend module exposes a **public interface** (`index.ts` : service interface, events, DTOs). Other modules import only from that file — enforced with ESLint `no-restricted-imports` / dependency-cruiser rules.
2. A module owns its tables. Other modules never query them directly; they call the owning module's service or react to its events.
3. Cross-module side effects go through **domain events** written to the outbox (Chapter 26), not direct calls, unless the caller needs an answer synchronously.
4. Supplier SDKs and HTTP clients are imported only inside `modules/suppliers/adapters/*` .
5. `packages/engine` and `packages/domain` import nothing from `apps/*` and perform no I/O.

19.3 Conventions

TOPIC	CONVENTION
IDs	UUID v7 (time-ordered) as primary keys; public references (`UT-F-…`) are separate columns
Time	Stored as `timestamptz` in UTC; local flight times stored with the airport's IANA zone; never compute with local strings
Money	Integer minor units + ISO-4217 currency (`{ amountMinor: 41200, currency: 'GBP' }`); no floats; FX conversions labelled indicative
Naming	Tables `snake_case` plural; TypeScript `camelCase` ; enums `UPPER_SNAKE`
Validation	Every API input validated with the Zod schema from `packages/contracts` ; outputs serialised through the same schemas
Errors	Typed error codes (`INVALID_TRANSITION` , `OTP_EXPIRED` , `SUPPLIER_TIMEOUT` , …) mapped to RFC 9457 problem responses (Chapter 24)
Logging	Pino JSON; every log line carries `requestId` , `userId` (if any), `module` ; personal data redacted by a shared serializer
Config	Environment variables only for secrets and infrastructure endpoints; business configuration lives in the database (versioned)
Feature flags	Read through one `FlagsService` ; flags have owners and removal dates
Migrations	Drizzle Kit, forward-only, reviewed SQL committed; destructive changes split across two releases (expand, then contract)
Commits	Conventional commits; each PR links to a user story id (Chapter 31)

19.4 Branching, environments and CI

- **Trunk-based**: short-lived feature branches, PR review, squash merge to `main` .
- **CI on every PR**: type-check, lint (including boundary rules), unit tests, integration tests with Testcontainers (PostgreSQL, Redis), contract tests against recorded supplier fixtures, build of all apps, OpenAPI diff (breaking changes fail the build unless labelled).
- **Main branch**: builds container images tagged with the commit, deploys automatically to **staging**; production deploys are manual promotions of a staging-verified image.

- **Mobile**: Expo builds per release; over-the-air updates only for JavaScript-only fixes, never for changes that alter permissions or security behaviour.

19.5 Generated artefacts

ARTEFACT	GENERATED FROM	USED BY
OpenAPI document	Zod schemas + NestJS controllers	API reference, client generation, contract tests
`api-client`	OpenAPI	web, console, mobile
Permission catalogue	`packages/contracts/permissions.ts`	API guards, Developer Panel role editor, docs
Error code table	`packages/contracts/errors.ts`	API, clients (localised messages), docs
Database docs	Drizzle schema	Developer onboarding

CHAPTER 20

Backend modules

Sixteen modules, each owning its tables and exposing a narrow interface. This chapter is the map Claude Code should follow when creating folders, services and events.

20.1 Module map

MODULE	RESPONSIBILITY	OWNS (TABLES)	PUBLISHES EVENTS
`identity`	Sign-up, OTP challenges, phone and email identities, sessions, refresh tokens, devices, staff second factor	`users`, `user_identities`, `otp_challenges`, `sessions`, `refresh_tokens`, `devices`, `mfa_factors`	`user.registered`, `identity.verified`, `session.revoked`
`access`	Roles, permissions, role assignment, `perm_version`, guards	`roles`, `role_permissions`, `user_roles`	`user.permissions_changed`
`customers`	Profiles, travellers, encrypted travel documents, contact preferences	`customer_profiles`, `travellers`, `traveller_documents`	`traveller.updated`
`reference`	Airports, cities, countries, time zones, airlines and their accounting codes, aircraft types	`airports`, `cities`, `countries`, `airlines`, `aircraft_types`	`reference.updated`
`suppliers`	Provider registry, adapter selection, credentials, budgets, health, circuit breakers, call log	`providers`, `provider_credentials`, `provider_calls`	`provider.health_changed`
`search`	Search jobs, normalisation, engine orchestration, result cache, offer snapshots, seat-map retrieval	`searches`, `search_results`, `offer_snapshots`	`search.completed`
`requests`	Flight requests, state machine, assignment, notes, customer messages, contact log, quotes	`flight_requests`, `request_travellers`, `request_status_history`, `request_notes`, `request_messages`, `contact_attempts`, `quotes`, `quote_options`	`flight_request.submitted`, `flight_request.transitioned`, `quote.sent`, `quote.accepted`
`bookings`	Reservations, tickets, after-sales cases	`reservations`, `reservation_segments`, `tickets`, `after_sales_cases`	`reservation.recorded`, `ticket.recorded`
`payments`	Offline payment records, verification, payment status; online payment adapter (parked)	`payment_records`	`payment.recorded`, `payment.verified`

MODULE	RESPONSIBILITY	OWNS (TABLES)	PUBLISHES EVENTS
`cargo`	Cargo requests, items, lanes, partners, partner bookings, tracking events, service-availability register	`cargo_requests`, `cargo_items`, `cargo_pieces`, `cargo_lanes`, `partners`, `partner_bookings`, `tracking_events`, `service_availability`	`cargo_request.submitted`, `cargo_request.transitioned`
`compliance`	Party, carrier, route and goods screening; list ingestion; policies; cases and decisions	`sanction_lists`, `sanction_entries`, `screenings`, `screening_hits`, `compliance_policies`, `compliance_cases`, `compliance_decisions`	`compliance.case_opened`, `compliance.case_decided`
`notifications`	Inbox, routing, templates, deliveries, SMS/push/email channel adapters, delivery webhooks	`notifications`, `notification_deliveries`, `notification_templates`, `sms_routes`	`notification.delivered`
`documents`	Upload sessions, file metadata, virus scanning, pre-signed URLs, publication to customers	`documents`, `document_links`	`document.published`
`config`	Application settings, feature flags, versioned rule sets (engine, workflow, notification matrix)	`settings`, `feature_flags`, `config_versions`	`config.published`
`audit`	Append-only audit log and its query API	`audit_log`	—
`platform`	Outbox dispatcher, scheduler, health, diagnostics, idempotency keys	`outbox_events`, `idempotency_keys`, `job_runs`	—

Table 20.1 — Backend modules. Table lists are indicative; Chapter 23 gives the full data model.

20.2 Dependency direction

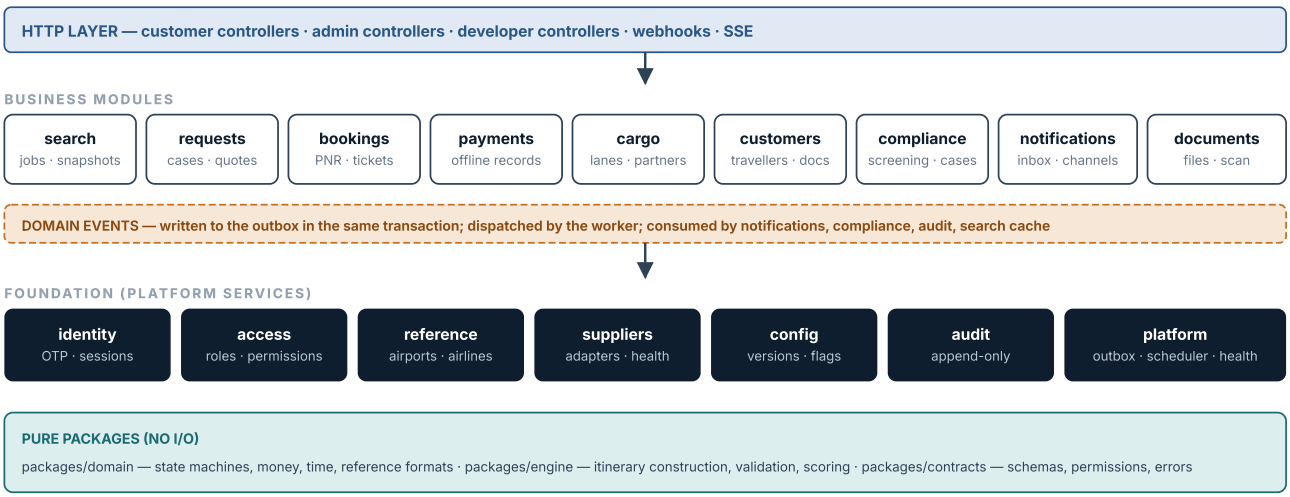


Figure 20.1 — Allowed dependencies (arrows point from caller to callee). Business modules depend on platform services; nothing depends on business modules except through events.

20.3 Inside a module

Every module follows the same internal layout so that code is predictable:

```
modules/requests/
├─ index.ts                    public interface (service interface, event types, DTO re-exports)
├─ requests.module.ts          NestJS module wiring
├─ http/
│  ├─ customer.controller.ts   /v1/flight-requests…          (owner checks)
│  ├─ admin.controller.ts      /v1/admin/flight-requests…    (permission checks)
├─ application/
│  ├─ commands/                one handler per command (submit, claim, send-quote, …)
│  └─ queries/                 list, detail, timeline
├─ domain/                     uses packages/domain state machine; policies; invariants
├─ infra/
│  ├─ requests.repository.ts   Drizzle queries; the only place that touches module tables
│  └─ mappers.ts
├─ jobs/                       BullMQ processors (SLA timers, expiry)
└─ events/                     event payload schemas and handlers for consumed events
```

20.4 The request pipeline

Every HTTP call passes through the same chain. Each step is a NestJS building block, so behaviour is consistent across all modules.

STEP	NESTJS ELEMENT	WHAT IT DOES
1	Middleware	Assigns `requestId`, starts the trace span, attaches client info (app version, platform, locale)
2	`AuthGuard` (global)	Verifies the access token (signature, expiry, audience). Public routes are explicitly marked `@Public()`
3	`PermVersionGuard` (global)	Compares the token's `perm_version` with the cached current value; mismatch → `401 PERMISSIONS_CHANGED`
4	`PermissionGuard`	Checks `@RequirePermission('flight_request.transition')` metadata against the token's permissions
5	`ZodValidationPipe`	Validates params, query and body against `packages/contracts` schemas
6	Controller → command handler	Loads the aggregate, checks ownership (`@OwnerOnly` resource policies), runs domain logic
7	Transaction	Business rows + status history + audit row + outbox events committed together
8	Interceptors	Serialises output through the response schema (strips internal fields), maps errors to problem responses, records metrics

```
// apps/api/src/modules/requests/http/admin.controller.ts (sketch)
@Controller('v1/admin/flight-requests')
export class AdminFlightRequestsController {
  constructor(private readonly commands: FlightRequestCommands) {}

  @Post(':ref/commands/send-quote')
  @RequirePermission('quote.create')
  @Idempotent()                              // honours Idempotency-Key header
  async sendQuote(
    @Param('ref', ReferencePipe) ref: string,
    @Body(new ZodValidationPipe(SendQuoteBody)) body: SendQuoteBody,
    @Headers('if-match') ifMatch: string,      // optimistic concurrency (row version)
    @Actor() actor: Actor,
  ) {
```

```
    return this.commands.sendQuote({ ref, body, expectedVersion: Number(ifMatch), actor });
  }
}
```

```
// packages/domain/src/flight-request/machine.ts (sketch)
export const transitions = {
  send_quote: {
    from: ['IN_REVIEW'], to: 'QUOTED',
    guard: (r: FlightRequest, q: Quote) ⇒
      q.options.length > 0 &&
      q.options.every(o ⇒ o.baggage.status ≡≡ 'KNOWN' && o.conditions.status ≡≡ 'KNOWN') &&
      q.validUntil > now(),
    permission: 'quote.create',
  },
  // … every row of Table 13.1
} as const satisfies TransitionTable<FlightRequestState>;
```

20.5 Concurrency and consistency

- **Optimistic locking**: aggregates that staff edit (`flight_requests`, `cargo_requests`, `quotes`) carry a `version` column. Commands require `If-Match`; a stale version returns `409 VERSION_CONFLICT` and the console reloads the case, so two admins can never silently overwrite each other.
- **Idempotency**: create-type endpoints accept an `Idempotency-Key`; the first response is stored for 24 hours and replayed for retries with the same key and body hash.
- **Exactly-once side effects (effectively)**: side effects are driven from the outbox with deduplication keys, so a retried job never sends a second SMS or creates a second timer.
- **Read your writes**: the API returns the updated aggregate after every command, so clients do not need to re-fetch.

CHAPTER 21

Supplier integration framework

Every flight provider sits behind the same adapter interface and speaks the same normalised model. The engine, the console and the clients never see a supplier's native format, so providers can be added, swapped or switched off from the Developer Panel.

21.1 Principles

1. **Official, contracted interfaces only.** No scraping, no undocumented endpoints, no bypassing rate limits or bot protection (project rule). An adapter exists only for a provider Uni Travel has a contract or written permission to use.
2. **Normalise at the edge.** Adapters convert native responses into the normalised model immediately; native payloads are kept only as compressed, redacted call records for debugging.
3. **Capabilities, not assumptions.** Each adapter declares what it can do (search, price, seat map, order) per environment. The engine asks for capabilities, never for a provider by name.
4. **Fail soft.** A slow or failing provider degrades results; it never fails the whole search.
5. **Compliance first.** Carrier and route policies are applied to adapter output before anything else sees it (Chapter 27).
6. **Fakes never reach production.** The local fake adapter is refused at start-up if `NODE_ENV=production` or if the provider registry marks the environment as production.

21.2 The adapter interface

```
// apps/api/src/modules/suppliers/adapter.ts
export interface FlightSupplierAdapter {
  readonly id: ProviderId;                       // 'amadeus-enterprise' | 'duffel' | 'manual' | …
  capabilities(env: ProviderEnv): Capabilities;  // { search, price, seatMap, order, cancel, ancillaries }

  search(q: SliceQuery, ctx: CallContext): Promise<SupplierResult<NormalisedOffer[]>>;
  price(offer: OfferRef, ctx: CallContext): Promise<SupplierResult<PricedOffer>>;      // revalidation
  seatMap?(offer: OfferRef, ctx: CallContext): Promise<SupplierResult<SeatMap[]>>;
  // Stage 7 (automated booking) — not used in v1:
  createOrder?(input: CreateOrderInput, ctx: CallContext): Promise<SupplierResult<SupplierOrder>>;
  cancelOrder?(order: OrderRef, ctx: CallContext): Promise<SupplierResult<CancellationQuote>>;

  healthCheck(ctx: CallContext): Promise<HealthResult>;
}

export type SupplierResult<T> =
  | { ok: true; value: T; meta: CallMeta }
  | { ok: false; error: SupplierError; meta: CallMeta };

export interface CallContext {
  requestId: string; deadline: Date;           // absolute deadline, not a per-call timeout
  pointOfSale: { country: string; currency: string };
  budget: BudgetToken;                         // decremented per call; refused when exhausted
}
```

21.3 The normalised model

```
export interface NormalisedOffer {
  source: {
    provider: ProviderId; providerOfferId: string;
    rung: 'CACHED_OFFER' | 'LIVE_OFFER' | 'PRICED_OFFER' | 'MANUAL';
    fetchedAt: string; expiresAt?: string;     // ISO-8601 UTC
  };
  slices: Slice[];                             // one per directional journey
  price: { total: Money; base?: Money; taxes?: Money; perPassenger?: PaxPrice[] };
  validatingCarrier?: string;                  // IATA code
  ticketing: 'SINGLE_TICKET';                  // supplier offers are always one ticket; self-transfer is
built by the engine
  brand: Tri<{ name: string }>;
  baggage: PaxBaggage[];                       // per passenger, per segment; Tri<…> values
  conditions: { change: Tri<Condition>; refund: Tri<Condition> };
  seatsRemaining?: number;
  restrictions: string[];                      // e.g. 'REQUIRES_PASSPORT_AT_BOOKING'
}

export interface Slice { origin: Airport; destination: Airport; segments: Segment[]; durationMin: number }

export interface Segment {
  marketing: { carrier: string; flightNumber: string };
  operating: { carrier: string; flightNumber?: string };
  origin: { iata: string; terminal?: string }; destination: { iata: string; terminal?: string };
  departure: { local: string; utc: string; tz: string };  // '2026-11-14T07:10', '2026-11-14T04:10Z',
'Europe/Istanbul'
  arrival:   { local: string; utc: string; tz: string };
  cabin: Cabin; bookingClass?: string; fareBasis?: string; aircraft?: string;
  technicalStops: { iata: string; durationMin?: number }[];
}
```

IMPLEMENTATION NOTE · TIME ZONES

Many supplier responses give local times without offsets. Adapters must resolve each airport's IANA time zone from the `reference` module and compute UTC before returning a segment. An airport with no known zone is a hard error for that offer (the offer is dropped and logged), because a wrong offset silently breaks connection validation.

21.4 Planned providers

PROVIDER	ROLE	CAPABILITIES PLANNED	ACCESS	STATUS
Amadeus Enterprise	Primary GDS content; Uni Travel already holds an Amadeus agency relationship	Search (Master Pricer via Amadeus Web Services, or Enterprise REST if offered), informative pricing, fare rules, seat maps (to confirm), booking later	Commercial agreement via the Amadeus UK account manager; credentials bound to the agency's office ID	`UNKNOWN` until the account manager confirms the product and price (Chapter 6)
Duffel	Secondary: NDC and low-cost content, seat maps, self-serve onboarding	Offer requests, single-offer revalidation, seat maps, orders (Stage 7)	Self-serve test tokens; production subject to Duffel's onboarding and compliance review	`DOCUMENTED` API; terms on Iran-linked customers `UNKNOWN`
Manual inventory	Staff-entered options (from the Amadeus terminal, airline sites, partners)	Quote options only; rung `MANUAL`	Internal	Built in v1

PROVIDER	ROLE	CAPABILITIES PLANNED	ACCESS	STATUS
Schedules / MCT data (OAG or Cirium)	Route intelligence: which flights exist, minimum connection times	Rung 1 only — never sold	Contract	Stage 7 option

21.5 Call lifecycle

CONCERN	MECHANISM
Authentication	OAuth or session tokens cached in Redis per provider and environment until shortly before expiry; refreshed with a lock so only one process refreshes
Deadlines	The search job has one absolute deadline (default 12 s for the first wave of results, 25 s overall); each call gets `min(remaining, provider timeout)`
Retries	Reads (search, price, seat map) retry once on network errors or 5xx with jitter if time remains. Writes (orders) never retry without a supplier idempotency key
Rate limits	Token bucket per provider in Redis (requests per second) plus a concurrency semaphore
Circuit breaker	Opens after 5 failures or 50% errors in 60 s; half-open probe every 30 s; state visible in the Developer Panel
Budget	Daily call budget and search-to-book ratio per provider; the engine reduces hub fan-out when the budget is low and stops calling when exhausted
Call records	Every call: provider, operation, duration, status, normalised error, size; native request and response stored compressed for 14 days with personal data removed
Metrics	Calls, latency (p50/p95), error rate per provider and operation; offers returned; offers removed by policy

21.6 Error taxonomy

CODE	MEANING	RETRY?	USER-FACING EFFECT
`SUPPLIER_TIMEOUT`	No answer before the deadline	Once if time remains	Results from other providers still shown; progress line notes a source was slow
`SUPPLIER_UNAVAILABLE`	5xx, connection refused, circuit open	Once	As above
`SUPPLIER_AUTH`	Credentials invalid or expired	No	Developers alerted immediately
`SUPPLIER_RATE_LIMITED`	429 or provider quota	No (back off)	Fewer hubs searched
`SUPPLIER_BAD_REQUEST`	Our request was invalid	No	Bug alert; offer path skipped
`NO_AVAILABILITY`	Valid request, nothing found	No	Normal empty result
`OFFER_EXPIRED`	Offer no longer valid on price check	No	"This price has expired — refresh"
`PRICE_CHANGED`	Price check returned a different total	No	Show old and new price; ask the customer to confirm
`CONTENT_RESTRICTED`	Provider refuses this market or route	No	Route silently skipped for that provider; logged
`SUPPLIER_UNKNOWN`	Anything unmapped	No	Logged with raw code for mapping

21.7 Deduplication across providers

The same flights can arrive from several providers. Offers are grouped by a **flight key** — the ordered list of `(marketing carrier, flight number, departure UTC date, origin, destination)` per segment, plus cabin. Within a group the platform keeps the lowest total price; ties go to the provider with the higher priority setting. Other offers in the group are kept as alternatives, visible to staff.

21.8 Testing adapters

- **Recorded fixtures**: real sandbox responses captured once, scrubbed of personal data, stored with the adapter; contract tests assert that each fixture normalises to the expected model.
- **Schema drift alarms**: a nightly sandbox smoke test per provider compares live responses against the recorded schema and opens an alert when fields disappear or change type.
- **Fake adapter** for local development and end-to-end tests: deterministic, clearly labelled `FAKE` in every offer, blocked in production by a start-up guard.

21.9 Checklist for adding a provider

1. Contract or written permission covering search, display of prices on Uni Travel's own site and app, and any booking; sanctions terms reviewed by counsel.
2. Sandbox credentials stored through the Developer Panel; capability flags set to match the contract.
3. Adapter implemented against the interface, with fixtures, contract tests and error mapping.
4. Time-zone resolution, carrier policy filtering and deduplication verified with the provider's data.
5. Budget, rate limits and timeouts configured; circuit breaker tested.
6. Shadow mode in staging (results logged, not shown) for one week; then enabled in production for staff search first, customers second.

CHAPTER 22

Itinerary and connection engine

The engine turns "Tehran to London on the 14th" into a ranked set of real, achievable journeys. It combines supplier-priced itineraries with self-transfer combinations it builds itself, validates every connection against configurable rules, and explains every ranking decision.

22.1 Three ways to get from A to B

CONSTRUCTION	WHAT IT IS	WHO VALIDATES THE CONNECTION	TICKETING	WHEN IT MATTERS MOST
Through itinerary	The supplier returns a complete journey, possibly with connections	The supplier (airline minimum connection times)	Single ticket	Whenever a carrier or alliance serves the whole route
Self-transfer	The engine joins two independently priced offers at a hub	The engine, using Uni Travel's rules	Separate tickets	When no single ticket exists, or it is much more expensive
Gateway start	The journey starts at an airport outside the customer's origin country that they reach overland	The engine for flights; the customer for the overland leg (information only)	Single or separate tickets from the gateway	When flights from the origin country are scarce or not lawful to sell

WHY THE THIRD CONSTRUCTION EXISTS

As of 22 October 2026, flights out of Iran are scarce: Iranian carriers are excluded by policy (Decision D-01), Turkish carriers have no Iran flights scheduled before March 2027, and only a handful of foreign carriers have resumed — for example Iraqi Airways via Najaf and SalamAir via Muscat REPORTED. Travellers are crossing overland to Türkiye and Armenia for onward flights REPORTED. The engine must therefore treat gateways as a first-class option, and everything about hubs and gateways must be **data, not code**, because the situation changes week to week.

22.2 Inputs

- **The query**: slices, dates and flexibility, passengers, cabin, and the customer's connection preferences (Chapter 11).
- **The published rule set** (versioned, Chapter 16): connection rules, hub and gateway tables, scoring weights, limits.
- **Carrier and route policy** from the compliance module (Chapter 27).
- **Reference data**: airports with IANA time zones, metro areas (London = LHR, LGW, STN, LTN, LCY, SEN), countries, airline codes.
- **Provider capabilities and budgets** from the suppliers module.

22.3 Connection rules

Rules are resolved by precedence: **carrier pair at airport → airport → route (origin–destination pair) → global**. The most specific rule that defines a field wins; undefined fields fall through to the next level.

FIELD	MEANING	GLOBAL DEFAULT
`selfTransferMinMin`	Minimum layover for separate tickets, including bag collection, immigration, re-check-in and security	180 min
`protectedMinBufferMin`	Extra margin added on top of the supplier's own minimum for single-ticket connections when ranking (not filtering)	0 min
`preferredLayover`	Window that scores best	240–360 min (the brief's 4–6 h)
`maxLayoverMin`	Longest acceptable layover	720 min
`allowOvernight` / `maxOvernightMin`	Whether a layover crossing local night (00:00–06:00) is allowed, and its maximum	true / 1,200 min
`airportChanges`	Allowed pairs and transfer time, e.g. `IST↔SAW: 150 min`, `LHR↔LGW: 180 min`	none allowed
`maxSeparateTickets`	Maximum number of tickets in one journey	2
`maxStops`	Total connections per slice	2
`maxTotalDurationMin` / `maxDurationFactor`	Absolute cap, and cap relative to the fastest result found	2,160 min / 2.5 ×
`selfTransferRequiresEntry`	Whether a self-transfer at this airport requires entering the country (landside transfer)	true
`entryAdvisory`	Customer-facing note for the hub, per language	—
`blocked`	Airport or hub not to be used	false

Table 22.1 — Connection rule fields and defaults. Defaults are proposals for the Developer Panel; Uni Travel's operations team should tune them per airport.

Hubs and gateways

```
{
  "hubs": [
    {
      "fromRegion": "IR", "toRegion": "EUROPE",
      "candidates": [
        { "iata": "MCT", "weight": 0.9 },
        { "iata": "NJF", "weight": 0.5 },
        { "iata": "IST", "weight": 1.0, "active": false,
          "note": "No Iran flights by Turkish carriers before Mar 2027" }
      ]
    },
    {
      "fromRegion": "TR", "toRegion": "UK",
      "candidates": [ { "iata": "IST", "weight": 1.0 }, { "iata": "SAW", "weight": 0.8 } ]
    }
  ],
  "restrictedOrigins": [
    {
      "country": "IR",
      "gateways": [
        { "iata": "EVN", "dayOffset": 1,
          "access": { "en": "Overland via the Nurduz–Agarak border crossing", "fa": "…" } },
        { "iata": "VAN", "dayOffset": 1,
          "access": { "en": "Overland via the Razi–Kapıköy border crossing", "fa": "…" } },
        { "iata": "ERZ", "dayOffset": 1,
          "access": { "en": "Overland via the Bazargan–Gürbulak border crossing", "fa": "…" } }
      ]
    }
```

```
  ]
}
```

Illustrative configuration. Hub weights, `active` flags, day offsets and access notes are maintained by the operations team; the engine never hard-codes airports.

`dayOffset` shifts the gateway departure date relative to the customer's chosen date to allow for the overland journey; the result card shows the offset ("Depart Van one day after leaving Tabriz").

22.4 The pipeline

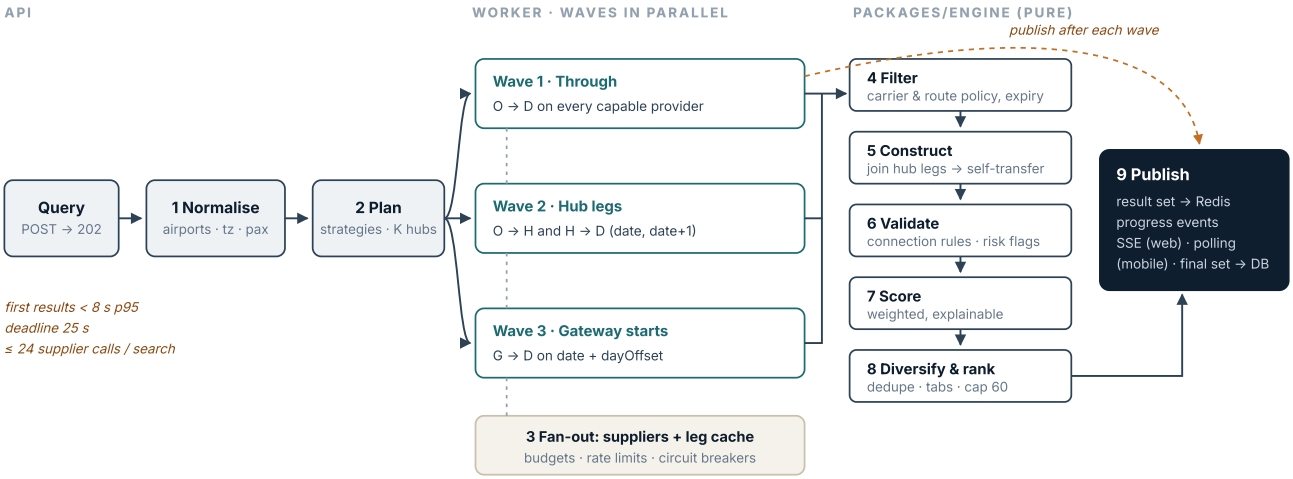


Figure 22.1 — Search pipeline. Waves run in parallel within the deadline; results are published to the client as soon as each wave produces valid itineraries.

1. **Normalise the query.** Expand cities to airports, resolve time zones, validate the passenger mix, apply flexibility (± N days → N date pairs, capped).
2. **Plan.** Choose the strategies: through search always; self-transfer if the customer allowed it and the route has hub candidates; gateway starts if the origin country is in `restrictedOrigins` and the customer did not opt out. Select the top `K` active hubs by weight (default 4) and assign the call budget.
3. **Fan out.** Wave 1: through searches O→D on every capable provider. Wave 2: hub legs O→H and H→D (H→D on the travel date and the day after). Wave 3: gateway searches G→D on the offset dates. Leg results come from the cache when fresh.
4. **Filter.** Remove offers that use blocked carriers (marketing or operating), blocked airports, expired offers, or offers with unresolvable time zones. Count what was removed and why.
5. **Construct.** Join hub legs into self-transfer candidates (pseudo-code below). Through and gateway offers pass straight on.
6. **Validate.** Apply the connection rules to every connection; compute risk flags; drop invalid candidates.
7. **Score.** Compute the weighted cost per itinerary and keep the component scores for explanation.
8. **Diversify and rank.** Remove near-duplicates; fill the Best, Cheapest, Fastest and Single-ticket tabs.
9. **Publish.** Write the current result set to Redis; emit a progress event; repeat as waves complete; persist the final set for staff and analytics.

Joining hub legs

```
// packages/engine/src/join.ts (sketch) — pure function, no I/O
export function joinAtHub(legA: NormalisedOffer[], legB: NormalisedOffer[], rules: RuleResolver):
Candidate[] {
  const out: Candidate[] = [];
```

```
  const byAirport = groupBy(legB, o ⇒ firstSegment(o).origin.iata);
  for (const a of legA) {
    const arr = lastSegment(a);
    for (const depAirport of [arr.destination.iata, ...rules.airportChangePartners(arr.destination.iata)]) {
      for (const b of byAirport.get(depAirport) ?? []) {
        const r = rules.forConnection({ at: arr.destination.iata, to: depAirport,
                                        inbound: arr.marketing.carrier, outbound:
firstSegment(b).marketing.carrier });
        const layover = minutesBetween(arr.arrival.utc, firstSegment(b).departure.utc);
        const required = r.selfTransferMinMin + (depAirport ≠= arr.destination.iata ?
r.airportChangeMin(depAirport) : 0);
        if (layover < required || layover > r.maxLayoverMin) continue;
        const overnight = crossesLocalNight(arr.arrival, firstSegment(b).departure, r.nightWindow);
        if (overnight && (!r.allowOvernight || layover > r.maxOvernightMin)) continue;
        out.push(candidate([a, b], { layover, required, overnight, airportChange: depAirport ≠=
arr.destination.iata, rule: r.id }));
      }
    }
  }
  return out;
}
```

Joins are cheap: with 4 hubs and up to 25 offers per leg, there are at most 2,500 pairs per date — trivial in memory. Expensive work is the supplier calls, so the planner, not the join, controls cost.

22.5 Validating connections

For each connection the engine records:

CHECK	OUTCOME
Layover ≥ required minimum (supplier's for single tickets; `selfTransferMinMin` + airport change for separate tickets)	Hard filter
Layover ≤ `maxLayoverMin`; overnight allowed and within limit	Hard filter
Total duration within absolute and relative caps	Hard filter
Number of separate tickets and stops within limits	Hard filter
Layover inside preferred window	Score
Separate tickets	Risk flag `SEPARATE_TICKETS`; warning on the card; acknowledgement on request
Airport change / terminal change / terminal unknown	Risk flags
Self-transfer requires entry to the hub country	Flag `ENTRY_REQUIRED` with the hub's advisory text; customers are told rules depend on their passport and staff confirm
Tight connection (below preferred minimum but above required)	Risk flag `TIGHT`
Red-eye departure or arrival after midnight	Score

The engine does **not** decide visa eligibility. It flags where entry is needed; staff confirm requirements for the traveller's nationality before quoting (a Timatic licence is a Stage 7 option, Chapter 6).

22.6 Scoring

Each itinerary gets a cost between 0 (best) and 1 (worst) from normalised components:

$$\text{cost} = 0.35 \cdot \text{price} + 0.20 \cdot \text{duration} + 0.15 \cdot \text{layoverFit} + 0.20 \cdot \text{risk} + 0.05 \cdot \text{stops} + 0.05 \cdot \text{timeOfDay}$$

COMPONENT	DEFINITION (0 = BEST)
`price`	(total − min total) ÷ (max total − min total) within the current result set
`duration`	(journey time − min) ÷ (max − min)
`layoverFit`	0 if every layover is inside the preferred window; otherwise the largest distance from the window ÷ 180 min, capped at 1
`risk`	Sum of risk points ÷ 10, capped at 1: separate tickets 3, airport change 3, overnight 2, tight 2, terminal change 1, terminal unknown 1, entry required 1
`stops`	Connections ÷ `maxStops`
`timeOfDay`	0.5 for a departure between 00:00 and 05:00 local, 0.5 for an arrival after 00:00 local

Weights are configurable per route. Preferred carriers (configured by operations) subtract up to 0.05. Ties are broken by price, then duration. Component values are stored with each result, so the console can explain a ranking ("ranked first: cheapest, layover in preferred window, but separate tickets").

22.7 Diversity

Ranking by cost alone tends to return twenty variants of the same idea. The engine therefore:

- keeps only the best of itineraries with identical flights from different providers (deduplication, Chapter 21);
- allows at most three itineraries sharing the same first flight, and three sharing the same last flight;
- guarantees at least one result per construction type (through, self-transfer, gateway) in the Best tab when one exists;
- caps the result set at 60 itineraries.

22.8 Progressive results and timing

STAGE	TARGET
Search accepted (`202` with search id)	< 300 ms
First results (through searches, cached legs)	< 4 s p50, < 8 s p95
Search complete or deadline	≤ 25 s
Result freshness shown to users	Fetch time of each component offer

Clients receive `progress`, `results` and `done` events by server-sent events on the web and by polling (every 1.5 s, backing off) on mobile. A search is a resource with a lifetime of 30 minutes; after that, viewing it shows the results as historical and offers "Search again".

22.9 Caching and cost control

- **Leg cache**: key = provider + origin + destination + date + passenger mix + cabin; default TTL 10 minutes (configurable per provider). A cached leg is shown with its own fetch time, never relabelled as live.
- **Budgets**: maximum supplier calls per search (default 24) and per provider per day. When a provider approaches its search-to-book threshold, the planner lowers `K` and the flexibility window for that provider.
- **Revalidation before submission**: if `requests.revalidate_on_submit` is on, the server prices each component offer before creating the request. A price change is shown to the customer for confirmation; an expired offer

asks for a new search.

22.10 What gets frozen in the snapshot

The offer snapshot stores the itinerary, each component offer with provider, offer id, rung and fetch time, the price at submission and after revalidation, the rule-set version and engine version that produced it, the component scores and the risk flags. A snapshot therefore always explains itself, even after rules change.

22.11 Worked example — Tehran to London

ILLUSTRATIVE The flights below show how the engine reasons, not real schedules.

1. **Normalise.** "Tehran" expands to IKA and THR; "London" to the London metro airports. The origin country, Iran, is in `restrictedOrigins`.
2. **Plan.** Wave 1: IKA/THR → London on two providers. Wave 2: hubs from the IR→EUROPE table that are active — Muscat (MCT) and Najaf (NJF); Istanbul is inactive. Wave 3: gateways Yerevan (EVN), Van (VAN) and Erzurum (ERZ) with a one-day offset.
3. **Filter.** Wave 1 returns no compliant through itineraries; the offers it did return use excluded carriers. The progress line reads "Some results were hidden by our carrier policy".
4. **Construct.** IKA→MCT on a foreign carrier joins MCT→LHR with a 6 h 10 m layover: valid, but just outside the preferred window. VAN has domestic flights only, so the gateway search returns through itineraries VAN→IST→LHR on one ticket and self-transfer pairs VAN→IST + IST→LHR.
5. **Validate.** VAN→IST arriving 09:00 and IST→LHR departing 13:50 gives a 4 h 50 m self-transfer layover: above the 3 h minimum, inside the 4–6 h window, flagged `SEPARATE_TICKETS` and `ENTRY_REQUIRED`.
6. **Score and present.** Best: VAN→IST→LHR on one ticket if priced within 15% of the self-transfer; Cheapest: the self-transfer pair; Fastest: EVN→LTN direct on its operating days.

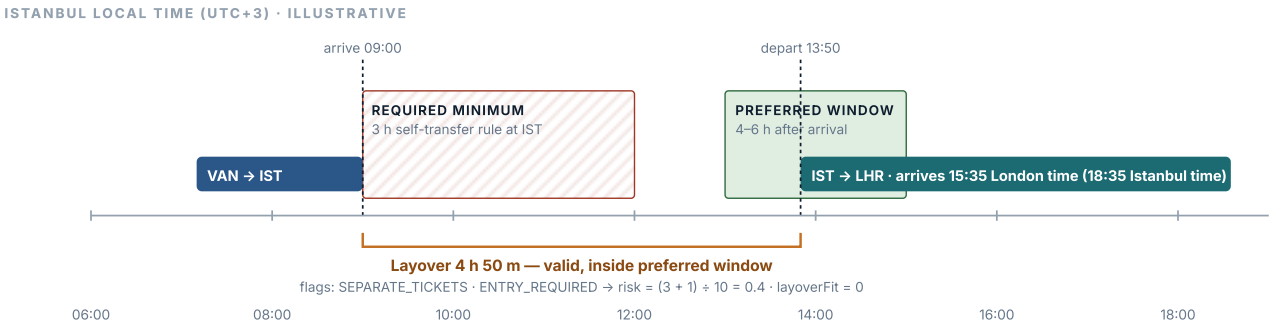


Figure 22.2 — The self-transfer in step 5 on a timeline: required minimum, preferred window and actual layover at Istanbul.

22.12 Known limits in version 1

- Self-transfer construction is limited to one hub (two tickets) and to one-way and return trips; multi-city uses supplier itineraries only.
- Without a schedules contract, hub selection relies on configuration, not on which flights actually operate; the operations team keeps `active` flags current.
- Gateway access notes are information, not bookings; ground tickets are out of scope (Decision D-04).
- Entry and visa guidance is advisory and confirmed by staff.

CHAPTER 23

Data model

PostgreSQL is the single system of record. This chapter lists every table by domain, with the columns that matter for behaviour, the immutability rules, and the indexing and retention choices.

23.1 Domain map

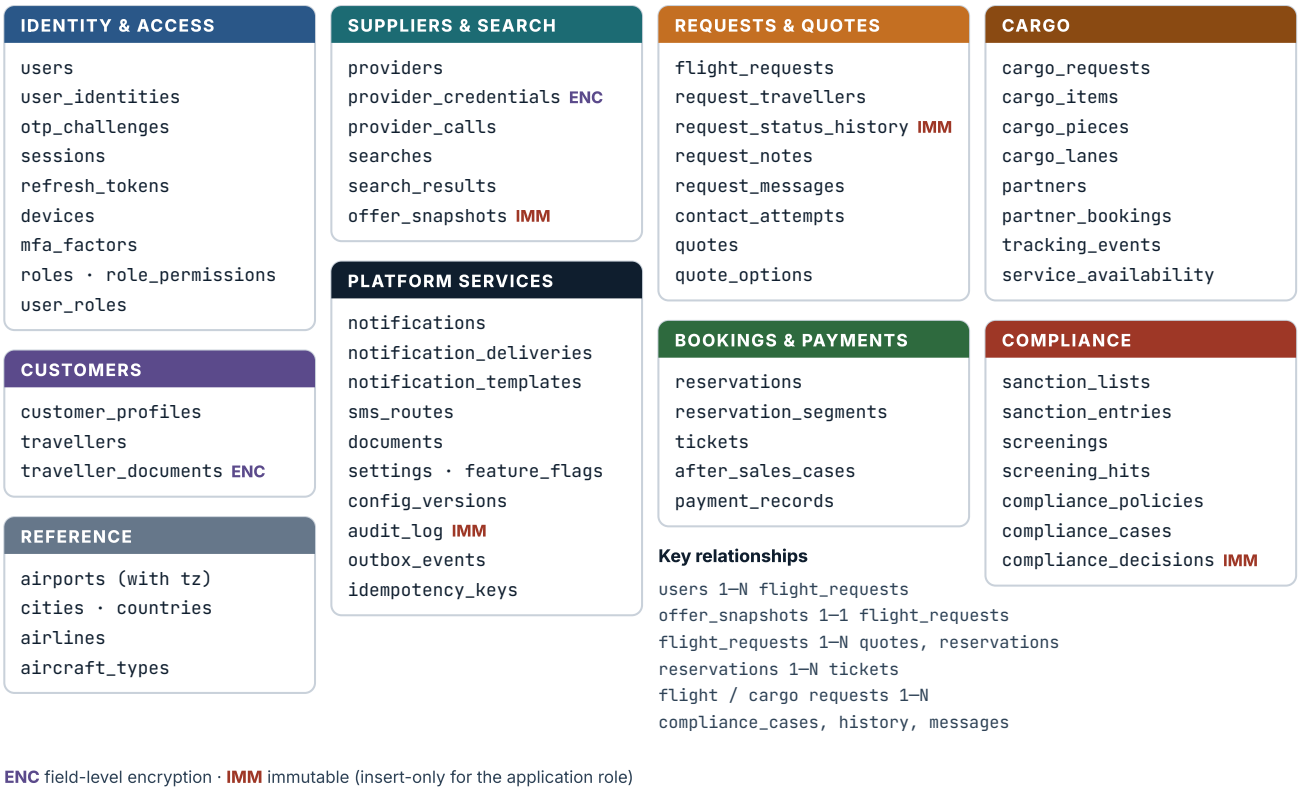


Figure 23.1 — Domain map of the main tables and their key relationships. Each colour band is owned by one backend module (Chapter 20).

23.2 Conventions

- Primary keys: `uuid` v7 generated in the application. Exceptions: reference tables keyed by natural codes (`airports.iata`), and `audit_log` (`bigint` identity for append speed).
- Every mutable table has `created_at`, `updated_at` (`timestamptz`, UTC). Soft deletion (`deleted_at`) only where Chapter 28 requires retention.
- Money: `*_minor bigint` + `currency char(3)`.
- Enumerations: PostgreSQL enums for stable sets (statuses); `text` with a check constraint for sets expected to grow.
- Flexible supplier-shaped data (`itinerary`, `query`, `score_components`): `jsonb`, validated by Zod before insert, never queried for business decisions except through indexed generated columns.
- **Immutable tables** (application role has `INSERT` and `SELECT` only): `offer_snapshots`, `request_status_history`, `compliance_decisions`, `audit_log`, `config_versions` rows once published.

23.3 Identity and access

TABLE	KEY COLUMNS	NOTES
`users`	`id`, `status` (ACTIVE, SUSPENDED, DELETED), `display_name`, `preferred_locale` (en, fa), `calendar` (GREGORIAN, JALALI), `timezone`, `perm_version int`	`perm_version` increments on any role change (Chapter 25)
`user_identities`	`id`, `user_id`, `type` (PHONE, EMAIL), `value_normalised`, `verified_at`, `is_primary`, `revoked_at`	Unique on `(type, value_normalised)` where not revoked; phone in E.164
`otp_challenges`	`id`, `identity_value`, `purpose` (SIGN_IN, VERIFY_PHONE, VERIFY_EMAIL, STEP_UP), `code_hash`, `expires_at`, `attempts`, `max_attempts`, `route`, `delivery_status`, `ip`, `device_id`, `consumed_at`	Code stored as HMAC-SHA-256 with a server pepper; 90-day retention
`sessions`	`id`, `user_id`, `device_id`, `client` (WEB, CONSOLE, MOBILE), `ip`, `user_agent`, `mfa_level`, `last_seen_at`, `revoked_at`, `revoked_reason`	Shown and revocable in the Developer Panel
`refresh_tokens`	`id`, `session_id`, `token_hash`, `family_id`, `expires_at`, `rotated_at`, `revoked_at`	Rotation with reuse detection (reuse revokes the family)
`devices`	`id`, `user_id`, `platform` (IOS, ANDROID, WEB), `push_provider` (EXPO, PUSHY), `push_token`, `last_success_at`, `app_version`, `disabled_at`	Token removed when the push service reports it invalid
`mfa_factors`	`id`, `user_id`, `type` (TOTP, WEBAUTHN), `secret_ciphertext` or `credential_id` + `public_key`, `last_used_at`	Staff only
`roles` / `role_permissions` / `user_roles`	`roles(key, name, built_in, privileged)`; `role_permissions(role_id, permission)`; `user_roles(user_id, role_id, granted_by, granted_at)`	Permissions are strings from `packages/contracts`

23.4 Customers

TABLE	KEY COLUMNS	NOTES
`customer_profiles`	`user_id`, `given_names_latin`, `surname_latin`, `name_fa`, `contact_time_pref`, `terms_version`, `privacy_version`, `marketing_consent_at`	Legal-version fields drive re-consent
`travellers`	`id`, `owner_user_id`, `title`, `given_names`, `surname`, `name_fa`, `date_of_birth`, `gender_on_document`, `nationality`, `relationship` (SELF, FAMILY, OTHER), `deleted_at`	Names exactly as in passport
`traveller_documents`	`id`, `traveller_id`, `type` (PASSPORT, NATIONAL_ID), `number_ciphertext`, `number_last4`, `issuing_country`, `expiry_date`, `key_id`	Field-level encryption (Chapter 28); `last4` for display and matching

23.5 Reference data

TABLE	KEY COLUMNS	NOTES
`airports`	`iata` PK, `icao`, `name_en`, `name_fa`, `city_code`, `country`, `tz` (IANA), `lat`, `lon`, `metro_code`, `active`	`tz` is mandatory; the engine refuses airports without it
`cities` / `countries`	codes, names in both languages, `region_tags` (e.g. `IR`, `EUROPE`, `TR`, `UK`)	Region tags drive hub tables
`airlines`	`iata`, `icao`, `accounting_code` (3-digit ticket prefix), `name`, `country`, `active`	Ticket-number validation

TABLE	KEY COLUMNS	NOTES
`aircraft_types`	`code`, `name`	Display only

LICENSING NOTE

IATA airline and airport code lists are IATA products, and some reference datasets carry commercial licence terms. Choose reference data sources with licences that allow commercial use (for example, the supplier's own reference APIs under the supplier contract, or open datasets with permissive licences), and record the source and licence in `docs/`.

23.6 Suppliers and search

TABLE	KEY COLUMNS	NOTES
`providers`	`id` (slug), `name`, `environment`, `enabled`, `priority`, `capabilities jsonb`, `limits jsonb`, `markets jsonb`, `version`	Edited in the Developer Panel
`provider_credentials`	`provider_id`, `environment`, `ciphertext`, `key_id`, `rotated_at`, `rotated_by`	Never selected by any query that serves an HTTP response
`provider_calls`	`id`, `provider_id`, `operation`, `search_id`, `request_id`, `status`, `error_code`, `duration_ms`, `payload_key`, `created_at`	Partitioned by month; payloads in object storage, 14-day retention
`searches`	`id`, `user_id`, `actor_kind` (CUSTOMER, STAFF, ANONYMOUS), `query jsonb`, `status` (RUNNING, COMPLETE, PARTIAL, FAILED), `rule_version`, `engine_version`, `stats jsonb`, `expires_at`	`stats` records calls, cache hits, offers removed by policy
`search_results`	`id`, `search_id`, `rank`, `tabs text[]`, `construction` (THROUGH, SELF_TRANSFER, GATEWAY), `itinerary jsonb`, `price_total_minor`, `currency`, `duration_min`, `risk_flags text[]`, `score numeric`, `score_components jsonb`	30-day retention
`offer_snapshots`	`id`, `search_result_id`, `itinerary jsonb`, `components jsonb` (provider, offer id, rung, fetched_at), `price_at_submit_minor`, `price_revalidated_minor`, `revalidated_at`, `rule_version`, `engine_version`, `content_hash`	**Immutable**; kept as long as the request

23.7 Requests, quotes and bookings

TABLE	KEY COLUMNS	NOTES
`flight_requests`	`id`, `ref` unique, `kind` (ITINERARY, MANUAL), `customer_user_id`, `contact_identity_id`, `contact_phone_snapshot`, `contact_phone_verified`, `status`, `payment_status`, `assignee_user_id`, `offer_snapshot_id`, `trip_type`, `query jsonb`, `customer_note`, `first_travel_date`, `urgent`, `sla_due_at`, `version`, `submitted_at`, `closed_at`	`version` for optimistic locking; index on `(status, sla_due_at)`
`request_travellers`	`request_id`, `traveller_id`, `passenger_type`, `name_snapshot jsonb`	Names frozen at submission
`request_status_history`	`id`, `request_type` (FLIGHT, CARGO, AFTER_SALES), `request_id`, `from_status`, `to_status`, `command`, `actor_user_id`, `actor_kind`, `reason_code`, `reason_text`, `created_at`	**Immutable**

TABLE	KEY COLUMNS	NOTES
request_notes	id, request_type, request_id, author_id, body, created_at	Internal only; never serialised to customer endpoints
request_messages	id, request_type, request_id, author_id, direction (TO_CUSTOMER, FROM_CUSTOMER), body, document_ids, read_at	Customer-visible thread
contact_attempts	id, request_type, request_id, staff_id, channel (PHONE, SMS_TEMPLATE), outcome, call_back_at, note	SLA reporting
quotes	id, request_type, request_id, version, status (DRAFT, SENT, ACCEPTED, DECLINED, EXPIRED, SUPERSEDED), currency, valid_until, sent_at, accepted_option_id, accepted_at, accepted_via (APP, STAFF_RECORDED), created_by	One SENT quote per request at a time
quote_options	id, quote_id, label, source (SNAPSHOT, STAFF_SEARCH, MANUAL), attested_by, itinerary jsonb, price_breakdown jsonb, total_minor, baggage jsonb, conditions jsonb, ticketing_model, internal_cost_minor	Check: baggage and conditions KNOWN before SENT
reservations	id, request_id, system (AMADEUS_TERMINAL, DUFFEL_API, PARTNER, AIRLINE_DIRECT), record_locator, airline_locators jsonb, status (HELD, CONFIRMED, CANCELLED, LAPSED), ticketing_deadline, quote_option_id, mismatch_reason, recorded_by	Mirror of the external booking
tickets	id, request_id, reservation_id, traveller_id, ticket_number char(13), validating_carrier, issue_date, status (ISSUED, VOIDED, EXCHANGED, REFUNDED), coupons jsonb, document_id, recorded_by	Unique on ticket_number
after_sales_cases	id, ref, original_request_id, type (CHANGE, REFUND, CANCEL), status, assignee_user_id, version	Linked to tickets it changes
payment_records	id, request_type, request_id, amount_minor, currency, method (BANK_TRANSFER, CASH, CARD_TERMINAL, OTHER), received_at, external_reference, payer_name, payer_screening_id, evidence_document_id, status (RECORDED, VERIFIED, REJECTED, REFUNDED), recorded_by, verified_by	verified_by ≠ recorded_by above threshold

23.8 Cargo

TABLE	KEY COLUMNS	NOTES
cargo_requests	id, ref, customer_user_id, service, lane_id, status, payment_status, assignee_user_id, shipper jsonb, consignee jsonb, purpose, declared_value_minor, currency, insurance_requested, ready_date, handover_mode, dg_declared, version	
cargo_items	id, cargo_request_id, description, category, quantity, unit_value_minor, currency, hs_code, origin_country, screening_outcome	One row per declared line
cargo_pieces	id, cargo_request_id, length_cm, width_cm, height_cm, weight_kg numeric(8,2), verified_weight_kg	Volumetric weight computed, not stored
cargo_lanes	id, origin_country, destination_country, services text[], enabled, requires_compliance_approval, volumetric_divisor, customer_notice jsonb, version	Iran lanes created disabled
partners	id, name, type, lanes, services, integration_level, compliance_status, contacts jsonb, active	

TABLE	KEY COLUMNS	NOTES
`partner_bookings`	`id`, `cargo_request_id`, `partner_id`, `partner_reference`, `awb_number char(11)`, `booked_at`, `recorded_by`	AWB check digit validated
`tracking_events`	`id`, `cargo_request_id`, `event_code`, `location`, `occurred_at`, `description`, `source` (STAFF, PARTNER_API), `created_by`	
`service_availability`	`id`, `provider_name`, `lane`, `service`, `status` (AVAILABLE, SUSPENDED, UNKNOWN), `source_url`, `last_checked_at`, `checked_by`, `note`	Register of which carriers and couriers currently serve a lane (Chapter 9)

23.9 Compliance

TABLE	KEY COLUMNS	NOTES
`sanction_lists`	`id` (UK, OFAC_SDN, OFAC_NON_SDN, EU), `source_url`, `version_hash`, `fetched_at`, `entry_count`, `status`	Ingestion log
`sanction_entries`	`id`, `list_id`, `external_id` (e.g. UK Unique ID), `type` (PERSON, ENTITY, VESSEL, AIRCRAFT), `names jsonb` (primary, aliases, non-Latin script), `dob`, `nationalities`, `identifiers jsonb`, `programmes`, `search_tokens`	Trigram and token indexes for fuzzy matching
`screenings`	`id`, `subject_type` (CUSTOMER, TRAVELLER, PAYER, SHIPPER, CONSIGNEE, PARTNER, CARRIER, GOODS), `subject_ref`, `context_ref`, `lists_version jsonb`, `result` (CLEAR, POSSIBLE_MATCH, MATCH), `created_at`	Every screening is kept as evidence
`screening_hits`	`screening_id`, `entry_id`, `score`, `matched_name`, `reasons jsonb`	
`compliance_policies`	`id`, `type` (CARRIER, AIRPORT, COUNTRY_ROUTE, GOODS_CATEGORY, KEYWORD, LANE), `key`, `action` (BLOCK, REVIEW, ALLOW), `reason`, `version`, `approved_by`, `effective_from`	Versioned; changes require compliance permission
`compliance_cases`	`id`, `request_type`, `request_id`, `trigger` (SCREENING, POLICY, LANE), `status` (OPEN, RELEASED, DECLINED, ESCALATED), `assigned_to`, `opened_at`, `decided_at`	
`compliance_decisions`	`id`, `case_id`, `decision`, `reason`, `decided_by`, `second_approver`, `created_at`	**Immutable**

23.10 Notifications, documents, configuration and platform

TABLE	KEY COLUMNS	NOTES
`notifications`	`id`, `user_id`, `event_type`, `title`, `body`, `data jsonb`, `critical`, `read_at`, `dedupe_key`, `created_at`	Inbox; index on `(user_id, read_at, created_at)`
`notification_deliveries`	`id`, `notification_id`, `channel`, `provider`, `status`, `provider_message_id`, `error`, `attempts`, `sent_at`, `delivered_at`	Unique on `(notification_id, channel)`
`notification_templates`	`id`, `event_type`, `channel`, `locale`, `body`, `variables`, `provider_template_id`, `version`, `active`	
`sms_routes`	`id`, `prefix`, `providers jsonb` (ordered), `enabled`	`+98` → Iranian providers; default → international

TABLE	KEY COLUMNS	NOTES
`documents`	`id`, `owner_user_id`, `request_type`, `request_id`, `type`, `filename`, `mime`, `size`, `storage_key`, `sha256`, `scan_status` (PENDING, CLEAN, INFECTED), `visibility` (INTERNAL, CUSTOMER), `created_by`	Downloads only through short-lived signed URLs
`settings` / `feature_flags`	key–value with `updated_by`; flags with `owner`, `remove_by`	
`config_versions`	`id`, `domain` (ENGINE_RULES, HUBS, WORKFLOW, NOTIFICATION_MATRIX, AUTH), `version`, `status` (DRAFT, PUBLISHED, SUPERSEDED), `payload jsonb`, `change_note`, `created_by`, `published_by`, `published_at`	Published rows immutable
`audit_log`	`id bigint`, `occurred_at`, `actor_user_id`, `actor_kind`, `action`, `entity_type`, `entity_id`, `context_ref`, `before jsonb`, `after jsonb`, `ip`, `user_agent`, `request_id`, `prev_hash`, `hash`	**Append-only**, monthly partitions, optional hash chain for tamper evidence
`outbox_events`	`id`, `aggregate_type`, `aggregate_id`, `event_type`, `payload jsonb`, `dedupe_key`, `created_at`, `dispatched_at`, `attempts`	Polled by the worker (Chapter 26)
`idempotency_keys`	`key`, `user_id`, `route`, `body_hash`, `status_code`, `response jsonb`, `expires_at`	24-hour lifetime

23.11 Example: Drizzle definition

```
// packages/db/src/schema/flight-requests.ts (excerpt)
export const flightRequestStatus = pgEnum('flight_request_status', [
  'SUBMITTED','COMPLIANCE_HOLD','NEW','IN_REVIEW','AWAITING_CUSTOMER','QUOTED',
  'ACCEPTED','RESERVED','TICKETED','COMPLETED','DECLINED','CANCELLED','EXPIRED',
]);
export const paymentStatus = pgEnum('payment_status',
['NONE','PARTIAL','PAID','REFUND_PENDING','REFUNDED']);

export const flightRequests = pgTable('flight_requests', {
  id: uuid('id').primaryKey(),
  ref: varchar('ref', { length: 12 }).notNull().unique(),
  kind: text('kind', { enum: ['ITINERARY', 'MANUAL'] }).notNull(),
  customerUserId: uuid('customer_user_id').notNull().references(() => users.id),
  contactIdentityId: uuid('contact_identity_id').notNull().references(() => userIdentities.id),
  contactPhoneSnapshot: varchar('contact_phone_snapshot', { length: 16 }).notNull(),
  contactPhoneVerified: boolean('contact_phone_verified').notNull(),
  status: flightRequestStatus('status').notNull().default('SUBMITTED'),
  paymentStatus: paymentStatus('payment_status').notNull().default('NONE'),
  assigneeUserId: uuid('assignee_user_id').references(() => users.id),
  offerSnapshotId: uuid('offer_snapshot_id').references(() => offerSnapshots.id),
  tripType: text('trip_type', { enum: ['ONE_WAY','RETURN','OPEN_JAW','MULTI_CITY'] }).notNull(),
  query: jsonb('query').$type<FlightRequestQuery>().notNull(),
  firstTravelDate: date('first_travel_date').notNull(),
  urgent: boolean('urgent').notNull().default(false),
  slaDueAt: timestamp('sla_due_at', { withTimezone: true }),
  version: integer('version').notNull().default(1),
  submittedAt: timestamp('submitted_at', { withTimezone: true }).notNull().defaultNow(),
  closedAt: timestamp('closed_at', { withTimezone: true }),
  createdAt: timestamp('created_at', { withTimezone: true }).notNull().defaultNow(),
  updatedAt: timestamp('updated_at', { withTimezone: true }).notNull().defaultNow(),
}, t => ({
  queueIdx: index('fr_queue_idx').on(t.status, t.slaDueAt),
  customerIdx: index('fr_customer_idx').on(t.customerUserId, t.submittedAt),
  assigneeIdx: index('fr_assignee_idx').on(t.assigneeUserId, t.status),
}));
```

23.12 Database roles and safety

ROLE	RIGHTS	USED BY
`app_rw`	`SELECT/INSERT/UPDATE/DELETE` on mutable tables; `SELECT/INSERT` only on immutable tables	api, worker
`app_migrate`	DDL	Release job only
`app_ro`	`SELECT` on non-sensitive tables and views	Reporting, support tooling

Backups: nightly full backup and continuous WAL archiving to EU object storage, encrypted; restore tested monthly (Chapter 30).

CHAPTER 24

API design

One REST API serves the website, the console and the mobile app. It is versioned, schema-first and predictable: every input is validated, every error has a code, every write is safe to retry.

24.1 Conventions

TOPIC	RULE
Base path	`/v1`. Breaking changes create `/v2` for the affected resources; `/v1` stays for at least 6 months after the last mobile release that uses it
Format	JSON (UTF-8). Field names `camelCase`. Timestamps ISO-8601 UTC with `Z`; local flight times also carry their IANA zone
Resource naming	Plural nouns (`/flight-requests`); state changes as commands (`/commands/send-quote`)
Audiences	`/v1/*` customer and public; `/v1/admin/*` Admin Panel and mobile admin mode; `/v1/dev/*` Developer Panel only (separate host)
Authentication	`Authorization: Bearer <access token>` for mobile; HTTP-only, `Secure`, `SameSite=Lax` cookies for web and console (Chapter 25)
Validation	Zod schemas from `packages/contracts`; unknown fields are rejected on input and stripped on output
Pagination	Cursor-based: `?limit=25&cursor=…`; response has `nextCursor`
Filtering and sorting	Explicit query parameters (`status`, `assignee`, `from`, `to`, `sort=slaDueAt`); no free-form query language
Concurrency	`ETag` on aggregates; commands require `If-Match` (row version); mismatch → `409 VERSION_CONFLICT`
Idempotency	`Idempotency-Key` header on creates and payment/record commands; replayed for 24 h
Localisation	`Accept-Language: fa` or `en` selects error message and label language; data is never translated server-side except labels
Rate limits	Per IP and per user, per route group (Chapter 25); `429` with `Retry-After`
Documentation	OpenAPI 3.1 generated in CI; published to the Developer Panel; the generated client is the only way apps call the API

24.2 Errors

Errors follow RFC 9457 (`application/problem+json`) with a stable machine `code`:

```
{
  "type": "https://api.unitravel.example/problems/invalid-transition",
  "title": "This action is not allowed in the current state",
  "status": 409,
  "code": "INVALID_TRANSITION",
  "detail": "send_quote requires every option to have confirmed baggage (option 2: UNKNOWN).",
  "requestId": "req_01JBX6YQ7Z0K3M2C8F4D5E6G7H",
  "errors": [ { "path": "options[1].baggage", "code": "UNKNOWN_NOT_ALLOWED" } ]
}
```

CODE	HTTP	MEANING
`VALIDATION_FAILED`	400	Input failed the schema; `errors[]` lists fields
`UNAUTHENTICATED` / `TOKEN_EXPIRED`	401	No or expired token
`PERMISSIONS_CHANGED`	401	Token's `perm_version` is stale; refresh and retry
`FORBIDDEN`	403	Authenticated but lacks permission or ownership
`NOT_FOUND`	404	Also returned for records the caller may not see (no existence leaks)
`VERSION_CONFLICT` / `INVALID_TRANSITION`	409	Concurrency or state-machine guard
`IDEMPOTENCY_MISMATCH`	422	Same key, different body
`OTP_INVALID` / `OTP_EXPIRED` / `OTP_LOCKED`	400 / 400 / 429	Verification failures (generic message to the user)
`RATE_LIMITED`	429	Too many requests
`OFFER_EXPIRED` / `PRICE_CHANGED`	409	Revalidation outcomes
`SUPPLIER_UNAVAILABLE`	503	Only for synchronous price checks; search degrades instead
`INTERNAL`	500	Unexpected; `requestId` for support

24.3 Endpoint catalogue — customer and public

METHOD & PATH	PURPOSE	AUTH
`POST /v1/auth/otp/request`	Send a code to a phone or email (`purpose` : SIGN_IN, VERIFY_PHONE, VERIFY_EMAIL)	Public + rate limits + proof-of-work after thresholds
`POST /v1/auth/otp/verify`	Verify a code; returns session (tokens or cookies)	Public
`POST /v1/auth/refresh`	Rotate the refresh token, issue a new access token	Refresh token
`POST /v1/auth/logout`	Revoke the current session	User
`GET /v1/me`	Profile, identities, roles, permissions, feature flags, `permVersion`	User
`PATCH /v1/me`	Name, language, calendar, time zone, notification preferences	User
`POST /v1/me/identities`	Add a phone or email (starts verification)	User
`GET/POST/PATCH/DELETE /v1/me/travellers[/:id]`	Traveller profiles and documents	User (owner)
`GET /v1/locations?q=`	Airport and city autocomplete (EN/FA)	Public
`POST /v1/flight-searches`	Start a search; returns `202` with `id`	Public or user (anonymous searches rate-limited harder)
`GET /v1/flight-searches/:id`	Status, progress and current results (paginated)	Same actor as creator

METHOD & PATH	PURPOSE	AUTH
`GET /v1/flight-searches/:id/events`	Server-sent events: `progress`, `results`, `done`	Same actor
`GET /v1/itineraries/:id`	Full itinerary detail	Same actor
`POST /v1/itineraries/:id/price-check`	Revalidate price now	User
`GET /v1/itineraries/:id/seat-maps`	Seat maps where the supplier provides them	User
`POST /v1/flight-requests`	Create from an itinerary or as a manual request	User with verified phone; `Idempotency-Key`
`GET /v1/flight-requests` · `GET /v1/flight-requests/:ref`	List and detail (customer view)	Owner
`POST /v1/flight-requests/:ref/messages`	Message the team	Owner
`POST /v1/flight-requests/:ref/quotes/:quoteId/accept`	Accept a quote option	Owner; `Idempotency-Key`
`POST /v1/flight-requests/:ref/cancel`	Cancel (before reservation)	Owner
`POST /v1/cargo-requests` · `GET …` · `GET …/:ref` · messages · accept · cancel	Same pattern for cargo	Owner
`POST /v1/uploads`	Create an upload session (pre-signed URL, size and type limits)	User
`GET /v1/documents/:id/download`	Short-lived signed URL (after permission check)	Owner or staff
`GET /v1/notifications` · `POST /v1/notifications/read`	Inbox and read receipts	User
`POST /v1/devices` · `DELETE /v1/devices/:id`	Register or remove push tokens	User

24.4 Endpoint catalogue — Admin Panel

METHOD & PATH	PURPOSE	PERMISSION
`GET /v1/admin/queues/summary`	Counts and SLA breaches per queue	`flight_request.read.any` or `cargo_request.read.any`
`GET /v1/admin/flight-requests`	Filtered list	`flight_request.read.any`
`GET /v1/admin/flight-requests/:ref`	Staff view: customer, snapshot, timeline, notes, records	`flight_request.read.any`
`POST /v1/admin/flight-requests/:ref/commands/:command`	Any command from Table 13.1	Per command
`POST /v1/admin/flight-requests/:ref/notes`	Internal note	`flight_request.note.internal`
`POST /v1/admin/flight-requests/:ref/messages`	Message to customer	`flight_request.transition`
`POST /v1/admin/flight-requests/:ref/contact-attempts`	Log a call or template SMS	`flight_request.transition`
`POST /v1/admin/flight-requests/:ref/quotes` · `PATCH …/quotes/:id`	Draft and edit quotes	`quote.create`

METHOD & PATH	PURPOSE	PERMISSION
`POST /v1/admin/flight-requests/:ref/reservations` · `/tickets` · `/payments`	Record external actions	`reservation.record`, `ticket.record`, `payment.record`
`POST /v1/admin/payments/:id/verify`	Second-person verification	`payment.record` (different user)
`POST /v1/admin/flight-searches`	Staff search (adds staff fields)	`flight_search.run` + staff role
`GET /v1/admin/customers/:id` · `POST …/reveal-document`	Customer context; logged reveal	`customer.read.pii` / `customer.read.documents`
`…/v1/admin/cargo-requests/…`	Cargo equivalents, partner bookings, tracking events	`cargo_request.*`
`GET /v1/admin/compliance/cases` · `POST …/:id/decide`	Compliance queue and decisions	`compliance.case.read` / `.decide`
`GET/POST /v1/admin/compliance/policies`	Carrier, route, goods and lane policies	`compliance.case.decide` (owner approval for changes)

24.5 Endpoint catalogue — Developer Panel

METHOD & PATH	PURPOSE	PERMISSION
`GET /v1/dev/users` · `GET /v1/dev/users/:id`	Directory and detail	`user.read`
`PUT /v1/dev/users/:id/roles`	Replace role set (step-up for privileged)	`user.role.assign[.privileged]`
`POST /v1/dev/users/:id/suspend` · `/sessions/revoke`	Account actions	`user.role.assign`
`GET/POST/PATCH /v1/dev/roles`	Custom roles	`user.role.assign.privileged`
`GET/PATCH /v1/dev/providers/:id` · `PUT …/credentials` · `POST …/test`	Provider configuration	`provider.config.read` / `.write`
`GET /v1/dev/health` · `GET /v1/dev/queues` · `POST /v1/dev/jobs/:id/retry`	Health, queues, dead letters	`diagnostics.read`
`GET/POST /v1/dev/config/:domain/versions` · `POST …/:version/publish` · `POST …/simulate`	Versioned configuration (engine rules, hubs, workflow, notification matrix, auth)	`engine.rules.publish` / `settings.write`
`GET/PUT /v1/dev/notification-templates` · `POST …/test-send`	Templates	`notification.template.write`
`GET/PUT /v1/dev/settings` · `/feature-flags`	Application settings and flags	`settings.write` / `flags.write`
`GET /v1/dev/audit-log` · `POST /v1/dev/audit-log/export`	Audit search and export (step-up)	`audit.read`

24.6 Webhooks (inbound)

PATH	SOURCE	VERIFICATION
`POST /v1/webhooks/sms/:provider`	SMS delivery reports	Provider signature or shared secret + IP allowlist where offered

PATH	SOURCE	VERIFICATION
`POST /v1/webhooks/push/:provider`	Push receipts (where supported)	Signature
`POST /v1/webhooks/suppliers/:provider`	Order events (Stage 7, e.g. Duffel)	Signature; events deduplicated by id

Webhook handlers only verify, record and enqueue; processing happens in the worker.

24.7 Example: starting a search

```
POST /v1/flight-searches
Content-Type: application/json
Accept-Language: fa

{
  "tripType": "ONE_WAY",
  "slices": [ { "from": { "city": "THR" }, "to": { "city": "LON" }, "date": "2026-11-14", "flexDays": 2 } ],
  "passengers": [ { "type": "ADT" } ],
  "cabin": "ECONOMY",
  "preferences": { "allowSelfTransfer": true, "allowAirportChange": false, "allowOvernight": true,
                   "preferredLayoverMin": [240, 360], "maxStops": 2, "includeGateways": true }
}

HTTP/1.1 202 Accepted
Location: /v1/flight-searches/0193f7e2-8c1a-7b6e-9d2f-4a5b6c7d8e9f
{ "id": "0193f7e2-8c1a-7b6e-9d2f-4a5b6c7d8e9f", "status": "RUNNING", "expiresAt": "2026-10-22T10:42:00Z" }
```

24.8 Example: one result item

```
{
  "id": "itn_01JBX7…",
  "construction": "SELF_TRANSFER",
  "tabs": ["BEST", "CHEAPEST"],
  "price": { "total": { "amountMinor": 41200, "currency": "GBP" }, "isSumOfTickets": true },
  "durationMin": 685,
  "slices": [ { "origin": "VAN", "destination": "LHR", "segments": [ "…two segments…" ] } ],
  "connections": [
    { "at": "IST", "layoverMin": 290, "requiredMin": 180, "inPreferredWindow": true,
      "flags": ["SEPARATE_TICKETS", "ENTRY_REQUIRED"], "advisory": "…localised text…" }
  ],
  "gateway": { "iata": "VAN", "dayOffset": 1, "access": "…localised text…" },
  "truth": [
    { "component": 1, "provider": "duffel", "rung": "LIVE_OFFER", "fetchedAt": "2026-10-22T09:38:11Z" },
    { "component": 2, "provider": "amadeus-enterprise", "rung": "CACHED_OFFER", "fetchedAt": "2026-10-
22T09:31:02Z" }
  ],
  "baggage": [ { "segment": 1, "checked": { "status": "UNKNOWN" } },
               { "segment": 2, "checked": { "status": "KNOWN", "value": { "pieces": 1, "kgPerPiece": 23 } }
} ],
  "explain": { "price": 0.0, "duration": 0.31, "layoverFit": 0.0, "risk": 0.4, "stops": 0.5, "timeOfDay":
0.0 }
}
```

24.9 Example: server-sent events

```
event: progress
data: {"sourcesTotal":7,"sourcesDone":3,"removedByPolicy":4}

event: results
data: {"version":2,"count":11,"top":["itn_01JBX7…","itn_01JBX8…"]}

event: done
data: {"status":"COMPLETE","count":23,"durationMs":14210}
```

Clients re-fetch `GET /v1/flight-searches/:id?version=2` on a `results` event, so the event stream stays small and resumable (`Last-Event-ID`).

CHAPTER 25

Authentication and authorisation

Passwordless sign-in with one-time codes for everyone, a second factor for staff, short-lived tokens, and a permission check on every protected operation. Abuse controls protect both customers and the SMS budget.

25.1 Sign-in with a one-time code

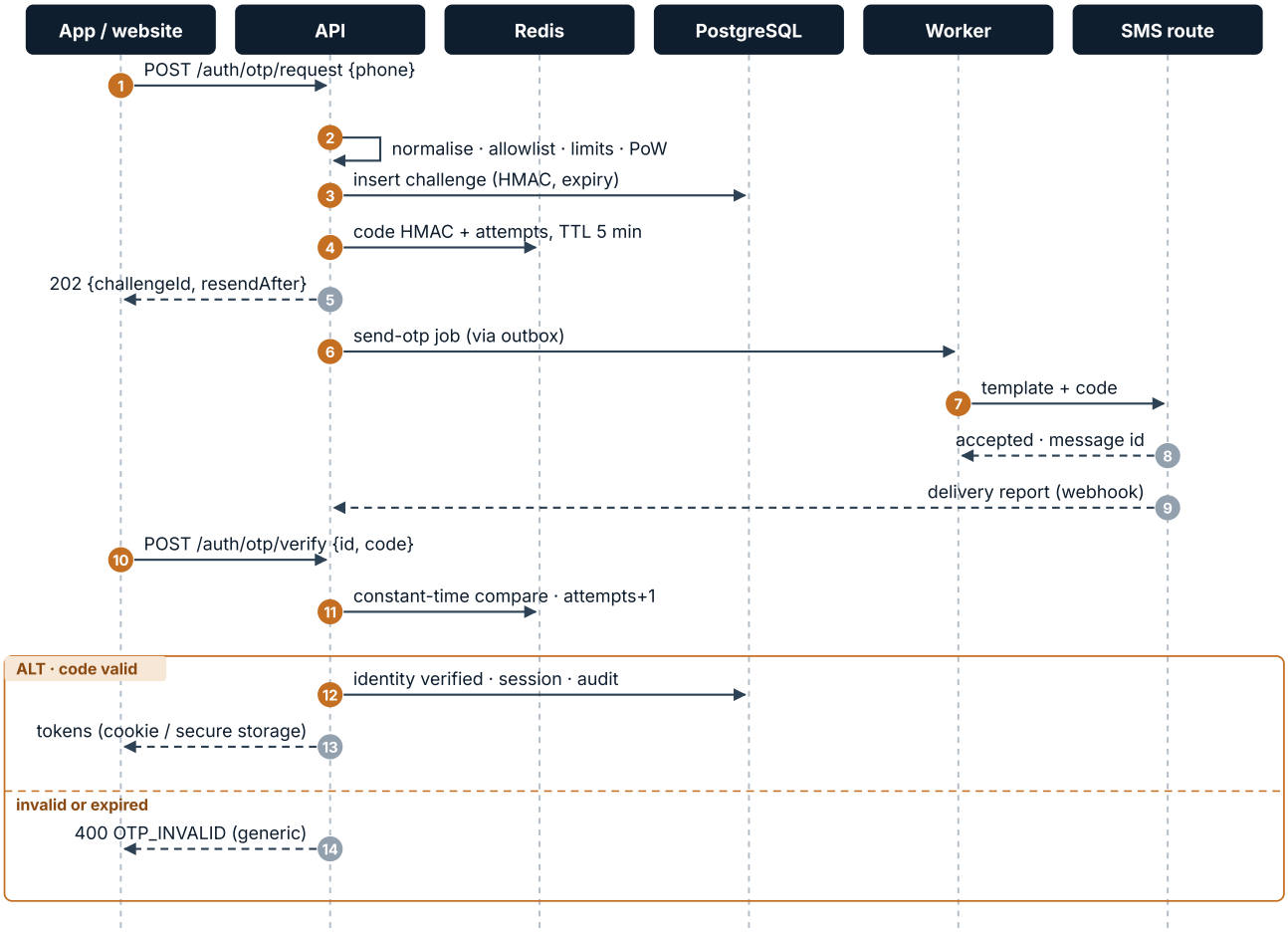


Figure 25.1 — Phone sign-in. The code is never stored in clear, never logged and never returned by the API.

RULE	VALUE (CONFIGURABLE)	WHY
Code format	6 digits, cryptographically random	Usable on any keypad; 1-in-a-million guess
Lifetime	5 minutes	Long enough for slow SMS in Iran, short enough to limit replay
Attempts per code	5, then the challenge is locked	Brute-force protection
Resend	After 60 s, doubling each time; maximum 5 per hour and 10 per day per number	Abuse and cost control
Storage	HMAC-SHA-256(code, pepper) in Redis (fast check) and the challenge row in PostgreSQL (audit)	No plaintext codes at rest

RULE	VALUE (CONFIGURABLE)	WHY
Comparison	Constant-time	Timing attacks
Response to wrong code	Generic "code invalid or expired"	No oracle about which part failed
Channel	SMS route by country prefix (Chapter 8); voice call fallback where the provider supports it	Delivery in Iran
Binding	Challenge bound to device id and IP range; verification from a different device requires a new code	Code interception
Normalisation	`libphonenumber-js` on the server; reject invalid and premium-rate ranges	SMS-pumping fraud

Abuse controls

SMS pumping — attackers triggering OTPs to premium or fake numbers to earn termination fees — is the most common attack on OTP sign-in, and Iranian SMS tariffs rose sharply in 2026 `REPORTED`. Controls are layered:

1. **Destination allowlist** of countries (Developer Panel); everything else is refused.
2. **Rate limits** per number, per IP, per /24 network, per device id and globally per country, in Redis sliding windows.
3. **Proof-of-work challenge** (self-hosted, e.g. ALTCHA `PROPOSED`) after thresholds. Google reCAPTCHA and hCaptcha are avoided because they are unreliable or contractually problematic for Iranian users (Chapter 8).
4. **Conversion monitoring**: an alert when the ratio of verified to sent codes for a country or prefix drops below a threshold; automatic temporary block of that prefix.
5. **Budget circuit breaker**: daily SMS spend cap per route; when reached, OTP falls back to email for users who have a verified email, and developers are paged.

25.2 Tokens and sessions

CLIENT	ACCESS TOKEN	REFRESH TOKEN	STORAGE
Website	JWT, 10 min, audience `web`	Opaque, 30 days, rotating	HTTP-only `Secure` cookies; CSRF protection with `SameSite=Lax` plus a double-submit token on state-changing requests
Console	JWT, 10 min, audience `console`	Opaque, 12 h absolute, rotating	HTTP-only cookies on the console host only
Mobile	JWT, 10 min, audience `mobile`	Opaque, 30 days, rotating	Expo SecureStore (Keychain / Android Keystore)

- Access tokens carry: `sub`, `sid` (session id), `aud`, `perm_version`, `permissions` (compact list), `mfa` level, `exp`. They are signed with an asymmetric key (EdDSA or ES256) whose public part is cached by the API; keys rotate every 90 days with overlap.
- Refresh tokens are stored hashed. Each refresh returns a new refresh token; presenting an already-rotated token revokes the whole token family and the session (theft detection).
- Sessions are listed for the user ("Signed in on iPhone, Tehran, 2 days ago") and for staff in the Developer Panel, with *Revoke*.

25.3 Email as an alternative

Email sign-in uses the same OTP mechanism with a 6-digit code (not a magic link, because links break across devices and are often scanned by mail filters). Email-only accounts can search and save travellers; submitting a request needs a verified phone when `auth.require_verified_phone_for_requests` is on, because the team's working channel is the phone (brief §7).

25.4 Account linking and recovery

- A user may hold one primary phone, additional phones and one or more emails; each identity is verified independently.
- If a customer loses their phone number, they sign in by email and add a new phone (verified by OTP). If they have no email, recovery is staff-assisted: the customer calls, an admin verifies identity against previous requests and travel documents, and triggers a recovery code to a new number. The action needs two staff members and is audited.
- Merging two accounts (same person signed up with phone and with email) is a Developer Panel action with step-up; requests move to the surviving account.

25.5 Staff authentication

CONTROL	RULE
First factor	Phone OTP, as for customers
Second factor	Passkey (WebAuthn) preferred; TOTP authenticator accepted. Enrolment is forced on first console sign-in
Step-up	Re-verify the second factor for privileged actions if the last verification is older than 10 minutes
Session	Idle timeout 30 min, absolute 12 h; one active console session per device
Developer Panel	Separate hostname; optional IP allowlist; permissions as in Table 10.1
Leavers	Suspension revokes all sessions immediately and removes push tokens

25.6 Authorisation

Permission checks

- Global guards authenticate every request and check `perm_version` (Chapter 20).
- Route-level `@RequirePermission(...)` declares the permission; routes without a declaration fail closed in CI (a test enumerates all routes and asserts each has either `@Public()` or a permission).
- **Ownership** is a separate check: customer endpoints load the resource and compare `owner_user_id` with the caller. Lookups by reference that fail ownership return `404`, not `403`, to avoid confirming that a reference exists.
- **Field-level filtering**: customer responses are serialised through customer schemas that cannot include internal fields (notes, costs, assignee details, screening results).

Permission refresh

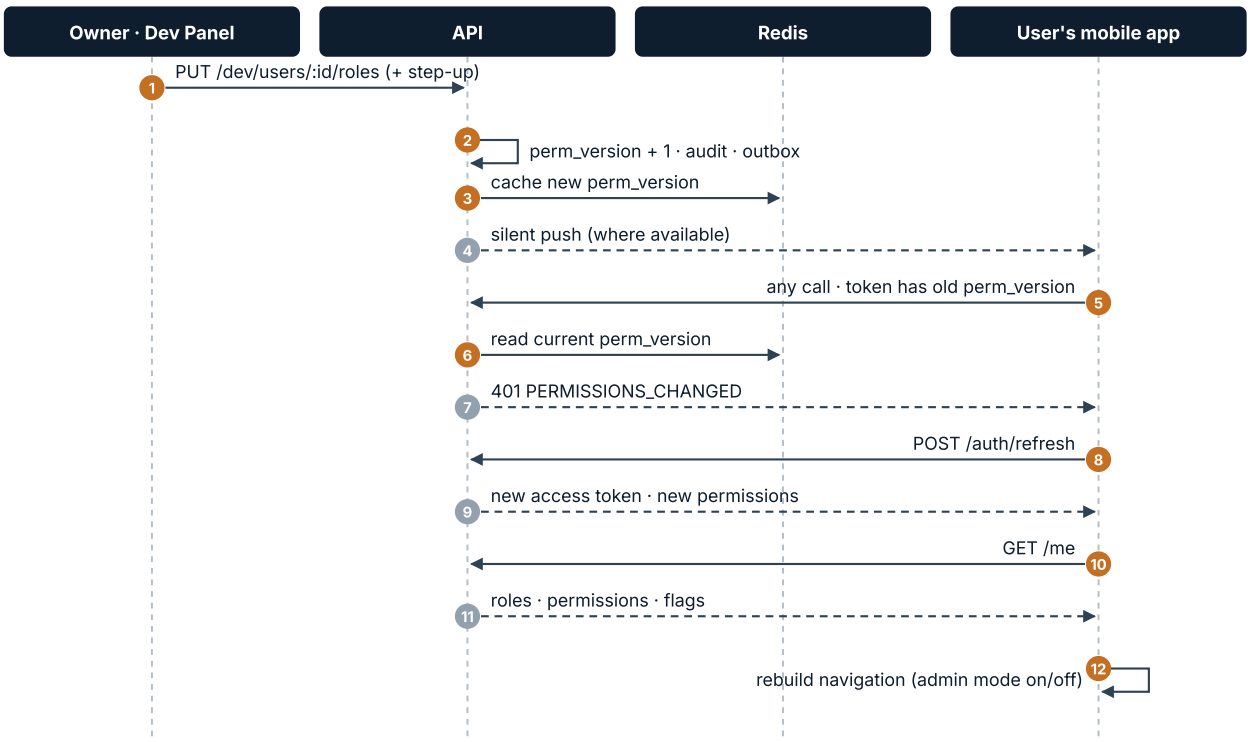


Figure 25.2 — A customer promoted to admin sees admin mode on the next call; a demoted admin loses access on the next call.

The current `perm_version` per user is cached in Redis (written through on change, falling back to the database on a cache miss). The check costs one Redis read per request, which is the price of making demotions immediate.

25.7 Rate limits

ROUTE GROUP	LIMIT (DEFAULT)	KEY
`POST /auth/otp/request`	5 / hour per number; 20 / hour per IP; challenge after 3 per 10 min per IP	number, IP, device
`POST /auth/otp/verify`	10 / 10 min per IP	IP
`POST /flight-searches`	Anonymous 10 / hour per IP; signed-in 60 / hour per user	IP or user
Customer writes	60 / hour per user	user
Admin API	600 / min per user	user
Developer API	120 / min per user	user

Limits are enforced in the API with Redis (sliding window) and coarsely at the proxy. They are configuration, adjustable in the Developer Panel.

CHAPTER 26

Background jobs, events and caching

Everything that is slow, external or time-based runs in the worker. A transactional outbox guarantees that every business change produces its side effects exactly once in effect, and Redis keeps the fast paths fast.

26.1 The transactional outbox

When a command changes state, the API writes, **in the same database transaction**:

1. the business rows (for example the request and its new status);
2. the history row and the audit row;
3. one row per domain event in `outbox_events`, each with a `dedupe_key`.

The worker polls `outbox_events` (with `FOR UPDATE SKIP LOCKED`, in batches) every 500 ms, publishes each event to the matching BullMQ queue, and marks it dispatched. If the API crashes after commit, the event is still there; if the worker crashes after publishing, the dedupe key stops the consumer acting twice. This replaces fragile "save, then send" code everywhere.

> **RULE**
> No module sends an SMS, push, email or supplier write directly from a request handler. Handlers write events; the worker performs side effects. The only synchronous external calls from the API are the customer-initiated price check and seat-map fetch, which are read-only and time-boxed.

26.2 Queues

QUEUE	PRODUCERS	WORK	CONCURRENCY	RETRIES
`search.execute`	API (search start)	Run the engine pipeline; write progressive results	20 per worker	None (the search has a deadline; failure is reported)
`supplier.call`	Engine	Individual supplier calls when isolated from the search job	Per-provider limits	1 for reads
`outbox.dispatch`	Scheduler	Move outbox rows to queues	1 (leader)	Infinite with back-off
`notify.route`	Events	Decide channels per recipient (Chapter 17)	10	5, exponential
`notify.sms` · `notify.push` · `notify.email`	Router	Deliver through providers; failover between SMS routes	Per provider	5, exponential; then dead letter
`timers.sla`	Requests, cargo	Delayed jobs for SLA reminders, quote expiry, deadline alerts	10	3
`compliance.screen`	Requests, cargo, payments	Party and goods screening on submission and on change	5	3
`compliance.lists-sync`	Scheduler (every 6 h + on demand)	Download UK, OFAC and EU lists; diff; re-screen affected subjects	1	5

QUEUE	PRODUCERS	WORK	CONCURRENCY	RETRIES
`reference.sync`	Scheduler (daily)	Airports, airlines, time-zone data	1	5
`documents.scan`	Uploads	Virus scan; mark clean or quarantine	3	3
`maintenance`	Scheduler	Retention deletions, partition rotation, expired idempotency keys, search cleanup	1	3

Timers

SLA reminders and deadlines are **delayed BullMQ jobs** keyed by `request id + timer type`. When a request changes state, the command removes timers that no longer apply and schedules new ones in the same outbox event. Each job re-checks the current state when it fires, and does nothing if the condition no longer holds, so a missed removal is harmless.

Dead letters and replay

Jobs that exhaust their retries move to a dead-letter set. The Developer Panel lists them with the error, the attempt history and a redacted payload; a developer can retry or discard. Every retry is idempotent by design: deliveries are keyed by `(notification_id, channel)`, records by their natural keys.

26.3 Domain events

EVENT	EMITTED BY	TYPICAL CONSUMERS
`user.registered`, `identity.verified`	identity	compliance (screen new customers), notifications (welcome)
`user.permissions_changed`	access	notifications (security alert, silent push)
`flight_request.submitted`	requests	compliance (screen), notifications (customer, admins), timers
`flight_request.transitioned`	requests	notifications, timers, reporting
`quote.sent`, `quote.accepted`	requests	notifications, timers
`reservation.recorded`, `ticket.recorded`	bookings	notifications, timers, documents
`payment.recorded`, `payment.verified`	payments	compliance (payer screening), requests (payment status)
`cargo_request.submitted`, `cargo_request.transitioned`	cargo	compliance, notifications, timers
`compliance.case_opened`, `compliance.case_decided`	compliance	requests or cargo (release / decline), notifications
`config.published`	config	all processes (reload)
`provider.health_changed`	suppliers	notifications (developers), engine (skip provider)

Event payloads carry identifiers and the minimum context needed, never full personal data; consumers load what they need through the owning module.

26.4 Redis usage

USE	KEY PATTERN	TTL
Search progress and results	`search:{id}:state`, `search:{id}:results:v{n}`	30 min
Supplier leg cache	`leg:{provider}:{o}:{d}:{date}:{paxHash}:{cabin}`	Per provider (default 10 min)
Supplier auth tokens	`supplier:{id}:{env}:token`	Until expiry − 60 s
Rate limits	`rl:{route}:{key}:{window}`	Window length
OTP	`otp:{challengeId}`	5 min
Permission versions	`perm:{userId}`	None (write-through)
Config cache	`config:{domain}:current`	None (invalidated by pub/sub)
Circuit breakers and budgets	`cb:{provider}`, `budget:{provider}:{day}`	Rolling / 36 h
Pub/sub channels	`config.published`, `search.progress.{id}`	—

Redis is treated as **disposable**: losing it delays work and clears caches but loses no business data, because PostgreSQL holds every record and the outbox re-drives queues. BullMQ needs Redis persistence (AOF) enabled so queued jobs survive restarts.

26.5 Performance budgets

INTERACTION	TARGET (P95)	HOW
Page load (customer, 3G-class connection)	< 2.5 s to interactive for key pages	Server rendering, small bundles, self-hosted fonts, no third-party scripts on core pages
Admin queue list	< 400 ms	Indexed queries, cursor pagination
Request detail	< 500 ms	One query per section, no N+1 (repository tests)
Command (e.g. send quote)	< 600 ms	Single transaction; side effects async
Search first results	< 8 s	Waves, cache, deadlines (Chapter 22)
OTP request to SMS handed to provider	< 3 s	High-priority queue

CHAPTER 27

Compliance engine

The compliance module turns the legal constraints of Chapter 4 into checks that run automatically, holds anything doubtful for a named person to decide, and keeps the evidence. It does not replace legal advice; it makes advice enforceable.

27.1 What is checked, when

CHECK	SUBJECTS	TRIGGER	OUTCOME
Party screening	Customer, travellers, payer, shipper, consignee, partner	Sign-up, request submission, traveller or party change, payment recording, list update	CLEAR · POSSIBLE_MATCH (hold) · MATCH (hold, owner alerted)
Carrier policy	Marketing and operating carriers of every offer	Every search (filter) and every quote option (validation)	Blocked carriers removed; quote option rejected
Route and airport policy	Airports, countries, hubs, gateways	Every search and quote	Blocked or held
Goods screening	Cargo line items (category, keywords, HS code)	Cargo submission and edits	Allowed · review (hold) · prohibited (decline)
Lane policy	Cargo origin–destination pair and service	Cargo submission	Lane disabled · requires approval (hold)
Payment timing (ATOL)	Payment records on flight requests	Payment recording	Blocked if the configured ATOL mode does not allow taking money at that stage

27.2 Sanctions list ingestion

SOURCE	FORMAT AND ACCESS	KEY USED	NOTES
UK Sanctions List (FCDO)	XML / CSV at static URLs; XSD schema; email alerts	**Unique ID**	The single UK list since 28 January 2026 (the OFSI Consolidated List is no longer updated); includes aliases with strength and non-Latin script names DOCUMENTED
OFAC SDN and non-SDN lists	Sanctions List Service: XML (standard and advanced), CSV, delta files, API	OFAC UID	Needed because US secondary sanctions reach non-US firms dealing with designated airlines DOCUMENTED
EU Financial Sanctions File	XML, daily	EU reference	Relevant for EU-based customers and partners
OpenSanctions (optional)	Aggregated API or bulk data	—	CC BY-NC: commercial screening requires a paid licence; useful as a cross-check DOCUMENTED

The `compliance.lists-sync` job runs every 6 hours: download, verify against schema, compute a content hash, diff against the previous version, store entries, and **re-screen** every active subject whose name tokens intersect the changed entries. A failed download alerts developers; screening continues on the last good version and records the version it used.

27.3 Matching Persian names

Names of Iranian customers arrive in Latin transliterations that vary widely (Mohammad, Mohammed, Muhammad; Hosseini, Husseini; -zadeh, -zade). List entries vary too. The matcher therefore works in layers:

1. **Normalise**: lower case, strip diacritics and punctuation, unify common affixes and particles (al-, el-, -zadeh/-zade, -i/-ee endings), collapse doubled vowels, map frequent variant spellings through a maintained equivalence table.
2. **Tokenise and reorder**: compare name tokens as sets, so "Ali Reza Hosseini" and "Hosseini Alireza" meet; also try joined forms ("Alireza").
3. **Score**: combine Jaro–Winkler similarity per token with a phonetic key suitable for transliterated Persian; compute an overall score in [0, 1].
4. **Native script**: when the customer supplied a Persian-script name and the list entry has a non-Latin name, compare in script as well.
5. **Discriminate**: use date of birth, nationality and document numbers to raise or lower the score; a different full date of birth reduces a name-only match below threshold.
6. **Decide**: score ≥ match threshold → `MATCH`; between review and match thresholds → `POSSIBLE_MATCH`; below → `CLEAR`. Thresholds are configuration, tuned on test sets.

Every screening stores the list versions used, the candidates considered and their scores, so a decision can be reconstructed later. The approach follows published guidance on screening transliterated names `DOCUMENTED`; it should be validated against a labelled sample before launch (Chapter 32).

27.4 Policies

Policies are versioned records (Chapter 23) edited by compliance officers and approved by an owner:

POLICY TYPE	EXAMPLE KEY	ACTION	DEFAULT AT LAUNCH
`CARRIER`	Iranian carriers designated by OFAC on 8 Sep 2026, Iran Air, Mahan Air, Saha Airlines	BLOCK	Blocked (Decision D-01)
`CARRIER`	Carriers flagged by counsel for enhanced review	REVIEW	Empty until counsel advises
`AIRPORT`	Airports to avoid	BLOCK / REVIEW	Empty
`COUNTRY_ROUTE`	Routes touching specific countries	REVIEW	Iran-origin requests are *not* held by default; only parties and carriers are screened
`GOODS_CATEGORY`	Electronics, medicines, aircraft parts, batteries	REVIEW	As in Chapter 14
`KEYWORD`	Description keywords (EN/FA) mapped to categories	REVIEW / BLOCK	Seed list maintained by compliance
`LANE`	Cargo lanes touching Iran	Disabled, approval required	Disabled

> **COUNSEL SIGN-OFF REQUIRED**
>
> The carrier list at launch must be produced from the current OFAC, UK and EU designations by the compliance officer and confirmed by sanctions counsel; the platform should not rely on a list compiled by developers. The same applies to goods categories mapped to the UK schedules introduced by SI 2026/983, which this research could not read in full `UNKNOWN`.

27.5 Cases and decisions

A hold creates a **compliance case** linked to the request. Compliance officers see the evidence and decide:

DECISION	EFFECT	EXTRA CONTROL
Release	Request moves to `NEW`; the reason is recorded	—
Decline	Request moves to `DECLINED`; the customer receives a neutral message	Reason code mandatory
Escalate	Case assigned to an owner	—
Override a BLOCK policy	Only for one request, with a reason	Second approver (compliance officer or owner); counsel reference field

Decisions are immutable. Corrections are new decisions that reference the earlier one.

27.6 Payment timing and ATOL

UK rules let a ticket agent sell flights without its own ATOL only if, among other conditions, confirmed tickets are issued immediately upon payment; otherwise the agency needs an ATOL or must sell as agent for an ATOL holder `DOCUMENTED` (CAA guidance; this is an inference for this business model and needs confirmation, Chapter 4). The payments module therefore has an `atol.mode` setting:

MODE	BEHAVIOUR
`PAY_ON_TICKETING` (default)	Staff may record a payment only in the same step as recording issued tickets; no deposits on requests
`AGENT_FOR_ATOL_HOLDER`	Payments allowed earlier; the platform records the ATOL holder's number on receipts and generates an ATOL Certificate at first payment (template supplied by the holder)
`OWN_ATOL`	As above with Uni Travel's own ATOL number

27.7 Evidence and retention

- Screenings, hits, cases and decisions are retained for the period counsel sets (proposed: 6 years after the relationship ends), separately from customer data deletion, so due diligence can be shown later.
- List versions are retained for the same period, so any screening can be replayed against exactly the data used.
- Exports for auditors are available to compliance officers with step-up.

CHAPTER 28

Security and privacy

The platform holds passport details, phone numbers, travel plans and sanctions-screening evidence for people in a high-risk context. Security is designed in layers, privacy by minimisation, and both are verified before launch.

28.1 Threat model

THREAT	EXAMPLE	PRIMARY CONTROLS
Account takeover	SIM swap, OTP interception, credential phishing of staff	OTP binding and limits; staff second factor (passkeys); session listing and revocation; new-sign-in alerts
Privilege escalation	Customer calling admin endpoints; admin calling developer endpoints	Server-side permission guards; fail-closed route test; separate developer host; `perm_version` checks
Insecure direct object reference	Guessing request references	Ownership checks on every lookup; `404` on failure; random references
Data exfiltration	Database dump, log leakage, backup theft	Field-level encryption of documents; log redaction; encrypted backups; least-privilege database roles
Supply-chain compromise	Malicious npm package	Lockfiles, pinned versions, automated dependency audit, minimal dependencies, CI isolation
Injection and XSS	SQL injection, stored XSS in notes or messages	Drizzle parameterised queries; output encoding in React; strict CSP; Markdown disabled in user content
Malicious uploads	Malware in cargo documents	Type and size limits; virus scanning before availability; downloads via signed URLs with `Content-Disposition: attachment`
Fraud and abuse	SMS pumping; fake requests	Chapter 25 abuse controls; verified phone required for requests
Insider misuse	Staff browsing customer passports	Reveal-on-click with audit; permission scoping; periodic access reviews
Availability	Supplier outage, DDoS, Iranian network shutdown	Fail-soft search; proxy rate limits; SMS fallback; clear status messaging

Target: **OWASP ASVS Level 2** for the API, web and console; OWASP MASVS L1 for the mobile app PROPOSED.

28.2 Secrets and keys

- Secrets (database URLs, signing keys, provider credentials' master key) live outside the repository: environment files on the host with restricted permissions, or a secrets manager if the hosting provider offers one PROPOSED.
- Provider credentials entered in the Developer Panel are encrypted with a data key that is itself encrypted by the master key (envelope encryption); the master key never enters the database.
- JWT signing keys rotate every 90 days; old public keys stay valid until outstanding tokens expire.
- The mobile app contains no secrets. Anything it needs comes from the API after authentication.

28.3 Encryption

DATA	AT REST	IN TRANSIT
Whole database and backups	Disk / volume encryption; backups encrypted with a separate key before upload	TLS to the database (if not on the same host)
Passport and ID numbers, TOTP secrets, provider credentials	**Field-level AES-256-GCM** with `key_id` for rotation; only `last4` stored in clear	—
Documents (tickets, cargo files)	Object storage server-side encryption; private buckets	Signed URLs over HTTPS, 5-minute lifetime
All client traffic	—	TLS 1.2+ (1.3 preferred), HSTS with preload on all hosts

Decryption of passport numbers happens only in two places: the admin *Reveal* action (audited) and, in Stage 7, the booking adapter.

28.4 Web and console hardening

- Content Security Policy with nonces; no inline scripts; no third-party scripts on authentication, request and console pages.
- `frame-ancestors 'none'`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy` minimal.
- Cookies: `HttpOnly`, `Secure`, `SameSite=Lax`; console cookies scoped to the console hosts.
- Self-hosted fonts and assets: no Google Fonts or Google Maps (unreliable or prohibited for Iranian users, Chapter 8).
- Error pages never echo stack traces.

28.5 Logging and the audit log

- Application logs are structured; a shared redaction list removes phone numbers (keeps the country code and last two digits), emails, names, document numbers, OTP codes, tokens and free-text message bodies.
- The **audit log** (Chapter 23) records who did what to which record, with masked before/after values. It is append-only for the application role, partitioned monthly, and optionally hash-chained so tampering is detectable.
- Security events (failed OTP bursts, refresh-token reuse, privileged role changes, policy overrides) also go to an alert channel for developers and owners.

28.6 Privacy (UK GDPR)

TOPIC	APPROACH
Controller and registration	Uni Travel is the controller; pay the ICO data protection fee (tier depends on size) DOCUMENTED
Lawful bases	Contract (handling requests and bookings); legal obligation (sanctions screening, record keeping); legitimate interests (fraud prevention, service security); consent (marketing only)
DPIA	Required before launch: passport data, sanctions screening, data about people in Iran, international transfers
Minimisation	Passport details collected only after a quote is accepted; search works without an account; free-text medical details discouraged

TOPIC	APPROACH
Special category data	Not collected deliberately; names and nationality are never used to infer ethnicity or religion; screening uses names only for matching DOCUMENTED (ICO)
International transfers	Phone numbers and message content sent to an Iranian SMS provider, and data held by any non-UK processor, are restricted transfers that need a documented basis and risk assessment; Iran has no UK adequacy decision INFERRED — counsel to confirm
Data subject rights	Self-service export and deletion request in the account; staff workflow with a 30-day clock; deletion respects legal retention
Processors	Data processing agreements with hosting, SMS, push and email providers; register of processors in `docs/`

Retention schedule (proposal for counsel)

DATA	RETENTION	THEN
Search queries and results	30 days	Deleted (aggregates kept anonymised)
Supplier call payloads	14 days	Deleted
OTP challenges	90 days	Deleted
Requests, quotes, reservations, tickets, payments	6 years after travel or closure	Deleted or anonymised
Passport numbers	Until 12 months after the last travel date, unless the customer keeps the traveller profile	Field erased
Compliance screenings, cases, decisions, list versions	6 years after the relationship ends	Deleted
Audit log	6 years	Partition dropped
Application logs	30 days	Deleted
Backups	35 days rolling	Overwritten

28.7 Verification before launch

1. Automated: dependency audit, static analysis, secret scanning, the route-permission test, and DAST against staging in CI.
2. Manual: an independent penetration test of web, console, API and mobile app, focused on authorisation and OTP abuse; findings fixed and retested before go-live.
3. Operational: restore test from backups; incident-response runbook with contacts, including the ICO 72-hour breach notification duty.

CHAPTER 29

Website, console and mobile app

Three clients, one design system, one generated API client. Each is built to work for users in Iran as well as in Europe: light pages, no Google dependencies, Persian right-to-left support and graceful behaviour when the network is poor.

29.1 Website (Next.js)

ASPECT	DESIGN
Routing	App Router with locale segment: `/en/…` , `/fa/…` ; locale chosen from the account, then cookie, then `Accept-Language`
Rendering	Server-rendered public pages (home, routes, help, legal); client components for search, results and account areas
API access	Same-origin: the proxy routes `/api/*` on the website host to the API, so cookies stay first-party and CORS is unnecessary
Data fetching	Generated `api-client` + TanStack Query; search progress via server-sent events with polling fallback
Forms	React Hook Form + the same Zod schemas the API uses; server errors mapped to fields by `errors[].path`
UI kit	Tailwind CSS, shadcn/ui, Base UI (Kit); components in `packages/ui`
Performance	Route-level code splitting, image optimisation, self-hosted fonts (Vazirmatn for Persian, an open Latin face), no third-party tags on core flows
Resilience	Request status pages cache the last known state and show "last updated" if the network drops

29.2 Console (Next.js)

- One app serving two hostnames: `admin.` (Admin Panel) and `dev.` (Developer Panel). Middleware maps the host to a route group and refuses routes from the other group.
- Dense, keyboard-friendly screens: data tables (TanStack Table) with saved filters, `j/k` navigation in queues, `c` to claim, `n` to add a note.
- Live updates: queue counts and the open request refresh via server-sent events; if someone else changed the case, a banner offers to reload (optimistic concurrency, Chapter 20).
- Forms render server-computed allowed actions; disabled actions show the guard's reason.
- Stricter CSP than the website; no analytics scripts.

29.3 Mobile app (Expo / React Native) PROPOSED

ASPECT	DESIGN
Navigation	Expo Router with two navigators: customer tabs (Search, Requests, Cargo, Inbox, Account) and admin tabs (Queue, Mine, Inbox, Account). The active navigator is chosen from `GET /v1/me` permissions
Auth storage	Refresh token in SecureStore (Keychain / Keystore); access token in memory
Data	Generated `api-client` + TanStack Query with a persisted cache, so request status remains visible offline

ASPECT	DESIGN
Search progress	Polling with back-off (simpler and more robust than SSE on mobile networks)
Push	Expo push service for iOS and for Android outside Iran. For Android users in Iran, Expo push cannot deliver because it relies on Google's FCM; evaluate a non-FCM provider (e.g. Pushy's MQTT gateway) and rely on SMS plus in-app polling for anything critical DOCUMENTED (Expo, Pushy) / UNKNOWN (delivery inside Iran)
Deep links	Universal links / app links for the short links in SMS; open the request after sign-in
Updates	Over-the-air updates for JavaScript-only fixes. Reachability of Expo's update CDN from Iran is unknown; `expo-updates` supports a self-hosted update server as a fallback UNKNOWN
Security	No secrets in the bundle; certificate pinning considered for the API host; jailbreak/root detection not used (would block legitimate users on older devices)

Distribution

CHANNEL	REACH	CONSIDERATIONS
Apple App Store	UK/EU users; Iranian users with foreign-region Apple accounts	No Iran storefront; Apple blocked the App Store for Iranian IPs in 2018 REPORTED
Google Play	UK/EU users; Iranian users when reachable	Free apps have been available in Iran since 2013, but access has been blocked during shutdowns REPORTED
Cafe Bazaar / Myket	The dominant Android stores in Iran (Cafe Bazaar ≈ 97% share) REPORTED	Publisher requirements for a UK company are UNKNOWN; payments to or contracts with Iranian platforms raise sanctions questions → counsel
Direct APK from the website	Fallback for Android users in Iran	Google's Android developer verification will block apps from unregistered developers on certified devices, with global rollout in 2027; register the developer account early REPORTED

The **website is the guaranteed channel**: every customer feature must work fully on the mobile web, so no customer depends on an app store.

29.4 Internationalisation and right-to-left

TOPIC	RULE
Languages	English and Persian at launch; message catalogues in `packages/i18n`; ICU message format
Direction	`dir="rtl"` for Persian; Tailwind logical utilities (`ms-*`, `me-*`, `ps-*`, `pe-*`, `start-*`, `end-*`); directional icons mirrored; numbers and codes (flight numbers, references, times) wrapped in LTR isolates
Mobile RTL	`I18nManager.allowRTL(true)`; switching language triggers an app reload, explained to the user
Calendar	Storage always ISO-8601 UTC. Display Gregorian or Jalali per user preference; web uses `Intl.DateTimeFormat` with the Persian calendar; mobile uses a Jalali date library because Hermes' `Intl` coverage varies
Digits	Persian digits optional in the Persian UI; inputs accept both Persian and Latin digits and normalise them server-side (`۰۱۲۳…` → `0123…`)
Names	Booking names always in Latin script as in the passport; Persian names optional and for display only
Currency	Prices in the supplier's or quote currency (GBP, EUR); no rial/toman conversions shown by default because exchange rates are volatile; if added later, label them indicative
Time zones	Flight times always in the airport's local time with the zone shown on hover/tap; notifications use the recipient's zone

29.5 Accessibility

Target **WCAG 2.2 AA** for website and console and platform accessibility guidelines on mobile: keyboard operability, visible focus, contrast ≥ 4.5:1, labels on every input, error messages tied to fields, screen-reader testing in English and Persian, and status changes announced through live regions. Truth badges and risk flags use text, not colour alone.

CHAPTER 30

Infrastructure, deployment and operations

Small, boring and portable: containers on European virtual machines, a managed or carefully run PostgreSQL, Redis, object storage and a reverse proxy. Every choice is checked against one extra question — does it still work for a visitor in Iran?

30.1 Hosting constraints discovered in research

OPTION	FINDING	CONSEQUENCE
Vercel	Users reported in 2026 that Iranian visitors receive HTTP 403, with no response from Vercel REPORTED	Do not host the customer website there
DigitalOcean	Terms say customers must not permit access by anyone located in a comprehensively sanctioned region DOCUMENTED	Not suitable
Hetzner	Terms restrict the customer's own export compliance; some German Hetzner IP ranges were blocklisted by large clouds in 2024 over sanctions evasion REPORTED	Possible; prefer a non-German region and test reputation of assigned IPs
OVHcloud	Sanctions terms not verified UNKNOWN	Possible after terms review
Cloudflare (CDN/proxy)	Terms bind the customer; Cloudflare data show it serves Iranian traffic, though it has no equipment in Iran INFERRED	Test before relying on it; keep the origin reachable directly as a fallback
Google Maps, reCAPTCHA, Fonts	Maps lists Iran as a prohibited territory; others unreliable DOCUMENTED	Self-host fonts; no Google Maps; self-hosted proof-of-work challenge

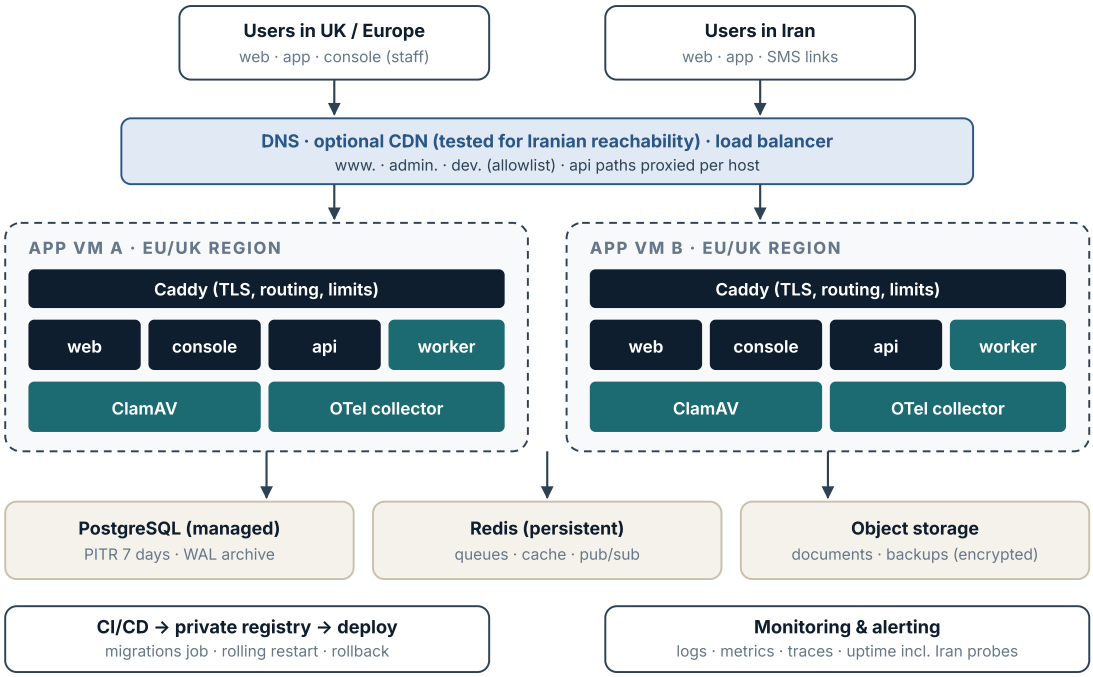
COUNSEL AND VENDOR REVIEW

Hosting, CDN, email, SMS and push vendors each have terms on sanctioned countries, and OFAC guidance treats communications services differently from other software. Before contracting, have counsel review each vendor's terms against Uni Travel's activities; the decision record goes in `docs/vendors.md`.

30.2 Environments

ENVIRONMENT	PURPOSE	DATA	PROVIDERS
Local	Development	Seeded fake data	Fake supplier adapter, console SMS sink
Staging	Integration, UAT, release candidate	Synthetic data only	Supplier sandboxes; SMS to staff test numbers only
Production	Live	Real	Production contracts

30.3 Deployment topology PROPOSED



Outbound calls from both VMs: flight suppliers, SMS routes, push and email providers, sanctions-list downloads.

Figure 30.1 — Production deployment. Two application VMs give redundancy for stateless services; the database is managed or runs on a dedicated VM with streaming backups.

COMPONENT	PRODUCTION V1	SCALING PATH
Reverse proxy	Caddy (automatic TLS) on each app VM, behind a load balancer or DNS failover	Managed load balancer
`web`, `console`, `api`	Docker containers on two app VMs (2 replicas each)	More VMs; later a container orchestrator if justified
`worker`	One container per app VM; queues shared through Redis	Separate worker VM; per-queue concurrency
PostgreSQL	Managed PostgreSQL in an EU/UK region, or a dedicated VM with WAL archiving	Read replica for reporting
Redis	Managed Redis with persistence, or a dedicated container with AOF	Separate instances for cache and queues
Object storage	S3-compatible bucket in the same region	—
Virus scanning	ClamAV container used by `documents.scan`	—

No microservices, service mesh or Kubernetes are proposed for v1; the topology runs on Docker Compose and can move to managed containers later without code changes.

30.4 CI/CD

1. **Pull request**: type-check, lint (with module boundary rules), unit and integration tests (Testcontainers), contract tests with supplier fixtures, OpenAPI diff, dependency and secret scanning, build images.
2. **Merge to main**: images pushed to a private registry tagged with the commit SHA; automatic deploy to staging; database migrations run as a one-off job before the new containers start; smoke tests.

3. **Release**: manual promotion of the staging-verified image to production; migrations first (expand), then rolling restart; a post-deploy check of health endpoints and key flows; one-command rollback to the previous image.
4. **Mobile**: store builds per release; over-the-air updates only for JavaScript fixes that do not change permissions or security behaviour.

30.5 Observability

SIGNAL	TOOLING PROPOSED	WHAT TO WATCH
Logs	Pino JSON → log store (self-hosted Loki or an EU-hosted service)	Errors by module; redaction verified
Metrics	OpenTelemetry → Prometheus-compatible store; Grafana dashboards	Request rate/latency/errors; queue depth and age; supplier latency and errors; SMS delivery rate per route; OTP conversion per country
Traces	OpenTelemetry traces across api → worker → supplier	Slow searches; failing adapters
Errors	Sentry-compatible error tracking (self-hosted GlitchTip or an EU-region service)	New error types after a release
Uptime	External checks from the UK, EU and, if possible, probes inside Iran (e.g. RIPE Atlas)	Reachability for Iranian users is a first-class SLO

Service-level objectives (initial)

SLO	TARGET
API availability (monthly)	99.5%
Search first results within 8 s	95% of searches
OTP SMS handed to provider within 3 s	99%
Notification of new request to on-duty admins within 60 s	99%
Outbox events dispatched within 5 s	99%

30.6 Backups and recovery

- PostgreSQL: nightly full backup plus continuous WAL archiving to encrypted object storage; point-in-time recovery for 7 days; daily backups for 35 days.
- Object storage: versioning on; lifecycle rules for retention (Chapter 28).
- Redis: persistence for queues; no backup needed for caches.
- **Restore test monthly** into a scratch environment, timed and recorded. Targets: RPO ≤ 15 minutes, RTO ≤ 4 hours.

30.7 Runbooks (to be written in Stage 6)

RUNBOOK	TRIGGER
Supplier outage	Circuit breaker open > 15 min
SMS route failure	Delivery rate < 80% for a route over 30 min
OTP abuse spike	Sends per country > 3× baseline, or conversion collapse
Queue backlog	Oldest job age > 2 min on a critical queue

RUNBOOK	TRIGGER
Database degradation	p95 query time > 200 ms or connections > 80%
Iranian reachability loss	External probes from Iran fail; check CDN, IP reputation, and whether a national shutdown is in progress
Security incident	Suspected breach; includes ICO 72-hour notification steps
Sanctions list ingestion failure	Sync failed twice in a row

PART E

E

Delivery

The staged roadmap, testing and quality, risks, open questions, the working playbook for Claude Code, reference tables and sources.

31	Delivery roadmap	121
32	Testing and quality	124
33	Risk register	127
34	Open questions and unknowns	128
35	Implementation playbook for Claude Code	130
36	Reference	133
37	Sources	136

CHAPTER 31

Delivery roadmap

Eight delivery stages, from contracts and discovery to launch and beyond. The order delivers value early: a staffed manual-request service goes live before the search engine, so Uni Travel can serve customers while supplier contracts are still being negotiated.

31.1 Stages at a glance

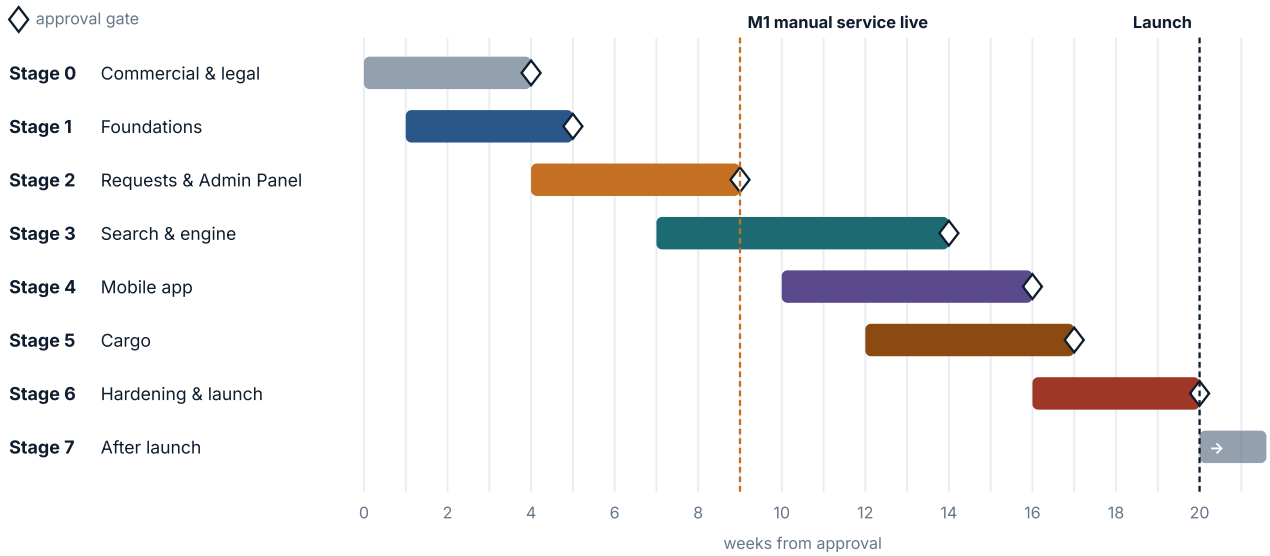


Figure 31.1 — Indicative plan for a team of two to three full-stack developers working with Claude Code, plus part-time design and QA. Weeks are from approval of this booklet. Stage 0 runs in parallel with engineering.

Delivery stages are distinct from the project's approval phases (Chapter 2): this whole roadmap sits inside project phases 5 and 6, and every stage ends with a demonstration and an approval gate before the next stage starts.

31.2 Stage 0 — Commercial, legal and discovery (weeks 0–4, parallel)

WORKSTREAM	DELIVERABLE
Amadeus	Read-only discovery of the Flight Builder panel (outstanding project phase 1); Enterprise API questions answered (Chapter 6); contract and sandbox, or a decision to use an alternative GDS
Duffel	Test account; written confirmation that the customer profile is acceptable
Counsel	Answers to the questions in Chapter 4; initial carrier policy list; ATOL mode; cargo lanes position
Vendors	SMS routes (+98 and international), email, hosting region; sanctions clauses reviewed
Data protection	ICO registration; DPIA started; processor agreements
Product	Brand assets; Persian copy owner; business hours and team rota for SLA settings

Gate: counsel's written position on D-01, payments/ATOL and cargo; at least one flight provider with sandbox access.

31.3 Stage 1 — Foundations (weeks 1–5)

Monorepo and CI; staging environment; `identity` (phone and email OTP, sessions, devices), `access` (roles, permissions, `perm_version`), `audit`, `config` (settings, flags, versioned config), `reference` data, `notifications` core (inbox, SMS router with both routes, templates), Developer Panel sections 1, 7, 8, 9, 10 (users and roles, auth settings, audit, diagnostics, settings).

Exit criteria: a customer can sign up with a +98 or +44 number in English or Persian; an owner can promote that user to admin and the user's next call reflects it; every route passes the fail-closed permission test; audit entries for all of the above.

31.4 Stage 2 — Requests and Admin Panel (weeks 4–9)

`customers` (travellers, encrypted documents), `requests` (manual requests first, state machine, assignment, notes, messages, contact log, quotes), `bookings` and `payments` (recording, ATOL mode), `compliance` (list ingestion, party screening, cases), timers and SLA, Admin Panel (queues, request detail, quote builder, record dialogs, compliance cases), customer request tracking on the website.

Milestone M1 — manual request service live (week 9): customers submit manual flight requests on the website; staff work them end-to-end in the console; notifications by SMS and inbox. This can launch to a pilot group while search is built.

31.5 Stage 3 — Search and itinerary engine (weeks 7–14)

Supplier framework, Duffel adapter, Amadeus adapter (as soon as the contract allows; otherwise behind a flag), `packages/engine` (through, self-transfer, gateway; validation; scoring; diversity), search job and progressive results, itinerary detail, offer snapshots and revalidation, staff search with "add to quote", hubs/gateways and rule editor with simulation in the Developer Panel, view-only seat maps for Duffel offers.

Exit criteria: engine property tests green; for a fixed set of benchmark queries (Tehran, Tabriz, Mashhad → London, Manchester, Frankfurt), results match expectations reviewed by operations; p95 first results < 8 s in staging; no result ever shows a blocked carrier.

31.6 Stage 4 — Mobile app (weeks 10–16)

Expo app with customer mode (search, requests, cargo later, inbox, account) and admin mode (queue, detail, claim, call, note, message); SecureStore auth; persisted cache; push via Expo; **pilot of a non-FCM push provider for Android users in Iran**; deep links from SMS; store submissions and a direct-download build.

Exit criteria: promotion to admin switches the app to admin mode without reinstalling; Persian RTL screens pass review; push or SMS reaches test devices in the UK and (where testers are available) in Iran.

31.7 Stage 5 — Cargo (weeks 12–17)

`cargo` module (requests, items, pieces, lanes, partners, service-availability register, partner bookings, tracking), goods screening rules, cargo forms on web and app, cargo queue and detail in the Admin Panel.

Exit criteria: lanes respect their configuration (Iran lanes disabled until enabled by owner and compliance); prohibited goods auto-decline; review categories create compliance cases; AWB validation; tracking timeline visible to customers.

31.8 Stage 6 — Hardening, pilot and launch (weeks 16–20)

Independent penetration test and fixes; load tests (search and queues); compliance matcher evaluation; accessibility review; runbooks; backup restore drill; DPIA finalised; UAT with admins; pilot with a limited customer group; production launch.

Gate: zero open critical or high security findings; SLOs met in staging under load; counsel sign-off on launch configuration; owner approval.

31.9 Stage 7 — After launch

CANDIDATE	DEPENDS ON
Automated reservations and ticketing through provider order APIs (Duffel orders; Amadeus PNR/ticketing)	Contracts, ATOL mode, operational confidence
Online payments with a provider that accepts the customer base	Counsel and provider approval
Schedules and MCT data (OAG or Cirium) for hub discovery	Contract; engine evidence that it improves results
Timatic document checks	Licence availability for agencies
More providers (Travelfusion, NDC aggregators)	Coverage gaps observed in Stage 3 metrics
Ground tickets for gateway access	A change to Decision D-04 and counsel's view

CHAPTER 32

Testing and quality

Tests are weighted towards where mistakes are most expensive: the state machines, the itinerary engine, permissions and compliance. Every layer has an automated suite in CI, and a few things — penetration testing, the compliance matcher and usability in Persian — get dedicated human review.

32.1 Test layers

LAYER	SCOPE	TOOLS PROPOSED	RUNS
Unit	`packages/domain`, `packages/engine`, pure helpers, mappers	Vitest	Every commit
Property-based	Engine invariants; state-machine invariants	Vitest + fast-check	Every commit
Integration	Repositories, commands in transactions, outbox, queues	Vitest + Testcontainers (PostgreSQL, Redis)	Every PR
Contract	Supplier adapters against recorded fixtures; SMS/push/email adapters against fakes	Vitest	Every PR
API	Endpoints, validation, error codes, permission matrix	Vitest + supertest against the Nest app	Every PR
End-to-end (web, console)	Critical journeys in English and Persian	Playwright	Every PR (smoke), nightly (full)
End-to-end (mobile)	Sign-in, search, request, admin mode switch	Maestro on emulators	Nightly, before release
Performance	Search fan-out, API queues, notification throughput	k6	Weekly in staging, before launch
Security	Dependency audit, secret scan, SAST, DAST (OWASP ZAP), external penetration test	CI tools + specialist firm	Every PR / before launch
Accessibility	Automated checks + manual screen-reader passes	axe, Playwright, VoiceOver/TalkBack	Every PR (auto), per release (manual)

32.2 Invariants tested by property

The engine and state machines lend themselves to property-based testing: generate thousands of random but valid inputs and check that rules always hold.

INVARIANT	GENERATOR
Every self-transfer connection's layover ≥ the resolved minimum and ≤ the maximum	Random leg offers across time zones, including date-line and DST changes
No returned itinerary contains a blocked carrier (marketing or operating)	Random offers with random carrier codes and random policy sets
Score is monotonic: making only the price higher never improves rank	Pairs of itineraries differing in one component
Deduplication is idempotent and order-independent	Shuffled result sets with duplicates

INVARIANT	GENERATOR
A request can never reach `TICKETED` without one `ISSUED` ticket per traveller	Random sequences of commands
A request can never be shown as reserved without an active reservation record	Random command sequences
Payment status equals the computed sum of verified records	Random payment record histories
Customer serialisers never emit internal fields	Random aggregates through customer schemas

32.3 Permission matrix tests

A generated suite reads the permission catalogue and the route table and, for every route and every built-in role, asserts the expected `2xx`, `403` or `404`. Adding a route without a permission declaration fails the build. Ownership tests create two customers and assert neither can read the other's requests, travellers or documents by id or reference.

32.4 Benchmark queries

Operations staff maintain a set of benchmark searches (for example Tehran → London, Tabriz → Manchester, Mashhad → Frankfurt, Yerevan → London) with expected properties: at least one gateway result, no blocked carriers, self-transfers flagged, layovers inside configured bounds. They run nightly in staging against sandbox suppliers and recorded fixtures; a change in the results is reviewed, not automatically accepted.

32.5 Compliance matcher evaluation

Before launch, the name matcher is evaluated on a labelled set: true list entries in several transliterations, common Iranian names that are not on lists, and near misses. Targets `PROPOSED`: recall ≥ 0.98 on true matches at the review threshold, and a false-positive rate that keeps the compliance queue workable (agreed with the compliance officer). Thresholds and the equivalence table are tuned against this set and re-evaluated after each change.

32.6 Test data

- No real customer data outside production. Staging uses synthetic customers with clearly fake passport numbers and phone numbers routed to a staging SMS sink or staff test devices.
- Supplier fixtures are scrubbed of names and contact details before being committed.
- The fake supplier adapter produces labelled `FAKE` offers and is blocked in production (Chapter 21).

32.7 User acceptance

Admins run scripted scenarios in staging before each stage gate: manual request end to end; quote with unknown baggage (must be blocked); reservation deadline alerts; payment above the four-eyes threshold; compliance hold and release; promotion to admin on mobile; cargo with a prohibited item; Persian UI walk-through by a native speaker.

32.8 Definition of done (per story)

1. Acceptance criteria met and demonstrated.
2. Unit and integration tests added; property tests where an invariant exists.
3. Permission and ownership checks covered by tests.

4. Customer-facing copy present in English and Persian; RTL checked.
5. Audit entries for state changes; logs free of personal data.
6. OpenAPI updated; no unapproved breaking change.
7. Feature flag or configuration documented if added.
8. Reviewed by another developer.

CHAPTER 33

Risk register

The biggest risks are external — sanctions, supplier terms, a corridor that keeps changing — not technical. The register below ranks them and names the mitigation already designed into the platform.

ID	RISK	L	I	MITIGATION	OWNER
R-01	A sale, payment or partner chain breaches UK sanctions or attracts US secondary sanctions	M	H	Counsel review before launch (Ch. 4); carrier, route, party and goods screening; holds and four-eyes overrides; evidence retention (Ch. 27)	Owner + compliance
R-02	Amadeus or Duffel declines the customer profile or restricts Iran-origin content	M	H	Early, honest disclosure in Stage 0; adapter framework allows alternatives (Sabre, Travelport, aggregators); manual-request service works without any provider	Owner
R-03	Very few compliant flights from Iran; the engine finds little	H	M	Gateway starts; manual requests as a first-class path; hub configuration updated weekly by operations	Operations
R-04	Corridor changes overnight (new suspensions or resumptions)	H	M	Hubs, gateways and access notes are configuration with `active` flags; status page and banner text editable without deploys	Operations
R-05	SMS to Iran fails (shutdown, regulator restrictions, provider issues)	M	H	Two Iranian routes; email fallback; in-app inbox; alternative contact on requests; delivery monitoring and alerts	Developers
R-06	Contracting or paying an Iranian SMS provider is not permissible	M	H	Counsel question 5; fallback to an international provider that serves +98 if one exists; otherwise phone OTP for +98 users becomes staff-assisted verification	Owner
R-07	Hosting, CDN or app store blocks Iranian users	M	M	Vendor choices tested for reachability; probes from Iran; mobile web as the guaranteed channel; direct APK	Developers
R-08	OTP abuse (SMS pumping) drives cost	M	M	Country allowlist, layered rate limits, proof-of-work challenge, conversion monitoring, spend cap (Ch. 25)	Developers
R-09	Customers misunderstand a request as a booking	M	H	Explicit acknowledgements, status wording derived from records, "requesting does not book a seat" copy, ATOL mode defaulting to payment at ticketing	Product
R-10	Self-transfer itineraries leave customers stranded	M	H	Long minimum layovers, risk flags, mandatory acknowledgement, staff confirmation of entry requirements	Operations
R-11	Passport or personal data breach	L	H	Field-level encryption, least privilege, audit of reveals, penetration test, incident runbook (Ch. 28)	Developers
R-12	False positives in name screening overwhelm staff; false negatives miss a designated person	M	M	Layered matcher with secondary identifiers; labelled evaluation set; tunable thresholds; reviewer guidance	Compliance
R-13	Supplier costs grow with searches (look-to-book)	M	M	Leg cache, per-search call caps, daily budgets, anonymous search limits	Developers
R-14	Stack additions (Expo, Turborepo, etc.) are not approved	L	M	Each addition is isolated and listed as a proposal (D-06); alternatives exist within the Kit's constraints	Owner
R-15	Cargo lanes cannot be opened lawfully or no partner is viable	M	M	Cargo module ships with lanes disabled; value from UK–Türkiye and other lanes; partner register	Owner
R-16	Small team, broad scope; schedule slips	M	M	Staged delivery with an early manual-service milestone; Claude Code playbook; scope gates	Owner

L = likelihood, I = impact (L/M/H). Review at every stage gate.

CHAPTER 34

Open questions and unknowns

Everything this booklet could not verify, and every decision still owed, in one place. Each item names who can answer it and which part of the design it unblocks.

34.1 Decisions owed by Uni Travel

#	QUESTION	DEFAULT USED IN THIS BOOKLET	UNBLOCKS
U-1	Attach the Engineering Kit, or confirm the recorded stack; approve or reject each proposed addition (Chapter 18)	Recorded stack + proposals	Stage 1
U-2	Company details: registration, IATA status, ATOL position, Amadeus office ID	UK Ltd, Amadeus agency, no ATOL	Chapters 4, 6, 27
U-3	Target markets and first destinations	UK, then DE/NL/FR	Hub tables, provider markets
U-4	Service fee policy (fixed, percentage, per traveller) and quote currency	GBP; fee entered per quote	Quote builder
U-5	Business hours and staffing across UK and Iran time zones	09:00–18:00 London and 09:00–17:00 Tehran	SLA timers
U-6	Brand assets, Persian copy owner, tone of voice	Neutral	Stage 1 design
U-7	Who holds the compliance-officer role	—	Stage 2

34.2 Questions for counsel

The ten questions in Chapter 4 (§4.8), covering itinerary sales, carrier lists, payments, Iranian SMS providers, ATOL mode, cargo brokering and personal effects, screening standards, vendor terms and consumer law.

34.3 Questions for providers

PROVIDER	QUESTIONS
Amadeus UK	The six questions in Chapter 6: available Enterprise APIs, commercial terms, display rights, sanctions terms, Flight Builder API, sandbox and certification
Duffel	Acceptability of the customer profile; airline coverage for the gateway and hub routes; seat-map coverage for those airlines; sanctions clauses in the services agreement
SMS (+98)	Whether a UK company can contract; payment route; template approval times; delivery-report formats; price per segment
SMS (international)	Whether +98 is supported; sanctions terms in writing; OTP products; EU data residency
Push (non-FCM)	Delivery inside Iran in practice; data processing terms
App stores	Cafe Bazaar and Myket requirements for a foreign publisher; Android developer verification timeline for the UK account

34.4 Research unknowns

TOPIC	UNKNOWN	HOW TO RESOLVE
Amadeus	Enterprise API catalogue and seat map availability for the contract; MCT handling	Account manager
Flight Builder	Whether any API exists	Stage 0 read-only discovery and Amadeus
Duffel	Sanctions terms; airline list	Duffel onboarding
Coverage	Whether Iraqi Airways and SalamAir Iran services appear in Amadeus or Duffel content	Sandbox searches in Stage 0
Gateways	Current timetables from Van, Erzurum and Yerevan (research used press and reference sources)	Supplier searches
Push	APNs reachability inside Iran; Pushy delivery in Iran	Stage 4 pilot
SMS	Iranian providers' terms for foreign customers; prices	Vendor contact via counsel-approved route
Hosting	OVHcloud sanctions terms; whether Vercel's 403s are deliberate; Cloudflare Turnstile reachability	Vendor terms review; reachability tests
Cargo	Current DHL, UPS and Aramex Iran status; whether any UK freight firm can lawfully carry to Iran today	Partner due diligence
Law	Exact goods lists in SI 2026/983 schedules; personal-effects exception for unaccompanied baggage; brokering status	Counsel
Timatic	Agency eligibility and price for AutoCheck or the widget	IATA
Schedules	OAG and Cirium pricing	Vendors (only if Stage 7 needs them)

CHAPTER 35

Implementation playbook for Claude Code

How the build should run day to day: the project rules Claude Code must follow, how work is sliced into epics and stories, and what the first two sprints contain. Paste the rules section into the repository's `CLAUDE.md`.

35.1 Rules of engagement

PROJECT RULES (CARRY INTO CLAUDE.MD)

1. **Stack.** Use only the Engineering Kit stack and approved additions (Chapter 18). Never introduce ASP.NET/.NET/C#, Python/FastAPI, Flutter, microservices or extra infrastructure without a stated requirement and the owner's approval.
2. **Data integrity.** Never display fabricated, scraped or unverified flights as options. No scraping, no undocumented endpoints, no bypassing authentication, bot detection or rate limits. Fake data only through the `FAKE` adapter, which must stay blocked in production.
3. **Truth model.** Keep search result, offer snapshot, request, quote, reservation, ticket and payment separate. Never infer baggage or fare conditions. Payment success never implies a booking.
4. **Authority.** All permission and state decisions live in the backend. Every protected route declares a permission; ownership is checked on every customer lookup.
5. **Compliance.** Do not weaken or bypass carrier, party, goods or lane policies in code. Policy changes are data, made by authorised staff.
6. **Secrets.** Credentials never appear in code, commits, logs, fixtures or reports.
7. **Evidence labels.** When reporting findings, label them OBSERVED, DOCUMENTED, INFERRED, UNKNOWN or BLOCKED.
8. **Discovery.** Discovery tasks (such as the Amadeus panel) are read-only: no form submissions, bookings, payments or installs.
9. **Gates.** After each stage deliverable, stop, summarise and wait for approval. Never auto-continue into the next stage.
10. **Change control.** Any deviation from this booklet gets a short ADR in `docs/adr/` before code.

35.2 Working method

- Work story by story, each on a short-lived branch, each ending in a PR with tests and a demo note.
- Start each story by writing or updating the Zod contract and the tests for invariants (state machines, engine), then implement.
- Prefer small vertical slices (API + console screen + tests) over horizontal layers.
- Keep `packages/domain` and `packages/engine` free of framework imports; review boundary-rule violations as bugs.
- Update the OpenAPI document, the permission catalogue and the Persian/English message catalogues in the same PR as the code.

35.3 Epics

EPIC	STAGE	SCOPE	KEY ACCEPTANCE
E1 Platform foundations	1	Monorepo, CI, environments, logging, config, flags, audit	CI green on all checks; staging deploy from main
E2 Identity and access	1	OTP (two SMS routes), email OTP, sessions, devices, roles, permissions, `perm_version`, staff MFA, step-up	Promotion/demotion effective on next call; abuse limits enforced
E3 Developer Panel core	1	Users and roles, auth settings, audit, diagnostics, settings and flags	All changes versioned and audited
E4 Notifications	1–2	Inbox, routing, templates EN/FA, SMS/push/email adapters, delivery webhooks	Escalation and throttling rules tested
E5 Customers and travellers	2	Profiles, travellers, encrypted documents, reveal audit	No passport number in logs or responses except reveal
E6 Flight requests	2	Manual request, state machine, assignment, notes, messages, contact log, SLA timers	All Table 13.1 guards tested
E7 Quotes, records, payments	2	Quote builder, reservations, tickets, payments, ATOL mode	Unknown baggage blocks sending; payment four-eyes
E8 Compliance	2–3	List ingestion, matcher, cases, policies, carrier filtering hook	Matcher evaluation targets met
E9 Admin Panel	2	Queues, request detail, compliance cases	UAT scenarios pass
E10 Supplier framework	3	Adapter interface, Duffel adapter, Amadeus adapter, fixtures, health, budgets	Contract tests and nightly smoke
E11 Itinerary engine	3	Normalise, plan, fan-out, filter, join, validate, score, diversify, publish	Property tests and benchmark queries
E12 Search UX	3	Search form, progressive results, detail, snapshot, revalidation, seat maps (view-only)	First results < 8 s p95
E13 Engine configuration	3	Rule editor, hubs and gateways, simulation, publish/rollback	Simulation uses cached data only
E14 Mobile app	4	Customer and admin modes, push, deep links, distribution	Admin mode switch without reinstall
E15 Cargo	5	Cargo module, lanes, partners, availability register, tracking	Lane and goods rules enforced
E16 Hardening and launch	6	Pen test, load test, runbooks, DPIA, UAT, pilot	Launch gate criteria

35.4 Sample stories with acceptance criteria

ID	STORY	ACCEPTANCE CRITERIA
E2-S3	As a customer in Iran, I can sign in with my +98 number	Code delivered via the +98 route; 6 digits, 5-minute expiry, 5 attempts; generic error on failure; challenge after 3 requests per IP in 10 min; identity marked verified with timestamp
E2-S7	As an owner, I can promote a customer to admin	Requires `user.role.assign`; step-up not needed for `admin`; `perm_version` increments; audit entry; the user's next API call returns `401 PERMISSIONS_CHANGED`; after refresh, `/me` lists admin permissions

ID	STORY	ACCEPTANCE CRITERIA
E6-S2	As a customer, I can submit a manual flight request	Requires verified phone; idempotent with `Idempotency-Key`; reference `UT-F-XXXXXX` returned; status `SUBMITTED` then `NEW` after screening; SMS confirmation with reference
E7-S1	As an admin, I can send a quote	Command allowed only in `IN_REVIEW`; every option needs known baggage and conditions; validity in the future; status `QUOTED`; customer notified by push and SMS; previous quote superseded
E8-S4	As a compliance officer, I can release a held request	Requires `compliance.case.decide`; reason mandatory; decision immutable; request moves to `NEW`; admins notified
E11-S5	As a customer, I see self-transfer options via a hub	Only when allowed by preferences and rules; every connection ≥ resolved minimum; flags shown; acknowledgement required on request
E14-S6	As an admin on mobile, I am told about new requests	On-duty admins receive push within 60 s; tapping opens the request; claim works offline-tolerantly (retries)
E15-S3	As a customer, I cannot send prohibited goods	Prohibited category or keyword declines with a neutral message; review categories create a compliance case; no quote possible until released

35.5 Sprint 1 and 2 (two weeks each)

SPRINT	STORIES
1	Monorepo scaffold (apps, packages, lint rules, CI); Drizzle setup and first migrations (users, identities, roles, audit, settings, outbox); NestJS skeleton with global guards and problem responses; OTP request/verify with a console SMS sink; Next.js web and console shells with locale routing and RTL; Developer Panel sign-in
2	Real SMS routes (+98 and international) behind config; email OTP; sessions, refresh rotation, device registry; roles and permission catalogue; `perm_version` mechanism; staff TOTP/passkey; Developer Panel users and roles; audit viewer; fail-closed route test; staging deployment

At the end of sprint 2, demonstrate: sign-up in Persian with a +98 test number, promotion to admin, the audit trail of both, and the permission test failing when a route lacks a declaration.

CHAPTER 36

Reference

Glossary, configuration keys with their defaults, and environment variables — the lookup tables developers and operations staff will need most.

36.1 Glossary

TERM	MEANING
ADR	Architecture Decision Record — a short document explaining a design decision
AWB	Air waybill — the transport document and 11-digit tracking number for air cargo
APNs / FCM	Apple Push Notification service / Firebase Cloud Messaging (Google)
ATOL	Air Travel Organiser's Licence — UK financial-protection scheme for air travel sales, administered by the CAA
BSP	IATA Billing and Settlement Plan — how agents settle ticket sales with airlines
CASS	IATA Cargo Account Settlement System
Gateway	An airport outside the customer's origin country from which the itinerary starts, reached overland
GDS	Global distribution system (Amadeus, Sabre, Travelport)
Hub	An airport where the engine joins two separately priced flights into a self-transfer
IATA code	Two-letter airline or three-letter airport/city code
Leg	One offer covering origin → hub or hub → destination, used to build self-transfers
MCT	Minimum connection time — the shortest legal connection at an airport
NDC	IATA New Distribution Capability — standard for airline retailing APIs
Offer	A priced, sellable itinerary from a supplier, valid until it expires
Offer snapshot	Immutable copy of the itinerary a customer chose, stored with the request
OTP	One-time password (here, a 6-digit code)
PNR / record locator	Passenger name record / its 6-character booking reference
Quote	Priced options prepared by staff with confirmed baggage and conditions and an expiry
Rung	Level on the truth ladder (Chapter 18)
SDN	OFAC Specially Designated Nationals and Blocked Persons list
Self-transfer	A connection between separately ticketed flights; the traveller re-checks bags and bears missed-connection risk
Slice / segment	A directional journey / a single flight within it
SSR	Special service request (e.g. wheelchair, meal)
Ticket number	13 digits: 3-digit airline accounting code + 10-digit serial
Truth badge	UI label that shows where a price or status came from and when

36.2 Configuration keys (defaults)

KEY	DEFAULT	CHAPTER
`auth.otp.length` / `auth.otp.ttl_seconds` / `auth.otp.max_attempts`	6 / 300 / 5	25
`auth.otp.resend_cooldown_seconds` / `auth.otp.max_per_hour` / `auth.otp.max_per_day`	60 (doubling) / 5 / 10	25
`auth.otp.allowed_countries`	IR, GB, EU/EEA, TR, AM, GE, AE	25
`auth.challenge.after_requests_per_ip_10min`	3	25
`auth.require_verified_phone_for_requests`	true	11
`auth.access_ttl_seconds` / `auth.refresh_ttl_days` / `auth.staff_session_hours`	600 / 30 / 12	25
`auth.stepup_window_minutes`	10	16
`search.deadline_first_wave_ms` / `search.deadline_total_ms`	12000 / 25000	21–22
`search.max_supplier_calls` / `search.max_hubs` / `search.max_offers_per_leg`	24 / 4 / 25	22
`search.leg_cache_ttl_seconds`	600	22
`search.max_results`	60	22
`search.self_transfer.enabled` / `search.gateways.enabled`	true / true	22
`engine.rules.global` (selfTransferMinMin, preferredLayover, maxLayoverMin, …)	Table 22.1	22
`engine.weights`	price .35 · duration .20 · layoverFit .15 · risk .20 · stops .05 · timeOfDay .05	22
`requests.revalidate_on_submit`	true	11
`requests.sla.unassigned_minutes` / `requests.sla.first_contact_minutes`	30 / 120	13
`quotes.default_validity_hours` / `quotes.max_options`	24 / 5	13
`payments.four_eyes_threshold_minor`	100000 (GBP 1,000)	13
`atol.mode`	PAY_ON_TICKETING	27
`notifications.quiet_hours` / `notifications.sms_daily_cap`	22:00–08:00 / 6	17
`cargo.reweigh_tolerance_pct`	5	14
`cargo.availability_stale_days`	30	14
`compliance.match_threshold` / `compliance.review_threshold`	Tuned on evaluation set	27
`compliance.lists_sync_hours`	6	27
`seatmaps.enabled` / `payments.online.enabled` / `cargo.enabled`	false / false / true	7, 4, 14

36.3 Environment variables

VARIABLE	USED BY	NOTES
`DATABASE_URL`	api, worker, migrate	TLS required outside a single host
`REDIS_URL`	api, worker	AOF persistence on
`JWT_PRIVATE_KEY` / `JWT_PUBLIC_KEYS`	api	Key rotation with overlap
`MASTER_ENCRYPTION_KEY`	api, worker	Envelope encryption root key; never in the database
`OTP_PEPPER`	api	HMAC key for codes
`OBJECT_STORAGE_*`	api, worker	Bucket, region, credentials
`APP_ENV`	all	`local`, `staging`, `production` — production refuses the fake adapter
`PUBLIC_WEB_URL` / `PUBLIC_CONSOLE_ADMIN_URL` / `PUBLIC_CONSOLE_DEV_URL`	all	Link building, cookie scoping
`OTEL_EXPORTER_OTLP_ENDPOINT`	all	Telemetry
`CLAMAV_HOST`	worker	Virus scanning

Provider credentials (Amadeus, Duffel, SMS, push, email) are **not** environment variables: they are entered in the Developer Panel and stored encrypted (Chapter 28), so they can be rotated without redeploying.

CHAPTER 37

Sources

Sources consulted between 12 and 22 October 2026. Press and reference sources are labelled "Reported" in the text; vendor documentation and government publications "Documented". Links may change; verify before relying on them.

37.1 Corridor, airlines and aviation sanctions

- Iran International — US sanctions all Iranian airlines in sweeping aviation crackdown (8 Sep 2026): https://www.iranintl.com/en/202609086215
- Iran International — Iranian airlines continue foreign flights after US sanctions deadline (23 Sep 2026): https://www.iranintl.com/en/202609234668
- Al Jazeera — US aviation sanctions disrupt Iran flights, push travellers overland (23 Sep 2026): https://www.aljazeera.com/news/2026/9/23/us-aviation-sanctions-disrupt-iran-flights-push-travellers-overland
- Middle East Eye — Turkish Airlines, Pegasus and AJet cancel Iran flights as US sanctions bite (21 Sep 2026): https://www.middleeasteye.net/news/turkish-airlines-pegasus-and-ajet-cancel-iran-flights-us-sanctions-bite
- bianet — Turkey's major airlines suspend flights to Iran after US sanctions move: https://bianet.org/haber/turkeys-major-airlines-suspend-flights-to-iran-after-us-sanctions-move-323677
- Turkish Minute — Turkish carriers remove Iran flights from schedules into 2027: https://www.turkishminute.com/2026/09/22/turkish-carriers-remove-iran-flights-from-schedules-into-2027-amid-us-sanctions/
- AGBI — US sanctions Iranian airlines in financial crackdown (9 Sep 2026): https://www.agbi.com/aviation/2026/09/us-sanctions-iranian-airlines-in-financial-crackdown/
- The Tribune / ANI — US sanctions 27 Iranian airlines: https://www.tribuneindia.com/news/iran-airlines-sanctions/us-sanctions-27-iranian-airlines-with-third-country-firms-targeted
- FDD — U.S. sanctions on Iranian aviation (GL J-1 suspension): https://www.fdd.org/analysis/2026/09/10/u-s-sanctions-on-iranian-aviation-should-be-followed-by-operational-isolation/
- Holland & Knight — OFAC suspends General License J-1: https://www.hklaw.com/en/insights/publications/2026/09/ofac-suspends-general-license-j-1-and-grounds-irans-aviation-sector
- HSF Kramer — OFAC targets Iran's aviation sector: https://www.hsfkramer.com/fr/notes/sanctions/2026-posts/ofac-targets-irans-aviation-sector-under-operation-economic-outcast
- Report.az / ednews — International flights resume at Tehran IKA (8 Oct 2026): https://report.az/en/other-countries/international-flights-resume-at-tehran-s-imam-khomeini-airport
- The New Arab — Iraqi Airways resumes Najaf–Tehran flights: https://www.newarab.com/news/iraqi-airways-resumes-najaf-tehran-flights-after-suspension
- WANA — Foreign airlines resume flights to Iran (SalamAir): https://wanaen.com/us-air-sanctions-hit-a-dead-end-as-foreign-airlines-resume-flights-to-iran/
- Shafaq News — Iran to resume international flights after war shutdown (Apr 2026): https://shafaq.com/en/Middle-East/Iran-to-resume-international-flights-after-war-shutdown
- IranWire — Flight to Iraq is the main news in Iran (Oct 2026): https://iranwire.com/en/features/158632-flight-to-iraq-is-the-main-news-in-iran/
- ch-aviation — EU sanctions IranAir, Mahan Air, Saha Airlines: https://www.ch-aviation.com/news/145767-eu-sanctions-iranair-mahan-air-saha-airlines
- Gherson — UK adds Iran Air to sanctions list: https://www.gherson.com/blog/uk-government-adds-two-entities-to-iran-sanctions-list-and-issues-new-general-licence/
- Euronews — Turkey–Iran border crossing truck delays (24 Sep 2026): https://www.euronews.com/2026/09/24/turkey-iran-border-crossing-hit-by-severe-truck-delays
- Reference pages on gateway airports (Istanbul, Sabiha Gökçen, Van, Erzurum, Zvartnots), Wikipedia, accessed Oct 2026

37.2 UK sanctions, trade controls and regulation

- GOV.UK — Iran sanctions guidance (updated 9 Sep 2026): https://www.gov.uk/government/publications/iran-sanctions-guidance/iran-sanctions-guidance

- GOV.UK — Notice to exporters 2026/18, Iran sanctions amendments effective 29 Sep 2026: https://gov.uk/government/publications/notice-to-exporters-202618-iran-sanctions-amendments-effective-from-29-september-2026/nte-202618-iran-sanctions-amendments-effective-from-29-september-2026
- Greenberg Traurig — UK expands Iran sanctions (Oct 2026): https://www.gtlaw.com/ar/insights/2026/10/uk-expands-iran-sanctions-what-the-2026-regulations-may-mean-for-businesses
- Aerocorner — UK Iranian cargo aircraft landing ban: https://aerocorner.com/news/uk-iran-cargo-aircraft-landing-ban/
- legislation.gov.uk — SI 2024/944 (personal-effects exception): https://legislation.gov.uk/uksi/2024/944/made
- GOV.UK — UK strategic export controls: https://www.gov.uk/guidance/uk-strategic-export-controls
- Clifford Chance — strict-liability civil penalties for UK trade sanctions: https://www.cliffordchance.com/insights/resources/blogs/regulatory-investigations-financial-crime-insights/2024/09/new-strict-liability-civil-penalties-for-u-trade-sanctions.html
- GOV.UK — The UK Sanctions List and format guide: https://gov.uk/government/publications/the-uk-sanctions-list · https://www.gov.uk/guidance/format-guide-for-the-uk-sanctions-list
- GOV.UK — Moving to a single list for UK sanctions designations: https://www.gov.uk/guidance/moving-to-a-single-list-for-uk-sanctions-designations-28-january-2026
- OFAC — Sanctions lists and data formats: https://ofac.treasury.gov/ofac-sanctions-lists · FAQ 844: https://ofac.treasury.gov/faqs/844 · FAQ 1088: https://ofac.treasury.gov/faqs/1088
- OpenSanctions — licensing and API: https://www.opensanctions.org/licensing/ · https://www.opensanctions.org/api/
- UK CAA — Do I need an ATOL? / airline ticket agents / ATOL certificates: https://www.caa.co.uk/atol-protection/atol-requirements-for-the-travel-industry/do-i-need-an-atol/ · https://www.caa.co.uk/atol-protection/atol-compliance/requirements-legal-obligations/airline-ticket-agents/ · https://www.caa.co.uk/atol-protection/trade/atol-compliance-and-regulations/atol-certificates/
- ICO — data protection fee; special category data; storage limitation: https://ico.org.uk/for-organisations/data-protection-fee/ · https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/lawful-basis/special-category-data/what-is-special-category-data/

37.3 Flight data providers

- PhocusWire — Amadeus shuts down Self-Service APIs: https://www.phocuswire.com/amadeus-shut-down-self-service-apis-portal-developers
- Amadeus — Master Pricer sales sheet: https://amadeus.com/documents/products/travel-sellers/master-pricer/Master%20Pricer_Sales%20Sheet_EN%20for%20TTIT%20report%20READY.pdf
- airQuest — company and brochure: https://airquest.com/ · https://www.airquest.com/pdf/airQuest_brochure.pdf
- Duffel — flights, pricing, getting started, seat maps, changes, cancellations: https://duffel.com/flights · https://duffel.com/pricing · https://duffel.com/docs/guides/getting-started-with-flights · https://duffel.com/docs/api/seat-maps · https://duffel.com/docs/guides/adding-seats · https://duffel.com/blog/falsehoods-about-seat-maps
- Travelport — JSON Air API endpoints: https://support.travelport.com/webhelp/jsonapis/airv11/Content/Air11/General/AirEndpointsList11.htm
- Sabre — air booking workflow and Get Seats: https://developer.sabre.com/guides/travel-agency/workflows/air-booking · https://developer.sabre.com/docs/rest_apis/air/getseats
- Kiwi.com — new approach to partnerships (May 2024): https://media.kiwi.com/articles-and-interviews/better-for-business-kiwi-com-takes-a-new-approach-to-partnerships/
- OAG — minimum connection times and Flight Info API: https://www.oag.com/minimum-connection-times · https://www.oag.com/flight-info-api
- Cirium — schedules and connections data: https://www.cirium.com/data/flight-schedules/schedules-and-connections-data
- AeroDataBox — pricing: https://aerodatabox.com/pricing/
- IATA — Timatic AutoCheck: https://www.iata.org/en/services/compliance/timatic/autocheck/
- Travelfusion, Mystifly, PKFARE, Verteil — vendor sites: https://corporate.travelfusion.com/ · https://www.mystifly.com/ · https://www.pkfare.com/ · https://verteil.com/product

37.4 Messaging, push, hosting and distribution

- Stripe — restricted and prohibited businesses: https://stripe.com/legal/restricted-businesses
- Kavenegar — Node SDK: https://github.com/kavenegar/kavenegar-node · SMS.ir REST API: https://sms.ir/rest-api/ · Ghasedak docs: https://ghasedak.me/docs
- Twilio — Iran SMS guidelines and error 21408: https://www.twilio.com/en-us/guidelines/ir/sms · https://static0.twilio.com/docs/api/errors/21408
- Vonage — countries where the API does not operate: https://api.support.vonage.com/hc/en-us/articles/22618590085148-Are-there-countries-where-Vonage-API-does-not-operate

- Sinch terms; Infobip coverage; Bird supported countries: https://sinch.com/fr/wp-json/wp/v2/legal/168366 · https://www.infobip.com/docs/essentials/sms-coverage-and-connectivity · https://bird.com/docs/knowledge-base/policies/supported-countries
- Expo — sending push notifications: https://docs.expo.dev/push-notifications/sending-notifications/ · Pushy FAQ: https://support.pushy.me/hc/en-us/articles/360043920271-Does-Pushy-depend-on-Firebase-Cloud-Messaging-
- Digiato — FCM unavailable to Iranian users (2022): https://digiato.com/article/2022/08/09/firebase-cloud-messaging-banned-in-iran-by-google
- Brevo, Mailjet, Postmark terms: https://www.brevo.com/legal/termsofuse/ · https://www.mailjet.com/legal/terms/ · https://postmarkapp.com/terms-of-service
- Vercel community threads on Iranian access; DigitalOcean terms; Hetzner terms; Cloudflare blog on Iran: https://community.vercel.com/t/request-for-temporary-access-exception-for-users-in-iran/41504 · https://www.digitalocean.com/legal/terms-of-service-agreement · https://www.hetzner.com/legal/terms-and-conditions/ · https://blog.cloudflare.com/iran-internet-partially-restored-may-2026/
- Google Maps Platform prohibited territories: https://cloud.google.com/maps-platform/terms/maps-prohibited-territories
- Filterwatch, Al Jazeera — Iran internet shutdowns 2025–2026: https://filter.watch/english/2025/06/19/network-monitoring-june-iran-internet-status-week-1-of-israel-iran-war/ · https://www.aljazeera.com/news/2026/1/17/iran-restores-sms-as-phased-rollback-of-internet-blackout-begins
- Cafe Bazaar (reference); TechCrunch on Google Play in Iran; The Hacker News on Android developer verification: https://en.wikipedia.org/wiki/Cafe_Bazaar · https://techcrunch.com/2013/08/26/android-developers-can-now-use-googles-play-store-to-distribute-their-free-apps-in-iran/ · https://thehackernews.com/2026/06/google-sets-sept-30-deadline-for.html

37.5 Cargo

- Royal Mail international updates: https://www.royalmail.com/internationalupdates · FedEx countries not served: https://www.fedex.com/en-jp/customer-support/faq/sending/what-goods-can-i-send/countries-not-served.html
- cargo.one; CargoAi pricing; Freightos for Forwarders; IATA ONE Record: https://www.cargo.one/ · https://cargoai.co/pricing · https://www.freightos.com/forwarders/ · https://www.iata.org/en/programs/cargo/e/one-record/
- WFS sanctions operating procedure: https://www.wfs.aero/wp-content/uploads/2024/04/Sanctions-Operating-Procedure-1.pdf
- Send My Bag destinations: https://www.sendmybag.com/en-gb/baggage-shipping-destinations/